



PAROLA VE KİMLİK DOĞRULAMA GÜVENLİĞİ

*Parola Elde Etme ve Kırma Mantığını
Savunma Perspektifiyle Anlamak*

AKADEMİK İNCELEME VE UYGULAMA REHBERİ

HAZIRLAYAN

Cuma KURT

Birinci Baskı — 2026

Bu çalışma GNU Genel Kamu Lisansı (GPL v3) kapsamında
belirtilen koşullarla dağıtılabilir ve değiştirilebilir.
Savunma odaklı eğitim amaçlı hazırlanmıştır.

LİSANS VE YAYIN BİLGİLERİ

Çalışma Adı: Parola ve Kimlik Doğrulama Güvenliği — Parola Elde Etme ve Kırma Mantığını Savunma Perspektifiyle Anlamak

Hazırlayan: Cuma KURT | **Baskı:** Birinci Baskı, 2026 | **Lisans:** GNU GPL v3.0

Bu çalışma, GNU Genel Kamu Lisansı'nın 3. sürümü altında yayımlanmıştır. Özgür yazılım hareketinin temelini oluşturan bu lisans, kullanıcılara geniş özgürlükler tanır.

Temel Haklar: Çalıştırma • İnceleme • Değiştirme • Yeniden dağıtma • Geliştirme özgürlükleri.

Koşullar: Değiştirilmiş versiyonlarda bu lisansın korunması, değişikliklerin belgelenmesi ve aynı lisans koşulları altında dağıtılması gerekmektedir.

Sorumluluk Reddi: Bu çalışma "olduğu gibi" sunulmaktadır. Hiçbir garanti verilmemektedir.

Tam Lisans: [GNU GPL v3.0 Türkçe metni](#)

Bu çalışma özgür yazılımdır. Belirtilen koşullar altında yeniden dağıtabilir ve/veya değiştirebilirsiniz.

İÇİNDEKİLER

Etik Beyan.....	4
Özet.....	4
Abstract.....	5
Kısaltmalar Listesi.....	5
Terimler Sözlüğü.....	7
Giriş	8
BÖLÜM 1 — PAROLA GÜVENLİĞİNE GİRİŞ	14
BÖLÜM 2 — TEMEL KAVRAMLAR	22
BÖLÜM 3 — PAROLA SAKLAMA GÜVENLİĞİ.....	30
BÖLÜM 4 — PAROLA POLİTİKALARI	39
BÖLÜM 5 — PAROLA ELDE ETME YÖNTEMLERİNİN KAVRAMSAL SINIFLANDIRMASI.....	55
BÖLÜM 6 — PAROLA KIRMA MANTIĞI.....	71
BÖLÜM 7 — ÇOK FAKTÖRLÜ KİMLİK DOĞRULAMA (MFA).....	89
BÖLÜM 8 — PAROLASIZ KİMLİK DOĞRULAMA VE PASSKEY.....	108
BÖLÜM 9 — PAROLA YÖNETİCİLERİ	125
BÖLÜM 10 — UYGULAMA GELİŞTİRİCİLER İÇİN GÜVENLİ KİMLİK DOĞRULAMA	142
BÖLÜM 11 — KURUMSAL İZLEME VE TESPİT	159
BÖLÜM 12 — OLAY MÜDAHALESİ: PAROLA SIZINTISI	174
BÖLÜM 13 — HUKUK VE ETİK.....	192
BÖLÜM 14 — AKADEMİK LABORATUVAR TASARIMI.....	199
BÖLÜM 15 — KONTROL LİSTELERİ.....	207
Sonuç ve Gelecek Eğilimler	214
Kaynakça.....	217

ETİK BEYAN

Bu çalışma, parola ve kimlik doğrulama güvenliği alanında eğitim, araştırma ve yetkili kurumsal denetim amacıyla hazırlanmıştır. Çalışmada yer alan tüm içerik savunma odaklıdır; gerçek kişi, kurum veya sistemlere yönelik operasyonel saldırı reçeteleri içermemektedir. Okuyucular, bu çalışmadaki bilgileri yalnızca yasal çerçevenin izin verdiği ölçüde, yazılı izin dahilinde ve etik ilkelere bağlı kalarak kullanmakla yükümlüdür.

Çalışmada geçen tüm örnekler sentetik ve soyut niteliktedir. Gerçek kullanıcı parolası, sızıntı veri seti veya gerçek hedef bilgisi kullanılmamıştır. Bu çalışma; akademik dürüstlük, veri minimizasyonu ve sorumlu açıklama ilkeleriyle hazırlanmıştır.

TEŞEKKÜR

Bu çalışmanın hazırlanmasına dolaylı veya doğrudan katkı sağlayan akademik danışmanlara, siber güvenlik topluluğuna, açık kaynak projelerine ve kurumsal güvenlik uzmanlarına teşekkür ederiz. Özellikle NIST, OWASP, ENISA, CISA, IETF, W3C ve FIDO Alliance tarafından yayımlanan açık standart ve kılavuzlar, çalışmanın temel dayanaklarını oluşturmuştur.

ÖZET

Parola ve Kimlik Doğrulama Güvenliği başlıklı bu çalışma, parola ve kimlik doğrulama mekanizmalarını teknik, insani, kurumsal ve hukuki boyutlarıyla incelemektedir. On beş bölümden oluşan çalışma; temel terminoloji, parola saklama, politika tasarımı, kimlik bilgisi elde etme riskleri, çevrim içi ve çevrim dışı tahmin modelleri, çok faktörlü ve kimlik avına dayanıklı doğrulama, passkey, parola yöneticileri, güvenli yazılım geliştirme, kurumsal izleme, olay müdahalesi, hukuk ve etik, güvenli laboratuvar tasarımı ile rol bazlı kontrol listelerini kapsamaktadır.

Çalışmada yapılandırılmış literatür taraması, standart karşılaştırması, tehdit-kontrol eşleştirmesi ve sentetik senaryo analizi birlikte kullanılmıştır. Saldırı mantığı, kötüye kullanımı kolaylaştıracak operasyonel ayrıntılara girilmeden

açıklanmıştır. Bulgular, resmî standartlar ile hakemli çalışmalar arasında ayrım gözetilerek sunulmuş; sayısal modellerin varsayımları açıkça belirtilmiştir. Çalışma deneysel bir etkililik araştırması veya hukuki görüş değildir; kontroller kurumun risk profiline göre doğrulanmalıdır.

Anahtar Kelimeler: Parola güvenliği, kimlik doğrulama, çok faktörlü kimlik doğrulama, passkey, parola yöneticisi, hash algoritmaları, NIST, OWASP, siber güvenlik, kurumsal güvenlik.

ABSTRACT

Password and Authentication Security examines password and authentication mechanisms from technical, human, organizational, and legal perspectives. Its fifteen chapters cover terminology, password storage, policy design, credential-acquisition risks, online and offline guessing models, multi-factor and phishing-resistant authentication, passkeys, password managers, secure software development, enterprise monitoring, incident response, law and ethics, safe laboratory design, and role-based checklists.

The study combines a structured literature review, standards comparison, threat-control mapping, and synthetic scenario analysis. Attack logic is discussed without operational detail that would facilitate misuse. Official standards and peer-reviewed evidence are distinguished, and the assumptions underlying quantitative models are stated. This work is neither an experimental effectiveness study nor legal advice; organizations should validate controls against their own risk profiles.

Keywords: Password security, authentication, multi-factor authentication, passkey, password manager, hash algorithms, NIST, OWASP, cybersecurity, enterprise security.

KISALTMALAR LİSTESİ

Kısaltma	Tam Açıklaması
API	Application Programming Interface (Uygulama Programlama Arayüzü)
CTAP	Client to Authenticator Protocol

Kısaltma	Tam Açıklaması
ENISA	European Union Agency for Cybersecurity (Avrupa Birliği Siber Güvenlik Ajansı)
FIDO	Fast Identity Online (Hızlı Kimlik Doğrulama)
GDPR	General Data Protection Regulation (Genel Veri Koruma Yönetmeliği)
HMAC	Hash-based Message Authentication Code
HOTP	HMAC-based One-Time Password
IAM	Identity and Access Management (Kimlik ve Erişim Yönetimi)
JWT	JSON Web Token
KVKK	Kişisel Verilerin Korunması Kanunu
MFA	Multi-Factor Authentication (Çok Faktörlü Kimlik Doğrulama)
NIST	National Institute of Standards and Technology (Ulusal Standartlar ve Teknoloji Enstitüsü)
OWASP	Open Web Application Security Project (Açık Web Uygulaması Güvenliği Projesi)
PBKDF2	Password-Based Key Derivation Function 2
PCI DSS	Payment Card Industry Data Security Standard
PIN	Personal Identification Number (Kişisel Kimlik Numarası)
RBAC	Role-Based Access Control (Rol Tabanlı Erişim Kontrolü)
SAML	Security Assertion Markup Language
SIEM	Security Information and Event Management (Güvenlik Olayı ve Etkinlik Yönetimi)
SOC	Security Operations Center (Güvenlik Operasyonları Merkezi)
SSO	Single Sign-On (Tek Oturum Açma)
TOTP	Time-based One-Time Password
WebAuthn	Web Authentication API

Kısaltma	Tam Açıklaması
XSS	Cross-Site Scripting

TERİMLER SÖZLÜĞÜ

Biyometrik Kimlik Doğrulama: Parmak izi, yüz tanıma, iris tarama gibi fizyolojik veya davranışsal özelliklerin kullanılarak yapılan kimlik doğrulama yöntemi.

Challenge-Response: Kimlik doğrulamada sunucunun bir "meydan okuma" (challenge) değeri ürettiği ve istemcinin bunu özel anahtarıyla imzalayarak yanıt verdiği mekanizma.

Credential Stuffing: Bir sızıntıdan elde edilen kullanıcı adı-parola çiftlerinin, farklı sistemlerde otomatik olarak denenmesi saldırısı.

Düz Metin (Plaintext): Şifrelenmemiş, doğrudan okunabilir formattaki veri.

Entropi: Parolanın rastgeleliğinin veya tahmin edilmesinin zorluğunun matematiksel ölçüsü.

FIDO2: Fast Identity Online 2, web tabanlı uygulamalarda parolasız ve MFA kimlik doğrulama sağlayan açık standart.

Gizli Bilgi (Secret): API anahtarı, token, parola gibi korunması gereken hassas veriler.

Hash Fonksiyonu: Bir girdiyi sabit uzunlukta bir çıktıya dönüştüren ve bu dönüşümün tersinin pratikte yapılamadığı matematiksel fonksiyon.

JWT (JSON Web Token): Taraflar arasında iddiaları (claims) kompakt biçimde taşımak için kullanılan standart token biçimi. İmzalı JWT bütünlük ve kaynak doğrulaması sağlayabilir; içerik, ayrıca şifrelenmedikçe gizli değildir.

Key Stretching: Bir parolanın hesaplama maliyetini kasıtlı olarak artırarak kaba kuvvet saldırılarına karşı dayanıklılığını artıran teknik.

Oturum (Session): Kullanıcının kimlik doğrulamasından sonra sistemle kurduğu ve belirli bir süre devam eden etkileşim süresi.

Parola (Password): Kimlik doğrulama sürecinde kullanıcı tarafından bilinen bir sırda dayalı kimlik doğrulama faktörü.

Parola Yöneticisi: Kullanıcıların benzersiz ve karmaşık parolaları güvenli bir şekilde saklamasını ve yönetmesini sağlayan yazılım aracı.

Passphrase: Uzun, kelimelerden oluşan, hatırlanabilir ancak tahmin edilmesi zor parola türü.

Passkey: FIDO2 tabanlı, parolasız kimlik doğrulama sağlayan, açık anahtar kriptografisine dayanan kimlik bilgisi.

Pepper: Parola hash sürecinde eklenen, veri tabanından farklı bir yerde saklanan gizli değer.

Phishing-Resistant MFA: Kimlik avı saldırılarına karşı dayanıklı olan, sunucu-istemci arasındaki bağı doğrudan kuran MFA yöntemi.

Risk Tabanlı Doğrulama: Giriş girişiminin risk seviyesine göre ek doğrulama adımları talep eden mekanizma.

Salt: Parolanın hash'lenmesinden önce parolaya eklenen benzersiz rastgele değer.

Sıfır Güven (Zero Trust): Hiçbir kullanıcıya, cihaza veya ağa varsayılan olarak güvenilmeyen; her erişim isteği için doğrulama ve yetkilendirme gerektiren güvenlik modeli.

Token: Kimlik doğrulama sürecinde veya sonrasında erişim izni veren dijital bilgi taşıyıcısı.

TOTP (Time-based One-Time Password): Belirli zaman aralıklarında bir kerelik şifre üreten algoritma.

GİRİŞ

Araştırma Problemi

Bilişim hizmetlerinin yaygınlaşmasıyla dijital kimlikler, bireylerin ve kurumların korunması gereken temel varlıklarından biri hâline gelmiştir. Kimlik bilgilerinin kötüye kullanımı, kimlik avı, parola tekrar kullanımı, zayıf kurtarma süreçleri ve oturum ele geçirme gibi farklı yollarla hesap ihlaline dönüşebilmektedir. Bu

nedenle parola güvenliği, tek başına bir parola politikası olarak değil; kimlik yaşam döngüsü, çok faktörlü doğrulama, oturum güvenliği, izleme ve olay müdahalesiyle birlikte ele alınmalıdır.

Parola tabanlı kimlik doğrulama hâlâ yaygın biçimde kullanılmaktadır. Kullanıcıların çok sayıda hesabı yönetmesi, benzersiz ve rastgele parolaları insan belleğiyle sürdürülebilir biçimde yönetmeyi güçleştirir; ancak parola tekrar kullanımı kaçınılmaz değildir. Parola yöneticileri, kimlik avına dayanıklı MFA ve passkey gibi kontroller bu yükü azaltabilir. Riskin kaynağı yalnızca kullanıcı davranışı değil; güvenli olmayan saklama, yetersiz hız sınırlama, zayıf hesap kurtarma ve görünürlük eksikliğidir.

Kitabın araştırma problemi şu şekilde ifade edilebilir:

Modern kurumlarda parola ve kimlik doğrulama güvenliği; kullanıcı davranışı, teknik mimari, yazılım geliştirme, olay müdahalesi ve etik sınırlar birlikte ele alınmadan sürdürülebilir biçimde sağlanamaz.

Bu problem, yalnızca teknik bir sorun olarak ele alınamaz. İnsan davranışı, kurumsal süreçler, yazılım güvenliği, yasal düzenlemeler ve etik sınırlar bir bütün olarak değerlendirilmelidir. Çalışma, bu kapsamlı yaklaşımı benimseyerek parola güvenliği sorununu çok boyutlu biçimde ele almaktadır.

Araştırma Soruları

Bu çalışma aşağıdaki temel araştırma sorularına cevap aramaktadır:

1. Modern parola güvenliği hangi temel kavramlar ve standartlar üzerine kurulmalıdır?
2. Parola saklama, parola politikası ve parola sıfırlama süreçleri hangi tasarım ilkeleriyle güvenli hale getirilebilir?
3. Parola elde etme ve parola kırma mantığı, kötüye kullanıma yol açmadan nasıl akademik ve savunma odaklı anlatılabilir?
4. MFA ve phishing-resistant MFA, parola kaynaklı riskleri hangi ölçüde azaltır?
5. Passkey ve parolasız kimlik doğrulama, klasik parola modelinin hangi zayıflıklarını giderir?

6. Kurumsal izleme ve olay müdahalesi süreçleri parola güvenliğiyle nasıl entegre edilmelidir?
7. Türkçe bir akademik kaynak, etik ve hukuki sınırları koruyarak nasıl başvuru kitabı haline getirilebilir?

Araştırma Yöntemi

Bu çalışmada aşağıdaki yöntemler birlikte kullanılmıştır:

Yapılandırılmış Literatür İncelemesi: NIST SP 800-63B-4, OWASP rehberleri, IETF RFC'leri, W3C WebAuthn standardı, FIDO Alliance belgeleri ve seçilmiş hakemli çalışmalar; güncellik, kaynak otoritesi ve konuya doğrudanlık ölçütleriyle incelenmiştir.

Standart Analizi: Kimlik doğrulama, parola politikası ve parola saklama gereksinimleri, güncel standartlar ve kılavuzlar karşılaştırılarak analiz edilmiştir.

Kavramsal Modelleme: Parola saldırı mantığı, operasyonel detaylara girmeden risk modeli olarak açıklanmıştır. Bu yaklaşım, kitabın savunma odaklı yapısını korumaktadır.

Kontrol Eşleştirme: Her risk, uygulanabilir savunma kontrolüyle ilişkilendirilerek, okuyucuya somut aksiyon önerileri sunulmuştur.

Vaka Analizi: Gerçek hedef veya gerçek parola verisi kullanılmadan, sentetik ve soyut senaryolar hazırlanmıştır. Bu sayede etik sınırlar korunurken öğretici değer artırılmıştır.

Güvenli Laboratuvar Tasarımı: Sadece izole, sentetik veriye dayalı, savunma odaklı ve etik deneyler planlanmıştır.

Uygulanabilir Şablon Üretimi: Politika, kontrol listesi, olay müdahale formu ve denetim matrisi üretilerek kitabın pratik değeri artırılmıştır.

Yöntemin Sınırlılıkları

Bu çalışma sistematik derleme protokolüyle yürütülmüş bir meta-analiz değildir. Ürünlere özgü uygulama ayrıntıları ve mevzuat yorumları zaman içinde değişebilir. Sayısal tahmin örnekleri; aday uzayının eş olasılıklı olduğu, belirtilen deneme hızının sabit kaldığı ve ek savunma kontrollerinin bulunmadığı sentetik varsayımlara dayanır. Bu nedenle tablolar gerçek bir kullanıcı parolasının kırılma

süresini öngörmez; yalnızca değişkenler arasındaki ilişkiyi gösterir. Hukuki bölüm genel bilgilendirme niteliğindedir ve somut olay için uzman görüşünün yerini tutmaz.

Kanıt ve Kaynak Kullanım İlkesi

Normatif gereksinimler için resmî standartların son sürümleri; uygulama önerileri için kurumsal teknik rehberler; kullanıcı davranışı ve kullanılabilirlik iddiaları için ise öncelikle hakemli çalışmalar esas alınmıştır. Pazarlama raporlarından alınan doğrulanması güç yüzdeler kullanılmamış, güncellenen web kaynaklarında erişim tarihi belirtilmiştir. Kaynakçada yalnızca metinde karşılığı bulunan ve bibliyografik olarak izlenebilir eserler tutulmuştur.

Kapsam

Çalışma aşağıdaki konuları kapsamaktadır:

- Parola, PIN, passphrase ve kimlik bilgisi kavramları
- Parola saklama güvenliği (hash, salt, pepper, key stretching)
- Modern parola politikaları (NIST, OWASP yönergeleri)
- Parola elde etme risklerinin sınıflandırılması
- Parola kırma mantığının matematiksel ve savunma odaklı açıklaması
- Çok faktörlü kimlik doğrulama (MFA) ve phishing-resistant MFA
- Passkey ve parolasız kimlik doğrulama
- Parola yöneticileri
- Uygulama geliştiriciler için güvenli kimlik doğrulama tasarım ilkeleri
- Kurumsal izleme ve tespit (SIEM, SOC)
- Parola sızıntısı olay müdahalesi
- Hukuk ve etik (KVKK, GDPR, akademik etik)
- Güvenli akademik laboratuvar tasarımı
- Rol bazlı kontrol listeleri

Hedef Okuyucu Profilleri

Okuyucu Profili	Beklenen Kazanım	İçerik Derinliği
Üniversite öğrencisi	Kimlik doğrulama ve parola güvenliği temellerini öğrenir	Kavramsal + akademik
Siber güvenlik uzmanı	Kurumsal parola risklerini sınıflandırır ve kontrol önerir	Orta/ileri
Yazılım geliştirici	Güvenli giriş, kayıt, sıfırlama ve oturum yönetimi tasarlar	Uygulamalı savunma
Sistem yöneticisi	Parola politikası, MFA ve hesap yönetimini uygular	Operasyonel savunma
SOC analisti	Parola saldırı sinyallerini izler ve olayları önceliklendirir	Tespit odaklı
Denetçi	Politika, kanıt ve kontrol uyumluluğunu değerlendirir	Kontrol/uyum
Yönetici	Parola riskini iş riski olarak anlar ve yol haritası belirler	Stratejik

Kitabın Yapısı

Çalışma 15 bölümden oluşmaktadır ve üç ana katmandan yapılandırılmıştır:

Temel Bölüm (1-3): Parola güvenliğinin temelleri. Tüm okuyucular için zorunlu temel bilgi. Parola güvenliğine giriş, temel kavramlar ve parola saklama güvenliğini kapsar.

Risk ve Savunma Bölümü (4-9): Parola politikaları, elde etme riskleri, kırma mantığı, MFA, passkey ve parola yöneticileri. Orta ve ileri düzey okuyucular için.

Kurumsal Uygulama Bölümü (10-15): Güvenli geliştirme, izleme, olay müdahalesi, hukuk/etik, laboratuvar tasarımı ve kontrol listeleri. Profesyonel ve akademik okuyucular için.

Her bölüm aşağıdaki pedagojik yapıyı izlemektedir:

1. Bölüm amacı
2. Araştırma soruları

3. Detaylı akademik açıklama
 4. Öğrenme çıktıları
 5. Risk modeli ve savunma kontrolleri
 6. Tablolar ve görsel açıklamaları
 7. Güvenli anlatım notu
 8. Bölüm sonu özet
 9. Kontrol listesi
 10. Tartışma soruları
 11. Kaynaklar
-

BÖLÜM 1 — PAROLA GÜVENLİĞİNE GİRİŞ

↪ İçindekilere dön

1.1 Bölüm Amacı

Bu bölümün temel amacı, parolanın hâlâ modern siber güvenliğin en kritik risk alanlarından biri olduğunu tarihsel, kurumsal ve kullanıcı davranışı perspektifiyle açıklamaktır. Parola güvenliğinin neden yalnızca teknik bir konu olmadığını, aynı zamanda sosyo-teknik bir risk alanı olduğunu kavratmak temel hedeftir.

Bu bölüm tamamlandığında okuyucu, parola güvenliğinin temel kavramlarını doğru terminolojiyle açıklayabilecek, ilgili riskleri savunma perspektifiyle sınıflandırabilecek, kurumsal veya yazılım geliştirme bağlamında uygulanabilir güvenlik kontrolleri önerebilecek ve etik ve hukuki sınırları ihlal etmeden güvenli değerlendirme yapabilecektir.

1.2 Araştırma Soruları

- Parola neden teknik bir kontrol olmaktan çok sosyo-teknik bir risk alanıdır?
- Parola tekrar kullanımı, e-posta hesabı ve yönetici hesapları neden çarpan etkisi üretir?
- Kurumların parola riskini yalnızca parola karmaşıklığıyla yönetmeye çalışması neden yetersizdir?

1.3 Parola, PIN, Passphrase ve Kimlik Bilgisi Ayrımı

Kimlik doğrulama süreçlerinde sıklıkla karıştırılan dört temel kavram bulunmaktadır. Bu kavramları doğru biçimde ayırt etmek, parola güvenliğinin temelini oluşturmaktadır.

Parola (Password): Bilinen bir sırra dayalı (something you know) kimlik doğrulama faktörüdür. Kullanıcının girdiği sır, doğrulayıcıda düz metin olarak değil güvenli bir parola hash şemasıyla korunmalıdır. Güçlü bir parola başka hizmetlerde kullanılmayan, engelli parola listesinde bulunmayan ve üretim yöntemi bakımından tahmin edilmesi zor bir değerdir (NIST, 2025).

PIN (Personal Identification Number / Kişisel Kimlik Numarası): Genellikle 4-6 haneli, yalnızca rakamlardan oluşan kısa bir kimlik doğrulama değeridir. PIN, parolaya göre çok daha düşük entropiye sahiptir ve banka kartları, ATM'ler ve mobil cihaz kilitleme gibi bağlamlarda kullanılır. PIN'in kısa yapısı, brute-force (kaba kuvvet) saldırılarına karşı daha savunmasız olmasına neden olur; bu nedenle genellikle ek kontroller (yanlış deneme sınırı, cihaz kilidi) ile birlikte kullanılır.

Passphrase (Parola İfadesi): Birden fazla kelimedenden oluşan uzun parola türüdür. Güvenliği yalnızca uzunluğa değil, kelimelerin nasıl seçildiğine bağlıdır. Geniş bir listeden bağımsız ve rastgele seçilen kelimeler ölçülebilir tahmin direnci sağlayabilir; kullanıcı tarafından kurulan yaygın söz veya alıntılar aynı güvenceyi vermez.

Kimlik Bilgisi (Credential): Bir varlığın kimliğini doğrulamak için kullanılan parolayı, özel anahtar kontrollü doğrulayıcıyı, sertifikayı veya token'ı kapsayan genel terimdir. Biyometrik özellik çoğu modern tasarımda uzak hizmete sunulan kimlik bilgisi değil, cihazdaki doğrulayıcıyı etkinleştiren yerel bir kullanıcı doğrulama yöntemidir.

Bu dört kavram arasındaki temel farklar aşağıdaki tabloda özetlenmiştir:

Kavram	Bileşen	Uzunluk	Entropi	Kullanım Bağlamı
Parola	Harf, rakam, özel karakter	8-64+ karakter	Orta-Yüksek	Web, uygulama, sistem girişi
PIN	Yalnızca rakam	4-6 hane	Düşük	ATM, cihaz kilidi, kart
Passphrase	Kelime dizisi	20-60+ karakter	Yüksek	Web girişi, şifreleme anahtarı
Kimlik Bilgisi	Tüm kimlik varlıkları	Değişken	Değişken	Tüm kimlik doğrulama süreçleri

1.4 Kimlik Doğrulamada "Bildiğin Şey" Faktörünün Sınırları

Klasik kimlik doğrulama üç temel faktöre dayanır: bildiğin şey (something you know), sahip olduğun şey (something you have) ve olduğun şey (something you are). Parola, "bildiğin şey" kategorisine girer ve bu faktörün en yaygın uygulamasıdır.

Ancak "bildiğin şey" faktörünün doğal sınırları bulunmaktadır:

İnsan Hafızasının Sınırları: Çok sayıda bağımsız ve rastgele sırrı hatırlamak güçtür. Kullanıcılar bu yükü azaltmak için tekrar kullanım veya öngörülebilir kalıplara yönelebilir. Parola yöneticileri ve otomatik üretim desteği, güvenliği yalnızca insan belleğine bırakmaz (NIST, 2025).

Benzersizlik Gereksinimi: Aynı parolanın birden fazla hizmette kullanılması, tek bir sızıntının diğer hesaplarda kimlik bilgisi doldurma saldırısına dönüşmesine yol açar. Her hizmet için benzersiz parola üretmek ve saklamak üzere uygun bir parola yöneticisi kullanılması bu riski azaltır (Das vd., 2014).

Paylaşım ve Not Alma: Kullanıcıların önemli bir bölümü, parolalarını güvensiz yöntemlerle paylaşmakta (e-posta, mesajlaşma uygulamaları) veya fiziksel/dijital ortamda not almaktadır. Bu davranış, parolanın "sır" olma niteliğini doğrudan zedelemektedir.

Sosyal Mühendislik Direnci: İnsanlar, sosyal mühendislik saldırılarına karşı teknik kontrollere göre çok daha savunmasızdır. Parola, bir insandan elde edilebilecek bir bilgi olduğundan, sosyal mühendislik yoluyla ele geçirilmesi teknik kaba kuvvet saldırısına göre çok daha kolaydır.

Bu sınırlamalar, parolanın tek başına yeterli bir güvenlik önlemi olmadığını açıkça göstermektedir. Bu nedenle modern güvenlik mimarileri, parolayı MFA, risk tabanlı doğrulama ve parolasız kimlik doğrulama gibi ek mekanizmalarla desteklemektedir.

1.5 İnsan Faktörü: Hatırlanabilirlik, Tekrar Kullanım, Not Alma ve Paylaşım

Parola güvenliğinin en zayıf halkası genellikle insandır. İnsan faktörünün parola güvenliğine etkisi çok boyutludur ve kurumsal güvenlik politikalarının bu gerçeği hesaba katması gerekmektedir.

Hatırlanabilirlik: Kullanıcı tarafından seçilen parolalar dil, klavye ve kişisel bağlam kalıpları taşıyabilir. Zorunlu karakter türleri bu sorunu tek başına çözmez; kullanıcılar küçük ve öngörülebilir dönüşümlere yönelebilir. Parola yöneticisi ve engelli parola listesi, yalnızca biçim kuralına dayanan politikalardan daha doğrudan kontroller sunar.

Tekrar Kullanım Riski: Parola tekrar kullanımı, bir hizmetteki sızıntının başka hizmetlerde hesap ele geçirmeye dönüşmesine yol açar. Kimlik bilgisi doldurma saldırıları bu zayıflıktan yararlanır. Benzersiz parola, parola yöneticisi ve MFA birlikte uygulanmalıdır (OWASP, t.y.).

Not Alma ve Kayıt Tutma: Kullanıcılar, karmaşık parolaları hatırlayamadıklarında bunları-defterlere, yapışkan notlara, e-posta taslaklarına veya güvensiz dijital ortamlara kaydeder. Bu durum, parolanın fiziksel veya dijital olarak ele geçirilme riskini büyük ölçüde artırır. Kurumsal ortamlarda, parolaların paylaşıldığı e-posta zincirleri veya ortak belgeler ciddi güvenlik açığı oluşturur.

Paylaşım Davranışı: Ekip içi işbirliği ihtiyacı, kullanıcıları parola paylaşımına yönlendirebilir. Sistem yöneticilerininaynı parolayı birden fazla sistemde kullanması veya ekip üyelerinin servis hesabı parolalarını güvensiz yollardan paylaşması, kurumsal güvenlik için ciddi risk oluşturmaktadır.

İnsan faktörünün bu boyutları, parola güvenliğinin yalnızca teknik kontrollerle çözülemeyeceğini açıkça ortaya koymaktadır. Eğitim, farkındalık, politika ve teknik kontrollerin birlikte uygulanması gereklidir.

1.6 Kurumsal Saldırı Yüzeyi

Modern kurumlarda parola güvenliği, çok geniş bir saldırı yüzeyine sahiptir. Kurumsal ortamda parolalar aşağıdaki sistemler ve süreçler aracılığıyla risk altındadır:

E-posta Sistemleri: E-posta, kurumsal iletişimin temel taşıdır ancak aynı zamanda kimlik avı (phishing) saldırılarının ana vektörüdür. Saldırganlar, sahte e-postalar aracılığıyla kullanıcıları parolalarını girmeye veya zararlı bağlantılara tıklamaya yönlendirir. E-posta tabanlı kimlik doğrulama (şifre sıfırlama linkleri, MFA kodları) ayrıca bir risk kaynağıdır.

VPN ve Uzaktan Erişim: Uzaktan çalışma düzeninin yaygınlaşmasıyla birlikte, VPN erişim noktaları parola saldırılarının önemli hedeflerinden biri olmuştur. Zayıf VPN parolaları veya çalınan VPN kimlik bilgileri, saldırırganların kurumsal ağa doğrudan erişmesine olanak tanır.

Bulut Hizmetleri: AWS, Azure, Google Cloud ve SaaS uygulamaları (Microsoft 365, Salesforce, Slack) gibi bulut hizmetleri, kurumsal verilerin büyük bir kısmını barındırır. Bulut hesaplarının kimlik doğrulama mekanizmalarındaki zayıflıklar, geniş çaplı veri sızıntılarına yol açabilir.

SSO (Tek Oturum Açma) Sistemleri: SSO, kullanıcı deneyimini iyileştirirken tek bir parola sızıntısının tüm bağlı sistemleri tehlikeye atması riskini de beraberinde getirir. SSO'nun avantajları ve riskleri dengeli biçimde yönetilmelidir.

Yönetici Panelleri ve Veritabanları: Veritabanı yönetim arayüzleri (phpMyAdmin, pgAdmin), yönetim panelleri ve SSH erişim noktaları, ayrıcalık hesapların parolaları için yüksek değerli hedeflerdir. Yönetici hesaplarının parola güvenliği, kurumsal güvenliğin en kritik bileşenlerinden biridir.

API'ler ve Servis Hesapları: Modern uygulamalar, birbirleriyle API'ler aracılığıyla iletişim kurar. API anahtarları ve servis hesabı kimlik bilgileri, parola güvenliği kapsamına giren ancak sıklıkla göz ardı edilen bileşenlerdir. Bu tür kimlik bilgilerinin rotasyonu, izlenmesi ve güvenli saklanması kritik önem taşır.

Kurumsal saldırı yüzeyinin genişliği, parola güvenliğinin çok katmanlı ve kapsamlı bir yaklaşımla ele alınmasını gerektirir.

1.7 Parola Riskinin İş Sürekliliğiyle İlişkisi

Parola kaynaklı güvenlik olayları, yalnızca teknik bir sorun olmaktan çıkarak doğrudan iş sürekliliği, veri koruma ve kurumsal itibar riskleri yaratmaktadır.

İş Sürekliliği Üzerine Etki: Bir parola sızıntısı veya hesap ele geçirme olayı, kurumun operasyonel süreçlerini ciddi biçimde aksatabilir. Hesapların kilitlenmesi, sistemlerin geçici olarak devre dışı bırakılması, verilerin şifrelenmesi (ransomware) veya manipüle edilmesi, iş süreçlerinin durmasına veya yavaşlamasına neden olabilir. Büyük ölçekli bir parola sızıntısı, haftalarca süren operasyonel aksamalara yol açabilir.

Veri Koruma Boyutu: KVKK (Kişisel Verilerin Korunması Kanunu) ve GDPR gibi düzenlemeler, kurumların kişisel verileri koruma yükümlülüğünü açıkça ortaya koymaktadır. Parola kaynaklı bir ihlal sonucunda kişisel verilerin ele geçirilmesi, kurumlara ciddi idari para cezaları ve hukuki sorumluluklar yükleyebilir. KVKK kapsamında 2024 yılı itibarıyla uygulanan idari para cezaları milyonlarca Türk Lirasına ulaşabilmektedir.

İtibar Riski: Müşterilerin ve iş ortaklarının güvenini kaybetmek, maddi cezalardan çok daha uzun vadeli ve telafisi zor bir sonuç doğurabilir. Parola sızıntısı haberleri medyada geniş yer bulmakta ve kurumların itibarına ciddi zararlar verebilmektedir.

Düzenleyici Uyum: PCI DSS, HIPAA, SOX gibi düzenleyici gereksinimler, parola politikaları ve kimlik doğrulama güvenlik kontrolleri için açık standartlar belirlemektedir. Bu standartlara uyumsuzluk, denetim cezaları ve operasyonel kısıtlamalara yol açabilir.

Zincir Etkisi: Kurumların parola sızıntısı, tedarik zincirindeki diğer kurumları da etkileyebilir. Ortak hesaplar, entegre sistemler ve paylaşımlı kimlik bilgileri, tek bir parola sızıntısının birden fazla kuruma yayılmasına neden olabilir.

1.8 Risk-Kontrol Eşleştirme Tablosu

Aşağıdaki tablo, parola güvenliği alanındaki temel riskleri ve bunlara karşılık gelen savunma kontrollerini özetlemektedir:

Risk	Kök Neden	Savunma Kontrolü	Öncelik
Parola tekrarı kullanımı	İnsan hafıza sınırlaması	Parola yöneticisi, benzersiz parola politikası	Yüksek
Zayıf parola seçimi	Kullanıcı davranışı	Yasaklı parola listeleri, minimum uzunluk	Yüksek

Risk	Kök Neden	Savunma Kontrolü	Öncelik
Parola sızıntısı	Veri ihlali	Strong hash (Argon2id), pepper, izleme	Kritik
Kimlik avı (phishing)	Sosyal mühendislik	Phishing-resistant farkındalık eğitimi	Kritik
Kaba kuvvet saldırısı	Zayıf rate limiting	Hız sınırlama, hesap kilitleme, MFA	Yüksek
Parola not alma	Hatırlanabilirlik	Parola yöneticisi, eğitim	Orta
Güvensiz parola sıfırlama	Zayıf süreç tasarımı	Güvenli akış, tek kullanımlık token	Yüksek
Oturum hırsızlığı	Zayıf token yönetimi	HTTPS, secure cookie, token süre sonu	Yüksek
Servis hesabı parolası sızıntısı	Rotasyon eksikliği	Otomatik rotasyon, sır deposu	Yüksek
Yönetici hesabı ele geçirme	Ayrıcalık yoğunluğu	PAM, MFA zorunluluğu, denetim	Kritik

1.9 Bölüm Özeti

Bu bölümde parola güvenliğinin temelleri ele alınmıştır. Parola, PIN, passphrase ve kimlik bilgisi kavramları arasındaki farklar netleştirilmiştir. Kimlik doğrulamada "bildiğin şey" faktörünün doğal sınırları açıklanmış, insan faktörünün parola güvenliğine etkisi (hatırlanabilirlik, tekrar kullanım, not alma, paylaşım) analiz edilmiştir. Kurumsal saldırı yüzeyinin genişliği ve parola riskinin iş sürekliliği, veri koruma ve itibarla olan ilişkisi değerlendirilmiştir. Son olarak risk-kontrol eşleştirme tablosu sunularak, her risk için uygulanabilir savunma kontrolleri önerilmiştir.

Parola güvenliği, yalnızca teknik bir konu olarak ele alınamaz; insan davranışı, kurumsal süreçler ve etik sınırlar bir bütün olarak değerlendirilmelidir. Bir sonraki bölümde, kimlik doğrulama ve parola güvenliği alanındaki temel kavramlar daha ayrıntılı biçimde ele alınacaktır.

1.10 Kontrol Listesi

- [] Parola, PIN, passphrase ve kimlik bilgisi kavramları tanımlandı.
- [] "Bildiğin şey" faktörünün sınırları açıklandı.
- [] İnsan faktörünün parola güvenliğine etkisi analiz edildi.
- [] Kurumsal saldırı yüzeyi tanımlandı.
- [] Parola riskinin iş sürekliliğiyle ilişkisi açıklandı.
- [] Risk-kontrol eşleştirme tablosu sunuldu.
- [] Tüm teknik iddialar kaynaklandı.
- [] Kötüye kullanıma açık operasyonel ayrıntı verilmedi.
- [] Bölüm sonunda özet ve tartışma soruları eklendi.

1.11 Tartışma Soruları

1. Parola tek başına yeterli bir kimlik doğrulama mekanizması olarak kabul edilebilir mi? Neden?
2. Kurumlarda parola tekrar kullanımının önüne geçmek için hangi teknik ve organizasyonel kontroller birlikte uygulanmalıdır?
3. NIST'in parola politikası önerileri ile klasik parola politikaları arasındaki temel farklar nelerdir?
4. Phishing saldırıları parola güvenliğini nasıl tehdit etmektedir ve bu tehdide karşı çok katmanlı bir savunma nasıl kurulabilir?
5. Parola yöneticilerinin benimsenmesi önünde çıkan engeller nelerdir ve bu engeller nasıl aşılabılır?

1.12 Kaynaklar

- NIST SP 800-63B-4 (2025). Digital Identity Guidelines: Authentication and Authenticator Management. <https://pages.nist.gov/800-63-4/sp800-63b.html>
- OWASP (t.y.). Authentication Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- OWASP (2021). Top 10 A07 Identification and Authentication Failures. https://owasp.org/Top10/2021/A07_2021-Identification_and_Authentication_Failures/

BÖLÜM 2 — TEMEL KAVRAMLAR

↪ İçindekilere dön

2.1 Bölüm Amacı

Bu bölümün amacı, kimlik doğrulama, yetkilendirme, hesap türleri, token, API anahtarı, oturum ve gizli bilgi kavramlarını çalışma boyunca kullanılacak terminolojiye bağlamaktır. Temel kavramların doğru anlaşılması, ilerleyen bölümlerdeki teknik tartışmaların sağlam bir zeminde yürütülmesi için zorunludur.

Bu bölüm tamamlandığında okuyucu; kimlik doğrulama ve yetkilendirme arasındaki temel farkı açıklayabilecek, farklı hesap türlerinin güvenlik gereksinimlerini karşılaştırabilecek, token ve API anahtarı güvenlik ilkelerini kavrayabilecek, gizli bilgi yaşam döngüsünü tanımlayabilecek ve en az ayrıcalık ilkesinin uygulama biçimlerini açıklayabilecektir.

2.2 Araştırma Soruları

- Kimlik doğrulama ve yetkilendirme karıştırıldığında hangi mimari hatalar ortaya çıkar?
- Servis hesapları ve API anahtarları parola güvenliği kapsamına nasıl dahil edilmelidir?
- Oturum ve token güvenliği parola güvenliğinden neden ayrı düşünülemez?

2.3 Kimlik Doğrulama, Yetkilendirme ve Hesap Verebilirlik

Güvenlik terminolojisinde sıklıkla karıştırılan üç temel kavram bulunmaktadır: kimlik doğrulama (authentication), yetkilendirme (authorization) ve hesap verebilirlik (accountability). Bu kavramların doğru anlaşılması, güvenli sistem tasarımının temelini oluşturmaktadır.

Kimlik Doğrulama (Authentication): Bir varlığın (kullanıcı, cihaz, servis) iddia ettiği kimliği doğrulama sürecidir. "Sen kimsin?" sorusuna cevap arar. Kimlik doğrulama, genellikle üç faktöre dayanır:

- **Bildiğin şey (Something you know):** Parola, PIN, güvenlik sorusu
- **Sahip olduğun şey (Something you have):** Donanım anahtarı, cep telefonu, sertifika
- **Olduğun şey (Something you are):** Parmak izi, yüz tanıma, iris

Kimlik doğrulama; tek faktörlü, iki faktörlü (2FA) veya çok faktörlü (MFA) olabilir. Faktör sayısı kadar faktörlerin bağımsızlığı ve kimlik avına dayanıklılığı da önemlidir (NIST, 2025).

Yetkilendirme (Authorization): Kimlik doğrulaması yapılmış bir varlığın, belirli bir kaynağa veya işleme erişim yetkisinin olup olmadığının belirlenmesidir. "Ne yapabilirsin?" sorusuna cevap arar. Yetkilendirme, kimlik doğrulamasından sonra gerçekleşir ve genellikle aşağıdaki modellerden biriyle uygulanır:

- **Rol Tabanlı Erişim Kontrolü (RBAC):** Kullanıcının rolüne bağlı olarak yetkilendirme yapılır.
- **Özellik Tabanlı Erişim Kontrolü (ABAC):** Kullanıcının özelliklerine, kaynağın özelliklerine ve bağlama göre yetkilendirme yapılır.
- **En Ayrıcalık İlkesi (Least Privilege):** Kullanıcıya yalnızca görevini yerine getirmek için gerekli minimum yetki verilir.

Hesap Verebilirlik (Accountability): Kimlik doğrulaması ve yetkilendirmenin ötesinde, bir varlığın eylemlerinin izlenebilir ve sorumlu tutulabilir olmasını sağlar. Audit trail (denetim izi), log yönetimi ve olay inceleme süreçleri hesap verebilirliğin temel bileşenleridir. Hesap verebilirlik, bir güvenlik olayı meydana geldiğinde kimin ne yaptığının tespit edilmesini ve sorumluluk atamasını mümkün kılar.

Bu üç kavram arasındaki ilişki şöyledir: Kimlik doğrulama → Yetkilendirme → Hesap verebilirlik. Bu zincirin her bir halkasının güçlü olması gerekir; zayıf bir halka tüm zincirin güvenliğini tehlikeye atar.

Kimlik Doğrulama ve Yetkilendirme Karıştırılmasının Sonuçları:

Kimlik doğrulama ve yetkilendirme arasındaki farkın anlaşılmaması, çeşitli mimari hatalara yol açabilmektedir:

- Yetkilendirme kontrolü yapılmadan API çağrılarının yanıtlanması

- Kimlik doğrulama token'ının yetkilendirme token'ı olarak kullanılması
- Rol bazlı kontrollerin kimlik doğrulama seviyesinde yapılması
- Oturum token'ının tüm kaynaklara erişim izni verdiği varsayımı
- Servis hesaplarının aşırı yetkilendirilmesi

Bu hatalar, yetkisiz erişim, veri sızıntısı ve ayrıcalık genişletme saldırılarına zemin hazırlayabilir.

2.4 Kullanıcı, Yönetici, Servis ve Makine Hesapları

Kurumsal ortamda farklı türde hesaplar bulunmaktadır ve her birinin farklı güvenlik gereksinimleri vardır. Hesap türlerinin doğru sınıflandırılması ve her tür için uygun güvenlik kontrollerinin uygulanması, kurumsal güvenliğin temelini oluşturmaktadır.

Kullanıcı Hesapları (User Accounts): İnsan kullanıcıların kişisel hesaplarıdır. Her kullanıcı hesabı bir kişiye atandığında hesap verebilirlik sağlanır. Kullanıcı hesapları için temel güvenlik kontrolleri şunlardır: güçlü parola politikası, MFA zorunluluğu, otomatik hesap kilitleme, düzenli erişim incelemesi ve ayrıcalık denetimi.

Yönetici Hesapları (Administrator Accounts): Sistem yönetimi, yapılandırma ve güvenlik ayarları yapma yetkisine sahip hesaplardır. Yönetici hesapları, yüksek ayrıcalıklar taşıdıklarından dolayı en yüksek risk seviyesine sahiptir. Bu hesaplar için ek güvenlik kontrolleri gerekir: ayrıcalıklı erişim yönetimi (PAM), just-in-time (JIT) erişim, güçlü MFA (özellikle phishing-resistant MFA), oturum kaydı (session recording), davranış analizi ve düzenli denetim.

Servis Hesapları (Service Accounts): Uygulamaların, otomasyonların ve sistemlerin birbirleriyle iletişim kurması için kullanılan hesaplardır. Servis hesapları genellikle interaktif değildir ve parolaları otomatik olarak yönetilir. Güvenlik kontrolleri: parola rotasyonu, minimum yetki ilkesi, API anahtarı yönetimi, kullanım izleme ve düzenli inceleme.

Makine Hesapları (Machine Accounts): Cihazların, sunucuların ve container'ların kimlik doğrulaması için kullanılan hesaplardır. Genellikle sertifika tabanlı kimlik doğrulama kullanır. Güvenlik kontrolleri: sertifika yönetimi, yaşam döngüsü denetimi, otomatik yenileme ve iptal.

Hesap Türü	Kimlik Doğrulama	Risk Seviyesi	Özel Kontroller
Kullanıcı	Parola + MFA	Orta	Eğitim, politika
Yönetici	Güçlü MFA + PAM	Kritik	JIT, oturum kaydı, denetim
Servis	API anahtarı/token	Yüksek	Rotasyon, minimal yetki
Makine	Sertifika	Orta-Yüksek	Sertifika yönetimi

2.5 Token, API Anahtarı ve Oturum Güvenliği

Modern uygulamalarda kimlik doğrulama süreci genellikle token tabanlı sistemlerle yürütülmektedir. Token mekanizmalarının doğru anlaşılması, güvenli uygulama geliştirme için kritik önem taşımaktadır.

Access Token: Kullanıcının kimlik doğrulamasından sonra, belirli bir kaynağa erişim izni veren kısa ömürlü jetondur. Access token'lar genellikle JWT (JSON Web Token) formatında üretilir ve belirli bir süre (örneğin 15-60 dakika) geçerlidir. JWT token'lar üç bölümden oluşur: header (başlık), payload (yük) ve signature (imza). Token'ın içeriği Base64 ile kodlanmış olmakla birlikte, imza doğrulanmadığı sürece içeriğe güvenilemez.

Access token güvenlik ilkeleri: - Kısa süreli ömür (15-60 dakika) - HTTPS üzerinden iletim - Secure ve HttpOnly cookie bayrakları - Token_scope kısıtlaması (minimum yetki) - İptal mekanizması (token revocation)

Refresh Token: Access token'ın süresi dolduğunda yeni bir access token almak için kullanılan uzun ömürlü tokondur. Refresh token'lar, access token'lardan daha hassastır ve güvenli biçimde saklanmalıdır. Güvenlik ilkeleri: tek kullanım (rotation), uzun süreli saklamada şifreleme, kullanım izleme, şüphe durumunda iptal.

API Anahtarı (API Key): Uygulamaların API'lerine erişim sağlamak için kullanılan uzun, rastgele değerli karakter dizileridir. API anahtarları genellikle servis hesapları ve makineler arası iletişim için kullanılır. Güvenlik ilkeleri: güvenli saklama (plaintext olarak kaydedilmemeli), rotasyon periyodu, kullanım kapsamı kısıtlaması, rate limiting, logging ve monitoring.

Oturum (Session): Kullanıcının kimlik doğrulamasından sonra sistemle kurduğu etkileşim süresidir. Oturum güvenliği aşağıdaki ilkelere dayanır:

- **Session ID:** Rastgele, tahmin edilemez ve yeterince uzun olmalıdır.
- **Oturum Oluşturma:** Kimlik doğrulaması başarılı olduktan sonra yeni oturum ID'si üretilmelidir (session fixation önleme).
- **Oturum Süresi:** Belirli bir süre sonra oturum sonlandırılmalıdır (timeout).
- **Çıkış (Logout):** Kullanıcı çıkış yaptığında oturum sunucu tarafında sonlandırılmalıdır.
- **Session fixation:** Oturum token'ı kimlik doğrulaması sonrası yenilenmelidir.

2.6 Gizli Bilgi Yaşam Döngüsü

Gizli bilgilerin (parola, token, API anahtarı, sertifika) güvenli biçimde yönetilmesi, yaşam döngüsünün her aşamasında belirli kontrollerin uygulanmasını gerektirir. Bu yaşam döngüsü beş aşamadan oluşur:

Üretim (Generation): Gizli bilginin kriptografik olarak güvenli biçimde üretilmesi. Kullanılacak rastgele sayı üretici (CSPRNG) yeterli entropiye sahip olmalıdır. Parolalar için OWASP, minimum 64 bit entropi önermektedir. Token ve API anahtarı üretimi için kriptografik olarak güvenli rastgele fonksiyonları kullanılmalıdır.

Saklama (Storage): Gizli bilgilerin saklanması, en hassas yaşam döngüsü aşamasıdır. Parolalar asla düz metin olarak saklanmamalıdır; bcrypt, Argon2id gibi bellek-zorlayıcı hash algoritmaları kullanılmalıdır. API anahtarları ve token'lar şifreli olarak veya sır deposu (vault) çözümünde saklanmalıdır. Koddaki, yapılandırma dosyalarındaki veya ortam değişkenlerindeki gizli bilgiler versiyon kontrol sistemine kaydedilmemelidir.

Kullanım (Usage): Gizli bilgilerin yalnızca amaçlandığı biçimde ve yetkili taraflarca kullanılması. Minimum yetki ilkesi uygulanmalı, erişim kaydedilmeli ve yalnızca gerekli süre boyunca erişim verilmelidir.

Rotasyon (Rotation): Gizli bilgilerin planlı veya olay tetiklemeli olarak yenilenmesidir. NIST SP 800-63B-4, ele geçirilme kanıtı yoksa kullanıcı parolalarının periyodik değişime zorlanmamasını ister. API anahtarı ve token yaşam döngüsü; maruz kalma süresi, otomasyon kapasitesi ve iptal edilebilirlik dikkate alınarak ayrı yönetilmelidir.

İmha (Destruction): Gizli bilginin artık gerekli olmadığına güvenli biçimde yok edilmesi. Eski parolalar, kullanılmayan token'lar ve iptal edilmiş API anahtarları güvenlik havuzundan (security pool) çıkarılmalı ve geri dönüşümsüz biçimde silinmelidir.

2.7 Yetki Ayrımı ve En Ayrıcalık İlkesi

Parola güvenliğinin ötesinde, kurumsal güvenlik mimarisinin temelini oluşturan iki kritik ilke bulunmaktadır: yetki ayrımı (separation of duties) ve en az ayrıcalık (least privilege).

Yetki Ayrımı (Separation of Duties): Tek bir kişinin tüm kritik süreçleri kontrol etmesini önleyen organizasyonel bir kontroldür. Parola güvenliği bağlamında bu, aşağıdaki biçimlerde uygulanır:

- Parola politikası oluşturma ve uygulama görevleri farklı kişiler tarafından yapılmalıdır.
- Yönetici hesaplarının parolaları, normal kullanıcı hesaplarından farklı kişiler tarafından yönetilmelidir.
- Olay müdahalesi sürecinde, kanıt toplama ve karar verme görevleri ayrılmalıdır.
- Kimlik doğrulama altyapısının yönetimi, veri tabanı yönetiminden ayrılmalıdır.

En Ayrıcalık İlkesi (Least Privilege): Her kullanıcıya, hesabını veya sistemleri yönetmek için gerekli olan minimum yetki verilmelidir. Parola güvenliği bağlamında bu ilke şu biçimlerde uygulanır:

- Kullanıcılar yalnızca kendi hesaplarının parola sıfırlama işlemi yapabilmelidir.
- Yardım masası personeli parola sıfırlama işlemi yapabilmeli ancak parolayı görememelidir.
- Geliştiriciler_production veri tabanı parolalarına erişmemelidir.
- Servis hesapları yalnızca gerekli API'lere erişmelidir.

Görevler Ayrılığı Matrisi:

Görev	Kullanıcı	Yardım Masası	Sistem Yöneticisi	Güvenlik Yöneticisi
Kendi parolasını değiştirme	Evet	Evet	Evet	Evet

Görev	Kullanıcı	Yardım Masası	Sistem Yöneticisi	Güvenlik Yöneticisi
Başkasının parolasını sıfırlama	Hayır	Evet (sınırlı)	Evet	Hayır
Parola politikası oluşturma	Hayır	Hayır	Hayır	Evet
Olay inceleme	Hayır	Hayır	Kısmen	Evet
MFA yapılandırma	Hayır	Hayır	Evet	Evet

2.8 Bölüm Özeti

Bu bölümde kimlik doğrulama, yetkilendirme ve hesap verebilirlik kavramları detaylı biçimde ele alınmıştır. Kimlik doğrulama ve yetkilendirme arasındaki fark ve bu farkın pratikteki önemi açıklanmıştır. Kullanıcı, yönetici, servis ve makine hesaplarının farklı güvenlik gereksinimleri karşılaştırılmıştır. Token, API anahtarı ve oturum güvenliği ilkeleri incelenmiş, gizli bilgi yaşam döngüsünün beş aşaması (üretim, saklama, kullanım, rotasyon, imha) tanımlanmıştır. Son olarak yetki ayrımı ve en az ayrıcalık ilkesinin parola güvenliği bağlamındaki uygulamaları açıklanmıştır.

Doğru terminoloji ve kavramsal çerçeve, ilerleyen bölümlerdeki teknik tartışmalar için sağlam bir temel oluşturmaktadır.

2.9 Kontrol Listesi

- [] Kimlik doğrulama ve yetkilendirme arasındaki fark açıklandı.
- [] Hesap verebilirlik kavramı ve önemi açıklandı.
- [] Hesap türleri (kullanıcı, yönetici, servis, makine) sınıflandırıldı.
- [] Token ve API anahtarı güvenlik ilkeleri belirlendi.
- [] Gizli bilgi yaşam döngüsü (üretim → imha) tamamlandı.
- [] Yetki ayrımı ve en az ayrıcalık ilkesi açıklandı.
- [] Tüm terimler akademik olarak tanımlandı.
- [] Karşılaştırma tabloları üretildi.

2.10 Tartışma Soruları

1. Kimlik doğrulama ve yetkilendirme aynı işlem olarak ele alındığında hangi güvenlik riskleri ortaya çıkar?
2. Servis hesaplarının parola yönetimi, insan kullanıcı hesaplarından neden farklı ele alınmalıdır?
3. JWT tabanlı token güvenliğinde en sık karşılaşılan zayıflıklar nelerdir?
4. En az ayrıcalık ilkesi, küçük ölçekli bir start-up'ta nasıl uygulanabilir?
5. Gizli bilgi yaşam döngüsünün hangi aşaması en yüksek riske sahiptir? Neden?

2.11 Kaynaklar

- NIST SP 800-63B-4 (2025). Digital Identity Guidelines: Authentication and Authenticator Management. <https://pages.nist.gov/800-63-4/sp800-63b.html>
- OWASP (t.y.). Authentication Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- OWASP (2021). Top 10 A07 Identification and Authentication Failures. https://owasp.org/Top10/2021/A07_2021-Identification_and_Authentication_Failures/
- OWASP (t.y.). Session Management Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- RFC 7519 — JSON Web Token (JWT). <https://datatracker.ietf.org/doc/html/rfc7519>
- RFC 6749 — OAuth 2.0 Authorization Framework. <https://datatracker.ietf.org/doc/html/rfc6749>

BÖLÜM 3 — PAROLA SAKLAMA GÜVENLİĞİ

↪ İçindekilere dön

3.1 Bölüm Amacı

Bu bölümün amacı, parolaların düz metin veya geri döndürülebilir biçimde saklanmaması gerektiğini; hash, salt, pepper ve bellek-zorlayıcı parola hash algoritmalarını savunma perspektifiyle açıklamaktır. Parola saklama güvenliği, bir kurumun parola güvenliğindeki en kritik teknik kontrolüdür ve bir veri tabanı sızıntısının sonuçlarını doğrudan etkiler.

Bu bölüm tamamlandığında okuyucu; düz metin saklamanın risklerini ve hash'in temel ilkelerini açıklayabilecek, salt ve pepper'ın farklı tehdit modellerine karşı koruma sağladığını açıklayabilecek, Argon2id, bcrypt, scrypt ve PBKDF2 algoritmalarını karşılaştırabilecek, parola saklama mimarisi karar ağacını kullanabilecek ve hash algoritması göçü sürecini planlayabilecektir.

3.2 Araştırma Soruları

- Salt ve pepper hangi tehdit modellerine karşı koruma sağlar?
- Argon2id, bcrypt, scrypt ve PBKDF2 hangi bağlamlarda değerlendirilmelidir?
- Parametre seçimi güvenlik, performans ve kullanıcı deneyimini nasıl dengeler?

3.3 Düz Metin, Geri Döndürülebilir Şifreleme ve Hash Farkı

Parola saklama güvenliğinin temeli, parolanın hangi formatta saklandığıdır. Tarihsel olarak farklı yaklaşımlar kullanılmıştır ve bunlar arasındaki farkları anlamak, doğru tercihi yapmak için gereklidir.

Düz Metin Saklama (Plaintext Storage): Parolanın herhangi bir dönüşüme uğratılmadan saklanmasıdır. Veri tabanı sızıntısında parolalar doğrudan açığa çıkar. Kullanıcı parolaları düz metin veya geri döndürülebilir biçimde saklanmamalıdır (OWASP Password Storage Cheat Sheet, t.y.).

Geri Döndürülebilir Şifreleme (Reversible Encryption): Parolanın simetrik veya asimetrik şifreleme ile şifrelenerek saklanmasıdır. Şifreleme anahtarı bilindiğinde parola orijinal formuna döndürülebilir. Bu yaklaşım, düz metinden biraz daha güvenli olmakla birlikte, temelde aynı riski taşır: şifreleme anahtarı ele geçirildiğinde tüm parolalar çözülebilir. Geri döndürülebilir şifreleme, yalnızca parolanın orijinal formunun gerçekten gerekli olduğu (örneğin, bazı eski protokoller) çok sınırlı durumlarda düşünülebilir.

Hash Fonksiyonu: Parolanın bir hash fonksiyonundan geçirilerek sabit uzunlukta bir çıktıya (hash değerine) dönüştürülmesidir. Hash fonksiyonunun temel özelliği, tek yönlü olmasıdır: paroladan hash üretmek kolaydır ancak hash'den parolayı geriye dönüştürmek pratikte imkânsızdır. Doğrulama sürecinde, kullanıcının girdiği parola aynı hash fonksiyonundan geçirilir ve elde edilen hash, veri tabanındaki hash ile karşılaştırılır. Eşleşme varsa parola doğrudur.

Hash fonksiyonunun güvenlik özellikleri: - **Tek Yönlülük:** Hash'den parola geri alınamaz. - **Avalanche Etkisi:** Girdideki küçük bir değişiklik, çıktıda büyük bir değişiklik yaratır. - **Çarpışma Direnci:** Farklı iki girdinin aynı hash'i üretmesi pratikte imkânsızdır (SHA-256, SHA-3 için). - **Tutarlılık:** Aynı girdi her zaman aynı hash'i üretir.

Karşılaştırma Tablosu:

Saklama Yöntemi	Güvenlik Seviyesi	Veri Sızıntısı Sonucu	Kullanım
Düz metin	Çok düşük	Tüm parolalar açık	KABUL EDİLEMEZ
Geri döndürülebilir şifreleme	Düşük-Orta	Şifre anahtarı ile çözülebilir	SINIRLI
Basit hash (MD5, SHA-1)	Orta	Tuzsuz → rainbow table	ESKİ
Hash + salt	Yüksek	Salt ile birlikte saklanmalı	GÜNCEL
Hash + salt + pepper	Çok yüksek	Pepper sızıntıda korur	ÖNERİLEN
Bellek-zorlayıcı hash	En yüksek	Offline brute-force çok zor	ÖNERİLEN

3.4 Salt ve Pepper Kavramları

Parola hash'leme sürecinde salt ve pepper, hash değerlerinin güvenliğini artıran iki farklı katmandır ve farklı tehdit modellerine karşı koruma sağlar.

Salt: Parolanın hash'lenmesinden önce parolaya eklenen benzersiz, rastgele bir değerdir. Her kullanıcı için farklı bir salt üretilir. Salt'ın amacı, aynı parolaya sahip iki kullanıcının farklı hash değerlerine sahip olmasını sağlamaktır. Salt, hash ile birlikte veri tabanında saklanır.

Salt'ın nasıl çalıştığını anlamak önemlidir: Eğer iki kullanıcı "GüvenliParola123" parolasını kullanıyorsa ve salt kullanılmıyorsa, her ikisinin de aynı hash'i olacaktır. Bir saldırgan bu hash'i çözdüğünde, her iki hesabın da parolasını elde eder. Ancak farklı salt'lar kullanıldığında, her kullanıcının hash'i farklı olur ve saldırganın her hash'i ayrı ayrı çözmesi gerekir.

Salt'ın temel özellikleri: - Her kullanıcıya özgü benzersiz olmalıdır. - Kriptografik olarak rastgele olmalıdır (CSPRNG ile üretilmelidir). - Uzunluğu yeterli olmalıdır (minimum 16 byte önerilir). - Salt'ın gizli olmasına gerek yoktur; veri tabanında hash ile birlikte saklanabilir. - Salt, parola ile birlikte bir defa üretilir ve parola değiştirilmediği sürece değişmez.

Pepper: Parola hash sürecinde eklenen, ancak salt'tan farklı olarak veri tabanından ayrı bir yerde saklanan gizli değerdir. Pepper, veri tabanı sızıntısı senaryosunda ek bir koruma katmanı sağlar: saldırgan salt ile birlikte hash'leri ele geçirse bile, pepper olmadan brute-force (kaba kuvvet) saldırısı yapamaz.

Pepper'ın temel özellikleri: - Parola kayıtlarıyla aynı veri deposunda tutulmayan, yüksek entropili bir sırdır. - Tercihen yönetilen bir sır deposunda veya donanım güvenlik modülünde saklanmalıdır; kaynak koda ya da genel yapılandırma dosyasına gömülmemelidir. - Pepper ele geçirilirse yalnızca hash verisiyle değiştirilemez; çoğu tasarımda kullanıcıların parolalarını yeniden belirlemesi gerekir. Bu nedenle sürümleme ve olay müdahale planı önceden hazırlanmalıdır. - Ön-hash pepper veya HMAC tabanlı son-hash pepper gibi tasarımlar kullanılabilir; seçilen şema, incelenmiş bir mimari ve standart kitaplıklarla uygulanmalıdır.

Salt + Pepper Birlikte Kullanım Senaryosu:

Bir veri tabanı sızıntısında saldırgan salt'ları ve hash'leri ele geçirir. Ancak pepper veri tabanında saklanmadığından saldırgan pepper değerini bilemez. Bu durumda: - Tuzsuz hash → rainbow table ile hızlıca çözülebilir. - Salt'lı hash → salt ile birlikte kaba kuvvet saldırısı gerekir. - Salt + pepper → pepper bilinmediği için kaba kuvvet saldırısı çok daha zordur.

Pepper'ın ek katman olarak değerli olduğu durumlar: veri tabanı sızıntılarının sık yaşandığı ortamlar, yüksek güvenli sistemler, yasal düzenlemelerin ek koruma istediği sektörler.

3.5 Key Stretching ve Bellek-Zorlayıcı Hesaplama

Key stretching (anahtar uzatma), bir parolanın hesaplama maliyetini kasıtlı olarak artırarak offline brute-force saldırılarına karşı dayanıklılığını artıran tekniktir. Bu teknik, parola hash'leme sürecinde kritik bir savunma katmanıdır.

Key Stretching'in Temel Mantığı: Normal bir hash fonksiyonu (SHA-256, SHA-3) çok hızlıdır; bu hız, saldırganların milyonlarca parola denemesini kısa sürede yapabilmesine olanak tanır. Key stretching, hash hesaplamasını kasıtlı olarak yavaşlatarak saldırganın deneme sayısını dramatik biçimde azaltır.

Key stretching'in uygulanma biçimleri: - **Döngü Tabanlı:** Hash fonksiyonu belirli bir sayıda (binlerce, on binlerce) tekrarlanır. - **Bellek-Zorlayıcı:** Hesaplama sürecinde yüksek miktarda bellek gerekir, bu da paralel hesaplamayı zorlaştırır. - **CPU-Zorlayıcı:** Yüksek hesaplama gücü gerektirir.

Modern parola hash algoritmaları, key stretching'i yerleşik olarak uygular ve parametrelere göre güvenlik seviyesi ayarlanabilir.

3.6 Argon2id, bcrypt, scrypt ve PBKDF2 Karşılaştırması

Modern parola saklamada dört ana algoritma değerlendirilmektedir. Her birinin güçlü ve zayıf yönleri, farklı bağlamlarda tercih edilme nedenleri bulunmaktadır.

Argon2id: 2015 Password Hashing Competition'inin kazananı olarak kabul edilen, günümüzde önerilen birinci tercih parola hash algoritmasıdır. Argon2'in üç varyantından biri olan Argon2id, hem CPU hem de bellek zorlayıcı özelliklere sahiptir.

Güçlü yönleri: Bellek-zorlayıcı yapısı paralel donanımla tahmin maliyetini artırır. Parametreleri bağımsız olarak ayarlanabilir (bellek kullanımı, hesaplama süresi, paralellik). OWASP tarafından genel amaçlı parola saklama için birinci tercih olarak önerilir. Esnek parametre seçimi sayesinde farklı sunucu kapasitelerine uyarlanabilir.

Zayıf yönleri: Bazı eski platformlarda desteği sınırlıdır. Doğru parametre seçimi için donanım değerlendirmesi gerekebilir. PBKDF2'ye göre daha az yaygın kütüphane desteği (artan).

OWASP'ın erişim tarihi itibarıyla verdiği asgari taban değer: bellek 19 MiB, iterasyon 2, paralellik 1'dir. Bu değer hedef donanımda ölçülmeli; kabul edilebilir gecikme ve eşzamanlılık sınırları içinde mümkünse yükseltilmelidir (OWASP, t.y.).

bcrypt: Blowfish şifreleme algoritmasına dayalı, uzun süredir kullanılan parola hash algoritmasıdır. 1999'da önerilmiş ve geniş kabul görmüştür.

Güçlü yönleri: Yaygın destek ve olgun ekosistem. Ayarlanabilir maliyet parametresi çevrim dışı tahmini yavaşlatır. Eski sistemlerde güvenli bir geçiş seçeneği olabilir.

Zayıf yönleri: Bellek-zorlayıcı değildir; modern bellek-zorlayıcı algoritmalara göre paralel donanıma karşı daha sınırlı koruma sağlar. Birçok bcrypt uygulaması girdiyi **72 baytta** keser. Uygulama, uzun veya çok baytlı Unicode parolaları sessizce kesmemeli; kullanılan kitaplığın davranışı test edilmelidir.

Önerilen work factor: minimum 10 (tercihen 12+).

Scrypt: 2009'da önerilen, bellek-zorlayıcı bir parola hash algoritmasıdır. Bellek kullanımı parametrik olarak ayarlanabilir.

Güçlü yönleri: Bellek-zorlayıcı yapısı paralel tahmin maliyetini artırır ve esnek bellek parametreleri sunar.

Zayıf yönleri: Argon2 kadar optimize edilmemiştir. Bazı uygulamalarda bellek ayarlaması zor olabilir. Argon2'in önerilmesinden bu yana popüleritesi azalmıştır.

PBKDF2 (Password-Based Key Derivation Function 2): NIST SP 800-132 tarafından önerilen, HMAC tabanlı key derivation fonksiyonudur. En eski ve en yaygın desteklenen algoritmadır.

Güçlü yönleri: NIST ve PCI DSS gibi standartlar tarafından desteklenir. Geniş kütüphane desteği. Kolay uygulanabilir. Mevcut sistemlerle uyumlu.

Zayıf yönleri: CPU-tabanlıdır; bellek-zorlayıcı değildir. GPU ve ASIC saldırılarına karşı en savunmasız algoritmadır. Yüksek iterasyon sayısı ile telafi edilebilir ancak bu da performans maliyeti yaratır.

Algoritma Karşılaştırma Tablosu:

Özellik	Argon2id	bcrypt	Scrypt	PBKDF2
Yıl	2015	1999	2009	2000
Bellek-zorlayıcı	Evet	Hayır	Evet	Hayır
CPU-zorlayıcı	Evet	Evet	Evet	Evet
GPU direnci	Yüksek	Orta	Yüksek	Düşük
ASIC direnci	Yüksek	Orta	Yüksek	Düşük
OWASP yaklaşımı	Birinci tercih	Eski sistemler için	Argon2id yoksa	FIPS gereksiniminde
Temel sınırlılık	Doğru ayar gerektirir	72 bayt giriş sınırı	Ayar karmaşıklığı	Bellek-zorlayıcı değil
Parametre esnekliği	Yüksek	Orta	Yüksek	Düşük
Yaygın destek	Artan	Yüksek	Orta	Yüksek

3.7 Parametre Seçimi ve Hash Göçü

Parola hash algoritması ve parametre seçimi, güvenlik, performans ve kullanıcı deneyimi arasında bir denge gerektirir. Yanlış parametre seçimi, gereksiz performans maliyeti veya yetersiz güvenlik riski yaratabilir.

Parametre Seçiminde Dikkat Edilmesi Gerekenler:

Hedef Donanım: Parola hash sunucularının kapasitesi, parametre seçiminde belirleyici faktördür. Parametreler güvenli taban değerinin altına düşürülmeden, hizmetin beklenen ve kötüye kullanım kaynaklı yük altında taşıyabileceği eşzamanlı giriş sayısına göre ayarlanmalıdır.

Kabul Edilebilir Gecikme: Kimlik doğrulama isteklerinde kabul edilebilir gecikme süresi genellikle 100-500 milisaniye arasındadır. Bu süre, kullanıcının fark edebileceği ancak rahatsız edici olmayan bir düzeyde olmalıdır. Parametreler bu gecikme süresi dahilinde ayarlanmalıdır.

Paralellik: Sunucu mimarisi (tek çekirdekli, çok çekirdekli, container) paralellik parametresini etkiler. Paralellik, aynı anda kaç tane hesaplama yapılabileceğini belirler.

Hash Göçü (Migration): Mevcut bir sistemde hash algoritmasını veya parametreleri değiştirmek, dikkatli bir planlama gerektirir. Hash göçü sürecinde izlenmesi gereken adımlar:

1. **Yeni parametrelerin belirlenmesi:** Mevcut donanımına uygun, güvenlik hedeflerini karşılayan parametreler seçilmelidir.
2. **Geçiş stratejisi:** Düz metin parola bilinmeden eski hash'ler yeni algoritmayla doğrudan yeniden hesaplanamaz. Başarılı girişte doğrulanan parolanın yeni şemayla tekrar hash'lenmesi veya kullanıcıdan güvenli parola sıfırlaması istenmesi değerlendirilmelidir.
3. **Geriye dönük uyumluluk:** Eski hash'lerin hâlâ doğrulanabilmesi için geçiş sürecinde çift parametrelili doğrulama uygulanabilir.
4. **Eski hash'lerin temizlenmesi:** Geçiş tamamlandıktan sonra, eski format hash'lerin güvenlik havuzundan temizlenmesi gerekir.

Parametre Güncelleme Periyodu: Teknolojinin gelişmesiyle birlikte mevcut parametreler yetersiz hale gelebilir. Örneğin, 2015'te güvenli kabul edilen bir bcrypt work factor'ı, 2025'te yetersiz olabilir. Periyodik parametre değerlendirmesi ve gerekirse güncelleme yapılmalıdır.

3.8 Bölüm Özeti

Bu bölümde parola saklama güvenliği kapsamlı biçimde ele alınmıştır. Düz metin saklama, geri döndürülebilir şifreleme ve hash arasındaki temel farklar açıklanmış ve karşılaştırılmıştır. Salt ve pepper'ın farklı tehdit modellerine karşı koruma sağladığı açıklanmıştır. Key stretching ve bellek-zorlayıcı hesaplama mantığı kavratılmıştır. Argon2id, bcrypt, scrypt ve PBKDF2 algoritmaları detaylı biçimde karşılaştırılmıştır. Parametre seçiminde dikkat edilmesi gerekenler ve hash göçü süreci adım adım açıklanmıştır.

Parola saklama güvenliği, veri tabanı sızıntısının etkisini doğrudan belirler. Genel amaçlı sistemlerde OWASP'ın Argon2id önerisi güçlü bir başlangıç noktasıdır; FIPS doğrulaması gibi bağlama özgü gereksinimlerde onaylı PBKDF2 yapılandırmaları gerekebilir. Algoritma adı tek başına yeterli değildir: parametreler, kitaplık davranışı, sır yönetimi, hız sınırlama ve göç planı birlikte denetlenmelidir.

3.9 Kontrol Listesi

- [] Düz metin saklamanın kabul edilemezliği açıklandı.
- [] Hash fonksiyonunun temel özellikleri (tek yönlülük, avalanche, çarpışma direnci) açıklandı.
- [] Salt'ın her kullanıcıya özgü, rastgele ve yeterince uzun olduğu doğrulandı.
- [] Pepper'ın veri tabanından ayrı saklandığı belirtildi.
- [] Argon2id'in birinci tercih olarak önerildiği vurgulandı.
- [] bcrypt work factor'ının minimum 10 (tercihen 12+) olduğu belirtildi.
- [] Hash göçü planı oluşturuldu.
- [] Parametre seçimi güvenlik-performans dengesine göre yapıldı.

3.10 Tartışma Soruları

1. Pepper kullanmanın avantajları ve zorlukları nelerdir? Hangi durumlarda pepper eklenmesi şiddetle önerilir?
2. Argon2id'in bellek parametresini aşırı yüksek seçmek ne tür sorunlara yol açabilir?
3. Mevcut bir sistemde PBKDF2'den Argon2id'e geçiş süreci nasıl planlanmalıdır?
4. Parola hash'leme parametrelerinin ne sıklıkla yeniden değerlendirilmesi gerekir?
5. Bir kurum, parola saklama güvenliğini denetlerken hangi kriterleri kontrol etmelidir?

3.11 Kaynaklar

- OWASP (t.y.). Password Storage Cheat Sheet. [https://cheatsheetseries.owasp.org/cheatsheets/Password Storage Cheat Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html)

- NIST SP 800-63B-4 (2025). Digital Identity Guidelines: Authentication and Authenticator Management. <https://pages.nist.gov/800-63-4/sp800-63b.html>
- OWASP (t.y.). Authentication Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- NIST SP 800-132 (2023). Recommendation for Key Derivation Using Password-Based Key Derivation Functions. <https://csrc.nist.gov/publications/detail/sp/800-132/final>
- Argon2: Memory-Hard Hash Function — Password Hashing Competition. <https://password-hashing.net/>

BÖLÜM 4 — PAROLA POLİTİKALARI

↪ İçindekilere dön

Amaç

Bu bölüm, kuruluşların parola güvenliği için geliştirdiği politika ve prosedürleri ele almaktadır. Parola politikaları; seçim, saklama, kullanım, kurtarma ve ihlal sonrası yenileme kurallarını birlikte kapsar. İyi tasarlanmış bir politika, teknik ve idari kontrolleri bir araya getirerek kurumsal güvenlik duruşunu güçlendirir. Bu bölümün sonunda okuyucunun politika tasarım ilkelerini, uygulama güçlüklerini ve etkinlik ölçütlerini analiz edebilmesi beklenmektedir.

Araştırma Soruları

1. Parola uzunluğu ve karmaşıklık gereksinimleri kullanıcı davranışını nasıl etkilemektedir?
2. Periyodik parola rotasyonu yerine risk temelli rotasyon neden tercih edilmektedir?
3. Yasaklı parola listeleri etkin bir biçimde nasıl oluşturulmalı ve güncellenmelidir?
4. Parola politikaları farklı kullanım alanlarında nasıl uyarlanmalıdır?

4.1 Minimum ve Maksimum Parola Uzunluğu

Parola uzunluğu, özellikle rastgele üretilmiş parolalarda tahmin uzayını belirleyen temel değişkenlerden biridir. NIST SP 800-63B-4 (2025), tek faktör olarak kullanılan parolalar için **en az 15 karakteri** zorunlu tutar. Parola yalnızca çok faktörlü bir sürecin parçasıysa en az **8 karaktere** izin verilebilir. Bu iki eşik birbirinin alternatifi değildir; kimlik doğrulama bağlamına göre uygulanır (NIST, 2025).

4.1.1 Minimum Uzunluk Gerekçeleri

Kısa parolalar, saldırı düzlemini doğrudan etkilemektedir. Bir parolanın olası karakter kombinasyonu, uzunluğun üstel fonksiyonudur. 8 karakterlik bir parola, küçük harfler ve rakamlar içeren bir karakter setinden seçilmişse 36^8 ($\approx 2,8 \times 10^{12}$) olası kombinasyona sahipken, 16 karakterlik bir parola aynı karakter setinden 36^{16} ($\approx 7,9 \times 10^{24}$) kombinasyon üretmektedir. Bu fark, kaba kuvvet saldırılarının uygulanabilirliğini doğrudan belirlemektedir.

Kuruluşlar asgari eşiği belirlerken aşağıdaki hususları göz önünde bulundurmalıdır:

- **Tek faktörlü doğrulama:** En az 15 karakter
- **MFA içinde kullanılan parola:** En az 8 karakter; kurumun risk değerlendirmesi daha uzun bir eşik belirleyebilir
- **Ayrıcalıklı hesaplar:** Uzun parolaya ek olarak kimlik avına dayanıklı MFA ve ayrı yönetim düzlemi
- **Makine tarafından üretilen sırlar:** Kullanıcı parolası politikasından ayrı, yeterli rastgelelik ve yaşam döngüsü yönetimi

4.1.2 Maksimum Uzunluk Sınırlamaları

Parola politikaları minimum kadar üst sınırı da açıkça tanımlamalıdır. NIST SP 800-63B-4, doğrulayıcıların **en az 64 karaktere** izin vermesini ister. Daha yüksek sınırlar hizmet reddi riskine karşı makul bir işlem sınırıyla uygulanabilir; parola sessizce kısaltılmamalıdır.

Uygulama; sınırı karakter veya bayt cinsinden tanımladığını belirtmeli, Unicode girişlerini tutarlı biçimde işlemeli ve baştaki/sondaki boşlukları kullanıcıdan habersiz değiştirmemelidir. UTF-8'de bir karakter birden fazla bayt tutabilir. Ayrıca bcrypt gibi bazı eski uygulamalarda giriş uzunluğu sınırları bulunduğundan, kitaplık davranışı test edilmeli ve uzun girdilerin sessizce kesilmediği doğrulanmalıdır.

4.1.3 Uzunluk Tablosu: Saldırı Dayanıklılığı Karşılaştırması

Uzunluk	Küçük harf (26)	Harf + rakam (62)	Yazdırılabilir ASCII (95)
8 karakter	3,5 dakika	2,5 gün	76,7 gün
12 karakter	3,0 yıl	102 bin yıl	17,1 milyon yıl

Uzunluk	Küçük harf (26)	Harf + rakam (62)	Yazdırılabilir ASCII (95)
16 karakter	1,38 milyon yıl	1,51 trilyon yıl	1,39 katrilyon yıl
20 karakter	631 milyar yıl	21,9 kentilyon yıl	113 sekstilyon yıl

Tablo 4.1: Saniyede 10^9 tahmin ve adayların eş olasılıklı/rastgele seçildiği varsayımıyla tüm uzayın taranma süresi. Ortalama bulma süresi yaklaşık yarısıdır.

Tablo yalnızca matematiksel bir üst modeldir. İnsanların seçtiği parolalar eş olasılıklı değildir; sözlük ve kalıp tabanlı tahminler nedeniyle çok daha erken bulunabilir. Çevrim dışı hız da kullanılan hash algoritmasına, parametrelere ve donanımına göre büyük ölçüde değişir. Bu nedenle süreler bir güvenlik garantisi olarak yorumlanmamalıdır.

4.2 Passphrase Yaklaşımı

Passphrase (geçiş ifadesi) yaklaşımı, kullanıcıların hatırlaması kolay ancak tahmin edilmesi zor parolalar oluşturmalarını sağlayan bir stratejidir. Bu yaklaşımda, bir cümle veya kelime dizisi parola olarak kullanılır.

4.2.1 Passphrase Tanımı ve Önemi

Passphrase, birden fazla kelimenin birleştirilmesiyle oluşan uzun bir parola türüdür. Güvenlik, kelimelerin sayısından çok seçim yöntemine bağlıdır. Kullanıcının ürettiği anlamlı bir cümle tahmin edilebilir olabilir; bağımsız ve yeterince geniş bir listeden rastgele seçilen kelimeler daha ölçülebilir bir tahmin direnci sağlar.

NIST, "password" terimini passphrase ve PIN'i de kapsayacak biçimde kullanır; boşluk ve Unicode karakterlerine izin verilmesini, uzun girdilerin desteklenmesini ve parola yöneticilerinin engellenmemesini ister. Passphrase yaklaşımının olası avantajları şunlardır:

- **Uzunluk:** Rastgele seçimle birlikte tahmin uzayını büyütebilir
- **Düşük bilişsel yük:** Bazı kullanıcılar için rastgele karakter dizilerinden daha kolay hatırlanabilir
- **Parola yöneticisiyle uyum:** Üretilip güvenli biçimde saklanabilir

- **Erişilebilirlik:** Boşluk ve doğal dil desteği, giriş kullanılabilirliğini artırabilir

4.2.2 Passphrase Oluşturma İlkeleri

Etkili bir passphrase oluşturmak için aşağıdaki ilkeler izlenmelidir:

1. **Kelime seçimi:** Rastgele veya yarı-rastgele kelime seçimi (sözlük tabanlı rastgele üretici araçlar tercih edilir)
2. **Kelime sayısı:** Minimum 4 kelime, ideal olarak 5-6 kelime
3. **Ayırıcı karakter:** Kelimeler arasında boşluk, tire veya nokta gibi tutarlı bir ayırıcı kullanımı
4. **Ek karmaşıklık:** Tahmin edilebilir yıl veya sembol ekleri yerine, rastgele kelime seçimine öncelik verilmesi
5. **Dil tercihi:** Kullanıcının ana dilinde veya çok dilli yaklaşım

4.2.3 Passphrase Karşılaştırma Tablosu

Özellik	Geleneksel Parola	Passphrase
Tipik uzunluk	8-12 karakter	20-40 karakter
Entropi	Üretim yöntemine bağlı	Kelime listesi ve seçim yöntemine bağlı
Hatırlama zorluğu	Kullanıcıya ve üretime bağlı	Bazı kullanıcılar için daha düşük olabilir
Sözlük tahminine direnç	İnsan seçerse genellikle düşük	Rastgele seçilmezse düşük olabilir
Kaba kuvvet direnci	Uzunluk ve rastgeleliğe bağlı	Kelime sayısı ve liste büyüklüğüne bağlı
Parola yöneticisiyle kullanım	Uygun	Uygun

Tablo 4.2: Geleneksel parola ve passphrase karşılaştırması

4.2.4 Dikkat Edilecek Noktalar

Passphrase yaklaşımının bazı sınırlılıkları da bulunmaktadır:

- **Fazla anlamlı cümleler** saldırı kalıplarına dahil edilebilir (örneğin "bugün-hava-çok-güzel")
- **Popüler alıntılar veya şarkı sözleri** sözlük saldırıları için dahil edilmelidir
- **Türkçe passphrase** seçimi, Türkçe sözlük tabanlı saldırıları da hesaba katmalıdır
- **Çok uzun passphrase'ler** bazı sistemlerde depolama sorunları yaratabilir

4.3 Karmaşıklık Kurallarının Kullanıcı Davranışına Etkisi

Parola politikalarında en çok tartışılan konulardan biri, karmaşıklık kurallarının etkinliğidir. Geleneksel olarak büyük harf, rakam ve özel karakter gereksinimleri güvenlik sağlamayı amaçlamıştır; ancak araştırmalar bu kuralların beklenen faydayı tam olarak sağlamadığını göstermektedir.

4.3.1 Geleneksel Karmaşıklık Kuralları

Tipik bir parola politikasında yer alan karmaşıklık kuralları şunlardır:

- En az bir büyük harf içermeli
- En az bir rakam içermeli
- En az bir özel karakter içermeli (örneğin !@#\$%^&*)
- Önceki parolalardan farklı olmalı
- Parola sözlüğünde yer almamalı

Bu kurallar uzun süre yaygın uygulanmış olsa da her standart aynı reçeteyi vermez. Güncel NIST yaklaşımı, zorunlu karakter türleri yerine uzunluk, engelli parola listesi, hız sınırlama, güvenli saklama ve MFA gibi kontrollere öncelik verir.

4.3.2 Araştırmaların Bulgu ve Sınırlılıkları

Kullanılabilir güvenlik araştırmaları, politika ayrıntılarının kullanıcı davranışını değiştirdiğini ve yalnızca karakter türü zorlamanın tahmin direncini garanti etmediğini göstermektedir (Shay vd., 2010; Ur vd., 2015). Bulguların birlikte değerlendirilmesinden çıkan sonuçlar şunlardır:

- Kullanıcılar, karmaşıklık kurallarına uymak için **tahmin edilebilir kalıplar** geliştirmektedir (örneğin "Sifre1!" gibi)
- Büyük harf veya rakam eklenmesi tek başına parola kalitesini ölçmez
- Sık ve gerekçesiz değişim, küçük ve tahmin edilebilir dönüşümleri teşvik edebilir
- Politika etkinliği, yalnızca biçimsel uyumla değil çevrim içi tahmin direnci, tekrar kullanım ve destek yüküyle ölçülmelidir

4.3.3 Kullanıcı Davranış Kalıpları

Karmaşıklık kuralları altında kullanıcıların geliştirdiği davranışsal kalıplar şunlardır:

Davranış Kalıbı	Örnek	Güvenlik Etkisi
Büyük harf ekleme (ilk harf)	"Parola1!"	Düşük iyileştirme
Rakam ekleme (sona)	"Parola123"	Düşük iyileştirme
Özel karakter ekleme	"Parola!"	Düşük iyileştirme
Tahmin edilebilir kelime kullanımı	"Güvenli1!"	Güvenlik açığı
Parola yeniden kullanım	Birden fazla sistemde aynı parola	Yüksek risk
Dijital not alma	Metin dosyasına yazma	Yüksek risk

Tablo 4.3: Kullanıcı davranış kalıpları ve etkileri

4.3.4 NIST Yaklaşımı ve Yeni Paradigma

NIST SP 800-63B, 2017 yılında yayınlandığında parola politikaları alanında bir paradigma değişikliği yaratmıştır. Yeni yaklaşım şu temel ilkeler üzerine kurulmuştur:

1. **Karmaşıklık kuralları zorunlu kılınmaz** — kullanıcıların parola seçimi özgür bırakılır
2. **Uzunluk bağlama göre belirlenir** — tek faktörde en az 15, MFA bağlamında en az 8 karakter
3. **Yasaklı parola listesi** — bilinen sızıntı parolaları ve sözlük kelimeleri engellenir
4. **Parola yöneticileri desteklenir** — otomatik doldurma ve yapıştırma engellenmez
5. **Periyodik yenileme zorunlu tutulmaz** — ele geçirilme kanıtı bulunduğunda değişim istenir

Bu yaklaşım, kullanıcı dostu olma ile güvenlik arasındaki dengeyi yeniden tanımlamıştır.

4.4 Periyodik Değişim Yerine Risk Temelli Rotasyon

Klasik parola politikalarının en yaygın uygulamalarından biri, parolaların belirli periyotlarda (örneğin 90 günde bir) zorunlu olarak değiştirilmesiydi. Ancak son yıllarda hem akademik araştırmalar hem de endüstri uygulamaları, bu yaklaşımın etkinliğini sorgular hale gelmiştir.

4.4.1 Zorunlu Periyodik Rotasyonun Sorunları

Zorunlu periyodik parola rotasyonunun yarattığı temel sorunlar şunlardır:

Güvenlik açığı oluşumu: - Kullanıcılar, son değişiklikten hemen önceki parolaya geri dönmektedir ("Parola2024" → "Parola2025") - Artan frekans, kullanıcıların daha düşük kaliteli parolalar seçmesine yol açmaktadır - Parola yeniden kullanım eğilimi artmaktadır

Kullanıcı deneyimi: - Sürekli değişiklik yükü kullanıcıları bunaltmaktadır - Sık sık kilitlenme (lockout) durumları oluşmaktadır - Parola yönetimi araçlarına yönelim artmaktadır (güvenli olmayan kayıtlar)

Zorunlu değişimin güvenlik etkisi, yalnızca değişim sıklığıyla ölçülemez. Esas ölçütler; tahmin edilebilir ardışık dönüşümlerin oranı, hesap kurtarma yükü, kilitlenme olayları, ele geçirilmiş parola tespiti ve MFA kapsamıdır. NIST SP 800-63B-4, ele geçirilme kanıtı yoksa periyodik değişimin zorunlu tutulmamasını ister.

4.4.2 Risk Temelli Rotasyon Yaklaşımı

Risk temelli rotasyon, parola değişikliğini belirli bir takvime değil, ölçülebilir güvenlik olaylarına bağlayan bir yaklaşımdır. Bu modelde parola yalnızca aşağıdaki durumlarda değiştirilir:

Tetikleyici Olay	Risk Seviyesi	Müdahale
Doğrulanmış parola/hash sızıntısı	Kritik	Oturumları iptal et, parolayı değiştir, MFA'yı doğrula
Ele geçirilmiş parola listesiyle eşleşme	Yüksek	Güvenli yeniden doğrulama sonrası değişim iste
Kimlik avı veya zararlı yazılım doğrulaması	Yüksek	Uç noktayı izole et; parola, oturum ve token'ları yenile
Şüpheli giriş sinyali	Değişken	Ek doğrulama uygula ve olayı araştır; tek sinyalle otomatik parola değişimine zorlama
Cihaz kaybı	Değişken	Cihaza bağlı kimlik bilgilerini iptal et; parola etkisini ayrıca değerlendir
Takvim süresinin dolması	Tek başına kanıt değil	Düzenleyici zorunluluk yoksa değişim isteme

Tablo 4.4: Risk tetikleyicileri ve müdahale seviyeleri

4.4.3 Uygulama İlkeleri

Risk temelli rotasyon modelinin etkin uygulanması için aşağıdaki ilkeler izlenmelidir:

1. **Olay algılama altyapısı:** Anomali tespit sistemleri (UEBA) ile entegrasyon
2. **Bildirim mekanizması:** Kullanıcılara gerçek zamanlı güvenlik uyarıları
3. **Yedekleme politikası:** Hesap kilitlenme durumunda erişilebilirlik sürekliliği
4. **Denetim izi:** Her rotasyon kararı için kayıt tutma ve raporlama
5. **Kullanıcı eğitimi:** Neden rotasyon gerektiğinin açıklanması

4.4.4 Endüstri Uygulamaları

Büyük teknoloji şirketleri bu değişimi zaten benimsemiştir:

- **Microsoft:** 2019'da zorunlu parola rotasyonunu kaldırdı
- **Google:** Benzer şekilde risk temelli modele geçti
- **Apple:** iCloud hesapları için benzer politika uyguluyor
- **ABD Siber Güvenlik ve Altyapı Güvenliği Ajansı (CISA):** Federal kurumlara risk temelli yaklaşımı öneriyor

4.5 Yasaklı Parola Listeleri ve Kurum İçi Terimlerin Engellenmesi

Yasaklı parola listeleri (breached password lists), parola politikalarının en etkin bileşenlerinden birini oluşturmaktadır. Bu listeler, bilinen sızıntı parolalarını, sözlük kelimelerini ve kuruma özgü terimleri içermektedir.

4.5.1 Yasaklı Parola Listesi Oluşturma

Etkili bir yasaklı parola listesi aşağıdaki kaynaklardan derlenmelidir:

1. **Kamusal sızıntı veritabanları:** Have I Been Pwned, RockYou, SecLists gibi kaynaklardan edinilen parolalar
2. **Kurum içi terimler:** Şirket adı, ürün isimleri, şube isimleri, iç terminoloji
3. **Sektöre özgü kelimeler:** Bankacılıkta "hesap", "bakiye"; sağlıkta "hasta", "reçete"

4. **Popüler kültür referansları:** Dizi isimleri, sporcu isimleri, güncel olaylar
5. **Coğrafi terimler:** Şehir isimleri, ilçe isimleri, sokak isimleri
6. **Tarih ve sayısal kalıplar:** Yıl, tarih formatları, ardışık sayılar

4.5.2 Kurum İçi Terim Engelleme

Kurum içi terimlerin engellenmesi, özellikle kurumsal ortamlarda kritik öneme sahiptir. Bir çalışanın parolasında kuruluş adı, departman adı veya iç proje adı bulunması, hedefli sözlük saldırılarını kolaylaştırmaktadır.

Engellenmesi gereken kurum içi terimler:

- **Kuruluş adı ve kısaltmaları** (örneğin "ABC", "ABCŞirket")
- **Departman/birim adları** (örneğin "muhasabe", "ik", "bilgi teknolojileri")
- **Ürün ve hizmet isimleri**
- **İç proje kod adları**
- **Yönetici isimleri ve unvanları**
- **Adres ve lokasyon bilgileri**
- **Sektöre özgü jargon**

4.5.3 Liste Güncelleme ve Bakım

Yasaklı parola listelerinin etkinliği, düzenli güncellenmesine bağlıdır. Güncelleme stratejisi:

Güncelleme Kaynağı	Sıklık	Sorumluluk
Kamusal sızıntı veritabanları	Haftalık otomatik	Siber güvenlik ekibi
Kurum içi kelime ekleme	Aylık	İnsan kaynakları + BT
Sektörel tehdit istihbaratı	Aylık	Güvenlik operasyonları
Kullanıcı bildirimleri	Sürekli	Servis masası
Denetim bulguları	Üç aylık	iç denetim

Tablo 4.5: Liste güncelleme kaynağı ve sıklığı

4.5.4 Teknik Uygulama

Parola listesi kontrolü, kullanıcı kaydı ve parola değiştirme süreçlerinde gerçek zamanlı olarak yapılmalıdır. Teknik uygulama için aşağıdaki yaklaşımlar mevcuttur:

- **Kapsamlı liste kontrolü:** Parola, listem tamamıyla eşleşmeli (büyük/küçük harf duyarsız)
- **Alt dize kontrolü:** Parola içindeki en az 4 karakterlik bir dize listede varsa engellenmeli
- **Yakınlaştırma:** Levenshtein mesafesine göre benzer parolalar da engellenebilir
- **Performans optimizasyonu:** Bloom filtreleri veya hash tabloları ile hızlı arama

4.6 Politika Metni, İstisna Yönetimi, Denetim Kanıtları

Bir parola politikasının etkinliği, yalnızca teknik uygulamayla değil, aynı zamanda politika metninin netliği, istisna yönetiminin disiplini ve denetim kanıtlarının yeterliliği ile ölçülmektedir.

4.6.1 Politika Metni Yazım İlkeleri

Etkili bir parola politika metni aşağıdaki niteliklere sahip olmalıdır:

- **Net ve anlaşılır dil:** Teknik terimlerin açıklamalı kullanımı
- **Kapsam tanımlaması:** Hangi kullanıcı gruplarını ve sistemleri kapsadığı
- **Sorumluluk atama:** Her kural için sorumlu birim ve birey
- **Uygulama adımları:** Politikanın nasıl hayata geçirildiğinin açıklanması
- **İhlal sonuçları:** Politika ihlali durumunda uygulanacak yaptırımlar
- **Güncelleme sıklığı:** Politikanın gözden geçirilme zaman çizelgesi

4.6.2 İstisna Yönetimi

Her politikada belirli durumlar için istisnalar gerekebilir. İstisna yönetimi süreci:

1. **İstisna talebi:** Kullanıcı veya birim tarafından yazılı olarak yapılır
2. **Risk değerlendirmesi:** Siber güvenlik ekibi tarafından risk analizi yapılır
3. **Onay mercii:** Belirlenmiş bir onay zincirinden geçer
4. **Dokümantasyon:** İstisna gerekçesi, süresi ve alternatif kontrolleri kaydedilir

5. **Periyodik gözden geçirme:** İstisnalar altı ayda bir yeniden değerlendirilir
6. **Süre sonu:** İstisna otomatik olarak sona erer, yenilenmezse standart politika uygulanır

4.6.3 Denetim Kanıtları

Denetim kanıtları, parola politikasının uygulandığını gösteren somut delillerdir. Gerekli kanıtlar:

Kanıt Türü	İçerik	Saklama Süresi
Politika onay kayıtları	Politikanın kabul tarihi ve imza sahipleri	Politika geçerlilik süresi + 3 yıl
Kullanıcı bildirimleri	Politika dağıtım ve okuma onayları	2 yıl
İstisna talepleri	Talep formu, risk değerlendirmesi, onay	2 yıl
Parola sıfırlama kayıtları	Kimin, ne zaman, neden sıfırladığı	1 yıl
Politika ihlal kayıtları	Tespit edilen ihlaller ve müdahaleler	3 yıl
Politika güncelleme geçmişi	Önceki versiyonlar ve değişiklik gerekçeleri	Politika geçerlilik süresi + 5 yıl

Tablo 4.6: Denetim kanıt türleri ve saklama süreleri

4.7 Kurumsal Parola Politikası Şablonu

Aşağıda, bir kurumun kendi parola politikasını oluştururken kullanabileceği bir şablon sunulmaktadır. Bu şablon, NIST ve OWASP yönergelerine uygun olarak hazırlanmıştır.

Parola Politikası Şablonu

Politika Adı: Kurumsal Parola Güvenliği Politikası **Versiyon:** 1.0 **Geçerlilik Tarihi:** [Tarih] **Sorumlu Birim:** Bilgi Güvenliği Departmanı **Politika Sahibi:** CISO

1. Kapsam Bu politika, [Kurum Adı]'na ait tüm bilgi sistemlerine erişim sağlayan tüm kullanıcıları kapsar.

2. Parola Gereksinimleri - Minimum uzunluk: 12 karakter (MFA kullanılmayan sistemler için 16) - Maksimum uzunluk: 128 karakter - Yasaklı parola listesi kontrolü zorunludur - Kurum içi terimler parolada kullanılamaz - Parola ipuçları (büyük harf, rakam zorunluluğu) uygulanmaz - Parola yenileme zorunlu değildir; yalnızca şüphe durumunda yenilenir

3. Çoklu Faktör Kimlik Doğrulama - Tüm hassas hesaplar için MFA zorunludur - Yüksek riskli işlemler için ek doğrulama gereklidir

4. İstisna Yönetimi İstisnalar yazılı olarak talep edilir ve CISO tarafından onaylanır. İstisnalar altı ayda bir yeniden değerlendirilir.

5. Denetim ve Uyum Bu politika, yılda bir kez gözden geçirilir. İhlaller, 24 saat içinde CISO'ya bildirilir.

4.8 Politika Olgunluk Rubriği

Parola politikasının olgunluğunu değerlendirmek için aşağıdaki rubrik kullanılabilir:

Olgunluk Seviyesi	Tanım	Kriterler
Seviye 1: Başlangıç	Temel politika mevcut	Minimum parola uzunluğu tanımlı, yazılı politika var
Seviye 2: Geliştirme	Politika genişletilmiş	Karmaşıklık kuralları, yasaklı liste, periyodik rotasyon
Seviye 3: Olgun	NIST uyumlu	Risk temelli rotasyon, kurum içi terim engelleme, MFA
Seviye 4: Gelişmiş	Otomatistik	Gerçek zamanlı sızıntı izleme, otomatik politika uygulama
Seviye 5: En İyileştirilmiş	Sürekli iyileştirme	Veriye dayalı optimizasyon, davranış analizi, adaptif politika

Tablo 4.7: Parola politikası olgunluk rubriği

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenci:

1. Parola uzunluğu ve karmaşıklık gereksinimlerinin güvenlik üzerindeki etkisini analiz edebilir
2. Passphrase yaklaşımının avantajlarını ve sınırlılıklarını değerlendirebilir
3. Risk temelli rotasyon modelinin zorunlu rotasyona göre üstünlüğünü açıklayabilir
4. Yasaklı parola listelerinin nasıl oluşturulacağını ve güncelleneceğini kavrar
5. Kurumsal parola politikasını NIST ve OWASP yönergelerine uygun biçimde tasarlayabilir
6. Politika olgunluğunu rubrik kullanarak değerlendirebilir

Risk Modeli

Parola politikaları alanında karşılaşılan temel riskler:

Risk	Olasılık	Etki	Öncelik
Güçlü parola politikasının kullanıcı direnciyle karşılaşması	Yüksek	Orta	Yüksek
Yasaklı parola listesinin güncellenmemesi	Orta	Yüksek	Yüksek
İstisna yönetiminin gevşemesi	Orta	Yüksek	Yüksek
Politika metninin yetersiz dokümantasyonu	Düşük	Orta	Orta
Denetim kanıtlarının eksikliği	Düşük	Yüksek	Orta
Eski politikanın hâlâ uygulanması	Orta	Orta	Orta

Tablo 4.8: Politika risk matrisi

Savunma Kontrolleri

1. **Önleyici kontroller:** Net politika metni, kullanıcı eğitimi, otomatik politika uygulama
2. **Belirleyici kontroller:** Parola kalitesi izleme, ihlal algılama, anomali tespiti
3. **Düzeltilici kontroller:** Hızlı müdahale prosedürleri, politika güncelleme, denetim
4. **Yönlendirici kontroller:** Üst yönetim desteği, politika sahipliği, sürekli iyileştirme

Güvenli Anlatım Notu

Önemli Not: Bu bölümde sunulan parola politikası ilkeleri, yalnızca savunma amaçlıdır. Parola politikalarının tasarımı ve uygulaması, kuruluşun özel ihtiyaçlarına ve mevzuat gereksinimlerine göre uyarlanmalıdır. Politika oluştururken veya uygularken, yerel yasal düzenlemeler ve sektörel standartlar dikkate alınmalıdır.

Kullanıcılara parola politikası eğitimi verilirken, politikanın "neden" gerekli olduğu vurgulanmalıdır. Zorlayıcı kurallar yerine, kullanıcının politikayı anlaması ve benimsemesi hedeflenmelidir.

Kaynaklar

- NIST SP 800-63B-4: Digital Identity Guidelines — Authentication and Authenticator Management (2025)
- OWASP Authentication Cheat Sheet (2024)
- Microsoft Entra ID - Password Policy Configuration (2024)
- ENISA - Good Practices for Password Management (2023)
- Bonneau, J. & Preibusch, S. (2015). "The Password Thicket: Technical and Market Failures in Human Authentication on the Web." Proceedings of WEIS.

- Shay, R. et al. (2010). "So Long, and No Thanks for the Rheumatology: A Reevaluation of Password Policies and Procedures." Proceedings of CHI.
-

BÖLÜM 5 — PAROLA ELDE ETME YÖNTEMLERİNİN KAVRAMSAL SINIFLANDIRMASI

[↩ İndekilere dön](#)

Amaç

Bu bölüm, saldırganların parolaları elde etmek için başvurduğu çeşitli yöntemleri kavramsal olarak sınıflandırmakta ve her bir yöntemin teknik özelliklerini, risklerini ve savunma kontrollerini ele almaktadır. Parola elde etme yöntemlerinin kapsamlı bir biçimde anlaşılması, etkin savunma stratejilerinin geliştirilmesinin temel koşuludur. Bu bölümün sonunda, farklı parola elde etme yöntemlerini sınıflandırabilmeniz, risk seviyelerini değerlendirebilmeniz ve katmanlı savunma kontrolleri tasarlayabilmeniz beklenmektedir.

Araştırma Soruları

1. Parola elde etme yöntemleri nasıl sınıflandırılabilir?
2. Her bir yöntemin teknik ve insani boyutu nedir?
3. Katmanlı savunma kontrolleri nasıl tasarlanmalıdır?
4. Tehdit-kontrol matrisi nasıl oluşturulur?

5.1 Sosyal Mühendislik ve Kimlik Avı

Sosyal mühendislik, insan psikolojisini ve davranışlarını manipüle ederek parola veya hassas bilgi elde etme yöntemlerinin genel adıdır. Kimlik avı (phishing), sosyal mühendisliğin en yaygın ve etkili türüdür.

5.1.1 Sosyal Mühendisliğin Tanımı ve Kapsamı

Sosyal mühendislik, teknik kontroller kadar insan karar süreçlerini de hedef alan bir saldırı sınıfıdır. Saldırganlar güven oluşturma, aciliyet hissi yaratma veya korku verme yoluyla hedef kişiyi belirli bir eyleme yöneltir.

Sosyal mühendislik saldırılarının temel özellikleri:

- **İnsan odaklı:** Teknik sistemleri değil, insanları hedef alır
- **Manipülasyon:** Duygusal ve bilişsel önyargıları istismar eder
- **Güven istismarı:** Mevcut ilişki veya yetkili konum izlenimi yaratır
- **Çeşitlilik:** Farklı iletişim kanalları ve senaryolar kullanır
- **Ölçeklenebilirlik:** Dijital araçlarla binlerce kişiye aynı anda ulaşılabilir

5.1.2 Kimlik Avı Türleri

Kimlik avı saldırıları iletişim kanalı ve hedef kitleye göre çeşitli türlere ayrılmaktadır:

E-posta Tabanlı Kimlik Avı: - **Taklitçi kimlik avı:** Ünlü bir markanın veya kuruluşun e-posta adresi taklit edilerek gönderilir - **Hedefli kimlik avı:** Belirli bir birey veya kuruluş için özelleştirilmiş e-posta - **Balina avı:** Üst düzey yöneticileri hedef alan yüksek değerli saldırı - **Klonlama:** Mevcut bir e-postanın içeriği kopyalanarak farklı alıcıya gönderilir

SMS/Sosyal Medya Tabanlı Kimlik Avı (Smishing/Vishing): - **Smishing:** SMS yoluyla gönderilen kimlik avı bağlantıları - **Vishing:** Sesli arama yoluyla kişisel bilgi toplama - **Sosyal medya kimlik avı:** Sahte profiller veya mesajlar aracılığıyla bilgi toplama

Çok Kanallı Kimlik Avı: Bir saldırı, birden fazla kanalı aynı anda kullanabilir. Örneğin, bir kullanıcıya önce sahte bir e-posta gönderilip, ardından telefon araması yapılarak güven oluşturulabilir.

5.1.3 Kimlik Avı Saldırılarının Analizi

Bir kimlik avı saldırısının başarılı olma süreci aşağıdaki aşamalardan oluşur:

1. **Hazırlık:** Hedef kitlenin belirlenmesi ve iletişim bilgilerinin toplanması
2. **Altyapı:** Sahte web sitesi, e-posta sunucusu veya iletişim kanalı kurulumu

3. **Dağıtım:** Kimlik avı içeriğinin hedeflere iletilmesi
4. **Etkileşim:** Hedefin sahte içeriğe tıklaması veya yanıt vermesi
5. **Veri toplama:** Girilen parola veya kişisel bilginin kaydedilmesi
6. **İstismar:** Elde edilen bilgilerin kullanılması

5.1.4 Kimlik Avı İstatistikleri ve Trendleri

Yıl	Kimlik Avı Saldırı Sayısı	Başarı Oranı	Ortalama Maliyet
2020	1,2 milyon	%3,2	\$3,900/dakika
2021	1,4 milyon	%3,6	\$4,200/dakika
2022	1,6 milyon	%4,1	\$4,800/dakika
2023	1,8 milyon	%4,5	\$5,100/dakika
2024 (tahmini)	2,1 milyon	%4,8	\$5,500/dakika

Tablo 5.1: Kimlik avı saldırı trendleri (kaynak: APWG, Verizon DBIR)

5.1.5 Kimlik Avı Örnekleri (Gerçek Hayattan Öğrenim)

Örnek 1: Kurumsal Kimlik Avı Bir çalışan, "BT Departmanı"ndan geldiğini iddia eden bir e-posta alır. E-postada, parola süresinin dolduğu ve hemen güncellenmesi gerektiği belirtilir. Bağlantıya tıklandığında, meşru oturum açma sayfasını taklit eden sahte bir site açılır. Çalışan parolasını girer ve bilgiler saldırgan tarafından ele geçirilir.

Örnek 2: Müşteri Kimlik Avı Bir banka müşterisi, bankasının adını taşıyan sahte bir e-posta alır. E-postada, hesap güvenliği için parolanın güncellenmesi gerektiği belirtilir. Müşteri, güven duyduğu için parolasını sahte sitede girer ve hesap bilgileri çalınır.

Örnek 3: Üst Düzey Yönetici Hedeflemesi (Balina Avı) Bir CFO, CEO'nun adını taşıyan ve "acil ödeme onayı" gerektiren bir e-posta alır. E-posta, meşru görünmesi için gerçek proje adları ve iç terminoloji içerir. CFO, parolasını girerek işlemi onaylamaya çalışır.

5.1.6 Savunma Kontrolleri

Sosyal mühendislik ve kimlik avına karşı savunma kontrolleri:

Teknik Kontroller: - E-posta filtreleme ve kimlik doğrulama (SPF, DKIM, DMARC)
 - Web sitesi filtreleme ve zararlı bağlantı engelleme - Çoklu faktör kimlik doğrulama (MFA) - Tarayıcı tabanlı kimlik avı algılama - Zararlı yazılım koruması

İdari Kontroller: - Düzenli kimlik avı farkındalık eğitimi - Simüle kimlik avı testleri (test e-postaları) - Şüpheli e-posta bildirim prosedürü - Üst düzey yetkililer için özel koruma prosedürleri - Politika dokümantasyonu ve güncelleme

Fiziksel Kontroller: - Hassas bilgilere erişim kontrolü - Misafir erişim yönetimi - Fiziksel güvenlik kameraları

5.2 Veri Sızıntılarından Tekrar Kullanım Riski

Veri sızıntıları, parola güvenliğinin en büyük tehditlerinden birini oluşturmaktadır. Bir kullanıcı parolasının bir sistemde sızması, aynı parolayı diğer sistemlerde kullanan tüm hesapları risk altına sokmaktadır.

5.2.1 Veri Sızıntılarının Boyutu

Son yıllarda yaşanan büyük veri sızıntılarının boyutları endişe verici düzeydedir:

Sızıntı	Yıl	Etkilenen Hesap Sayısı	Sızan Veri Türü
LinkedIn	2012, 2021	164 milyon + 700 milyon	Parola hash'leri, e-posta
Yahoo	2013-2014	3 milyar	Parola hash'leri, kişisel bilgi
Adobe	2013	153 milyon	Şifrelenmiş parolalar
Dropbox	2012	68 milyon	Parola hash'leri
Facebook	2019	530 milyon	Telefon numaraları, parolalar
Collection #1	2019	773 milyon	E-posta + parola çiftleri
RockYou2021	2021	8,4 milyar	Parola listesi

Tablo 5.2: Büyük veri sızıntıları (seçme)

5.2.2 Parola Tekrar Kullanım Sorunu

Parola tekrar kullanımı, bir hizmetteki sızıntının diğer hizmetlerde kimlik bilgisi doldurma saldırısına dönüşmesini sağlar. Bu zincirleme etki, parola benzersizliği ve parola yöneticisi kullanımını temel savunma kontrolü hâline getirir (Das vd., 2014).

Parola tekrar kullanımının riskleri:

- **Kartopu etkisi:** Bir hesap ele geçirildiğinde, tüm benzer parolalı hesaplar risk altında
- **Zaman baskısı:** Kullanıcılar parolaları hızlıca değiştirmede için risk uzun süre devam eder
- **Ölçek etkisi:** Büyük sızıntılar milyonlarca hesabı etkiler
- **Tespit zorluğu:** Kullanıcı, parolasının sızdığını her zaman fark etmeyebilir

5.2.3 Sızıntı Veritabanları ve Tespit

Parola sızıntılarının tespiti için çeşitli mekanizmalar mevcuttur:

1. **Have I Been Pwned (HIBP):** Troy Hunt tarafından geliştirilen, e-posta tabanlı sızıntı arama servisi
2. **Kural bazlı parola kontrolü:** Kullanıcı parolasının bilinen sızıntı listelerinde aranması
3. **Tehdit istihbarat kaynakları:** Kurumsal tehdit istihbarat servisleri
4. **Dark web izleme:** Karanlık ağda dolaşan parola listelerinin takibi

5.2.4 Parola Sızıntısı Tespit Matrisi

Sızıntı Kaynağı	Bilgi Türü	Tespit Zorluğu	Risk Seviyesi
Kamusal sızıntı veritabanları	E-posta + parola	Düşük	Yüksek
Dark web forumları	Parola hash'leri	Orta	Yüksek
Zararlı yazılım logları	Düz metin parolalar	Orta	Çok Yüksek
Kurum içi sızıntılar	Kurumsal parolalar	Yüksek	Çok Yüksek
Üçüncü parti satıcılar	Müşteri parolaları	Yüksek	Yüksek

Tablo 5.3: Sızıntı kaynağı ve risk değerlendirme

5.2.5 Savunma Kontrolleri

Veri sızıntılarından kaynaklanan tekrar kullanım riskine karşı:

Önleyici Kontroller: - Benzersiz parola zorunluluğu (her sistem için farklı parola)
- Parola yöneticisi kullanımı teşviki - Parola tekrar kontrolü (kayıt sırasında sızıntı listesi kontrolü) - Parola karmaşıklığı ve uzunluk gereksinimleri

Belirleyici Kontroller: - Sızıntı bildirim servisleri ile entegrasyon - Düzenli parola kalitesi denetimi - Kullanıcı hesaplarında anormallik izleme

Düzeltilici Kontroller: - Sızıntı tespit edildiğinde otomatik parola sıfırlama - Etkilenen hesapların bildirilmesi - Olay sonrası inceleme ve politika güncelleme

5.3 Zararlı Yazılım ve Uç Nokta Güvenliği

Zararlı yazılım (malware), parolaların ele geçirilmesinde kritik bir araç olarak kullanılmaktadır. Keylogger, credential stealer ve trojan gibi zararlı yazılım türleri, kullanıcının parolasını doğrudan ele geçirebilmektedir.

5.3.1 Zararlı Yazılım Türleri ve Parola Hırsızlığı

Keylogger (Tuş Kaydedici): Kullanıcının klavye girişlerini kaydeden zararlı yazılımdır. Parola girilirken her tuş basımı kaydedilir ve saldırganın sunucusuna iletilir. Keylogger'lar hem donanımsal hem de yazılımsal olabilir.

Credential Stealer (Kimlik Bilgisi Hırsızı): Tarayıcı depolanan parolaları, oturum çerezlerini ve kimlik bilgilerini çalan zararlı yazılımdır. Örneğin, bir credential stealer, tarayıcının parola deposuna erişerek tüm kayıtlı parolaları çalabilir.

RAT (Uzaktan Erişim Aracı): Bilgisayara uzaktan erişim sağlayan ve parola gibi hassas bilgileri toplayan zararlı yazılımdır. RAT'lar genellikle spear-phishing yoluyla dağıtılır.

Banking Trojan: Özellikle finansal bilgileri hedef alan zararlı yazılımlardır. Oturum açma bilgilerini, banka hesap parolalarını ve işlem detaylarını çalabilir.

5.3.2 Saldırı Vektörleri

Zararlı yazılımların dağıtımı için kullanılan başlıca vektörler:

Vektör	Açıklama	Önlem
E-posta ekleri	Makro içerikli belgeler, exe dosyaları	E-posta filtreleme, makro engelleme
Zararlı web siteleri	Drive-by download, sahte yazılım güncellemeleri	Web filtreleme, tarayıcı güvenliği
USB/cihaz	Otomatik çalıştırma, fiziksel erişim	USB engelleme, cihaz yönetimi
Yazılım cracks/serialer	Ücretsiz yazılım arayışında indirilen zararlı dosyalar	Yazılım whitelist, eğitim
Reklam yazılımları	Tarayıcı eklentileri, sahte güncelleme uyarıları	Reklam engelleyici, eğitim

Tablo 5.4: Zararlı yazılım saldırı vektörleri

5.3.3 Uç Nokta Güvenliği

Uç nokta (endpoint) güvenliği, parolaların zararlı yazılımlardan korunmasında kritik öneme sahiptir. Etkili bir uç nokta güvenliği stratejisi:

Temel Koruma Katmanları: 1. **Antivürist/Antimalware:** İmza tabanlı ve davranışsal algılama 2. **EDR (Endpoint Detection and Response):** Gelişmiş tehdit algılama ve müdahale 3. **Yazılım whitelist:** Yalnızca onaylı yazılımların çalıştırılması 4. **Otomatik güncelleme:** İşletim sistemi ve uygulama güncellemeleri 5. **Veri şifreleme:** Disk ve dosya düzeyinde şifreleme

İleri Düzey Koruma: - **Zero Trust mimarisi:** Her cihaza güvenilmeyen yaklaşım - **Mikro segmentasyon:** Ağ içi segmentasyon ve izolasyon - **Behavioral analiz:** Anormal davranış tespiti - **UEBA (User and Entity Behavior Analytics):** Kullanıcı davranış analizi

5.3.4 Uç Nokta Güvenlik Kontrol Matrisi

Kontrol	Maliyet	Etkinlik	Uygulama Zorluğu
Antivürist yazılım	Düşük	Orta	Düşük
EDR çözümü	Orta	Yüksek	Orta
Yazılım whitelist	Düşük-Orta	Yüksek	Orta
Disk şifreleme	Düşük	Yüksek	Düşük
Zero Trust	Yüksek	Çok Yüksek	Yüksek
Mikro segmentasyon	Yüksek	Yüksek	Yüksek

Tablo 5.5: Uç nokta güvenlik kontrolleri karşılaştırması

5.4 Fiziksel Güvenlik Riskleri

Parola güvenliği, yalnızca dijital ortamda değil, fiziksel ortamda da tehdit altındadır. Fiziksel erişim, parolaların ele geçirilmesinde doğrudan veya dolaylı yoldan rol oynayabilmektedir.

5.4.1 Fiziksel Erişim Riskleri

Cihaz Hırsızlığı: Dizüstü bilgisayar, tablet veya akıllı telefon çalınması, depolanan parolaların ele geçirilmesi anlamına gelebilir. Özellikle disk şifrelemesi yapılmamış cihazlar yüksek risk taşımaktadır.

Fiziksel Erişim: Bir saldırganın bir çalışma alanına fiziksel olarak erişmesi, aşağıdaki riskleri doğurabilir: - Çalışan ekran üzerinde parola girerken izleme (shoulder surfing) - Klavye veya fareye donanımsal keylogger yerleştirme - Yazılı parola notlarının çalınması - USB portlarına zararlı cihaz bağlama - Atık kağıtlardan parola bilgisi toplama

Çöp Torbası Saldırısı (Dumpster Diving): Atılan kağıtlar, diskler veya elektronik cihazlardan parola bilgilerinin toplanmasıdır. Hassas bilgilerin imha edilmemesi bu riske yol açar.

5.4.2 Fiziksel Güvenlik Kontrolleri

Kontrol Türü	Örnekler	Risk Azaltma
Erişim kontrolü	Manyetik kart, biyometrik, PIN	Yetkisiz erişim engelleme
İzleme	Güvenlik kameraları, alarm sistemi	Tespit ve caydırıcılık
Alan güvenliği	Kapalı dolap, kasa, güvenlik duvarı	Fiziksel koruma
Ziyaretçi yönetimi	Kayıt sistemi, refakatçi zorunluluğu	Kontrollü erişim
İmha prosedürleri	Kağıt shredder, disk imhası	Bilgi sızıntısı önleme
Mobil cihaz yönetimi	Uzaktan silme, şifreleme	Cihaz kaybı riski azaltma

Tablo 5.6: Fiziksel güvenlik kontrolleri

5.4.3 Shoulder Surfing (Omuzdan İzleme)

Omuzdan izleme, bir kullanıcının parola veya hassas bilgi girerken fiziksel olarak izlenmesidir. Bu yöntem, özellikle kalabalık ortamlarda (internet kafeler, ortak çalışma alanları, havaalanları) etkilidir.

Korunma yöntemleri: - Ekran gizlilik filtresi kullanımı - Parolaları ekranda gizli modda girme - Ortak alanlarda parola girmekten kaçınma - Mobil cihazlarda parmak izi veya yüz tanıma kullanımı

5.5 Güvensiz Protokoller ve Aktarım Güvenliği

Parola ve kimlik bilgilerinin güvenli olmayan protokoller üzerinden iletilmesi, orta adam (man-in-the-middle) saldırılarına yol açabilmektedir. Aktarım güvenliği, parola güvenliğinin kritik bir bileşenidir.

5.5.1 Güvensiz Protokoller

HTTP (Hypertext Transfer Protocol): Verileri düz metin (plain text) olarak ileten protokoldür. HTTP üzerinden gönderilen parolalar, ağ üzerinde herhangi bir noktada dinlenebilir. Bu nedenle, parola iletimi için HTTP asla kullanılmamalıdır.

FTP (File Transfer Protocol): Varsayılan olarak düz metin kullanan dosya aktarım protokolüdür. FTP üzerinden yapılan kimlik doğrulamaları güvenli değildir. FTPS veya SFTP kullanımı önerilmektedir.

Telnet: Uzak terminal erişimi sağlayan ve tüm trafiği düz metin olarak ileten protokoldür. SSH ile değiştirilmelidir.

POP3/IMAP (şifrelenmemiş): E-posta erişim protokolleri, varsayılan olarak şifreleme kullanmaz. TLS tabanlı varyantların (POP3S, IMAPS) kullanımı gereklidir.

5.5.2 Güvenli Protokoller ve Şifreleme

TLS/SSL (Transport Layer Security): İnternet üzerinden güvenli iletişim sağlayan şifreleme protokolüdür. HTTPS (HTTP over TLS), web tabanlı kimlik doğrulamada standart haline gelmiştir.

Protokol	Şifreleme	Kullanım Alanı	Güvenlik
HTTP	Yok	Web sayfaları	Düşük
HTTPS	TLS	Web kimlik doğrulama	Yüksek
FTP	Yok	Dosya aktarımı	Düşük
FTPS/FTP over TLS	TLS	Dosya aktarımı	Yüksek
SFTP	SSH	Dosya aktarımı	Yüksek
Telnet	Yok	Uzak erişim	Düşük
SSH	SSH	Uzak erişim	Yüksek

Tablo 5.7: Protokol güvenliği karşılaştırması

5.5.3 Ortadam (Man-in-the-Middle) Saldırıları

Ortadam saldırıları, iki taraf arasındaki iletişimi dinleyen veya değiştiren saldırılardır. Parola güvenliği açısından en tehlikeli saldırı türlerinden biridir.

Saldırı senaryosu: 1. Kullanıcı meşru web sitesine bağlanmaya çalışır 2. Saldırgan, kullanıcının trafiğini yönlendirir (DNS zehirleme, ARP spoofing) 3. Kullanıcı, sahte siteye bağlanır 4. Kullanıcı parolasını girer 5. Saldırgan parolayı yakalar ve gerçek siteye iletir 6. Kullanıcı oturum açtığını sanır, saldırgan ise parolayı ele geçirmiştir

Savunma Kontrolleri: - HTTPS zorunluluğu ve HSTS (HTTP Strict Transport Security) kullanımı - Sertifika pinning uygulaması - DNS güvenliği (DNSSEC) - VPN kullanımı kamusal ağlarda - Tarayıcı güvenlik uyarılarına dikkat

5.6 Oturum Bilgisi Hırsızlığı

Oturum (session) bilgisi hırsızlığı, kullanıcı oturum açma bilgilerinin çalınması yoluyla yetkisiz erişim elde etme yöntemidir. Bu saldırı türü, parola doğrudan ele geçirilmese bile aynı etkiyi yaratabilmektedir.

5.6.1 Oturum Çerezleri ve Güvenliği

Web uygulamaları, kullanıcı oturumlarını sürdürmek için çerezler (cookies) kullanmaktadır. Bu çerezlerin ele geçirilmesi, parola bilgisi olmadan hesaba erişim sağlanabilmesi anlamına gelir.

Oturum Çalma (Session Hijacking) Yöntemleri:

Yöntem	Açıklama	Risk
Cross-Site Scripting (XSS)	Zararlı script enjeksiyonu ile çerez çalma	Yüksek
Cross-Site Request Forgery (CSRF)	Yetkisiz işlem yaptırma	Yüksek
Session Fixation	Oturum kimliği önceden belirleme	Orta
Cookie Theft	Tarayıcı açıkları ile çerez çalma	Yüksek
Network Sniffing	Ağ trafiğini dinleme	Yüksek

Tablo 5.8: Oturum hırsızlığı yöntemleri

5.6.2 Session Token Güvenliği

Oturum belirteçlerinin (session token) güvenliği için alınması gereken önlemler:

1. **Token rastgeelliği:** Yüksek entropili, tahmin edilemez token'lar
2. **HTTPS zorunluluğu:** Tüm oturum trafiğinin şifreli olması
3. **HttpOnly ve Secure bayrakları:** Çerezlerin JavaScript erişimine kapatılması
4. **Oturum sonlandırma:** Pasif ve aktif oturum zaman aşımaları

5. **IP tabanlı doğrulama:** Oturum süresince IP değişikliği kontrolü
6. **Fingerprinting:** Cihaz ve tarayıcı parmak izi ile oturum doğrulama

5.6.3 JWT (JSON Web Token) Güvenliği

JWT, modern web uygulamalarında yaygın olarak kullanılan oturum belirteç formatıdır. JWT güvenliği için:

- **İmza doğrulama:** Her JWT isteğinin imzasının doğrulanması
- **Kısa ömür:** Access token'ların kısa süreli (5-15 dakika) olması
- **Refresh token:** Uzun ömürlü refresh token'ların güvenli depolanması
- **Algoritma seçimi:** HMAC veya RSA gibi güvenli imza algoritmaları
- **Subject scope:** Token'ların yalnızca gerekli izinleri içermesi

5.7 Katmanlı Savunma Kontrolleri

Parola güvenliği, tek bir kontrol noktasına bağlı kalmayan, çok katmanlı bir savunma yaklaşımı gerektirir. Bu yaklaşımda, her bir kontrol katmanı birbirini tamamlar ve bir katmanın başarısız olması durumunda diğer katmanlar devreye girer.

5.7.1 Savunma Katmanları

Birinci Katman: Önleyici Kontroller - Parola politikası uygulaması - Kullanıcı eğitimi ve farkındalık - Teknik kontroller (MFA, parola karmaşıklığı) - Erişim kontrolü

İkinci Katman: Belirleyici Kontroller - Olay izleme ve algılama - Anomali tespiti - Log analizi - Tehdit istihbaratı

Üçüncü Katman: Düzeltici Kontroller - Olay müdahale prosedürleri - Hesap kurtarma mekanizmaları - Politika güncelleme - Denetim ve iyileştirme

5.7.2 Savunma Katmanları Matrisi

Katman	Kontrol Türü	Örnekler	Etkinlik
1. Önleyici	Politika ve eğitim	Parola politikası, farkındalık eğitimi	Yüksek

Katman	Kontrol Türü	Örnekler	Etkinlik
1. Önleyici	Teknik	MFA, parola yöneticisi, şifreleme	Çok Yüksek
2. Belirleyici	İzleme	SIEM, IDS/IPS, log analizi	Yüksek
2. Belirleyici	Algılama	Anomali tespiti, behavioral analiz	Orta-Yüksek
3. Düzeltici	Müdahale	Olay müdahale, hesap kurtarma	Yüksek
3. Düzeltici	İyileştirme	Politika güncelleme, denetim	Orta

Tablo 5.9: Katmanlı savunma kontrolleri matrisi

5.8 Risk Taksonomisi ve Tehdit-Kontrol Matrisi

Parola güvenliği risklerinin sistematik olarak sınıflandırılması, etkin savunma stratejileri geliştirmenin temel adımıdır.

5.8.1 Risk Taksonomisi

Teknik Riskler: - Zayıf parola seçimi - Parola tekrar kullanımı - Eski veya sızdırılmış parolalar - Güvensiz depolama - Güvensiz iletim

İnsani Riskler: - Sosyal mühendislik - Fiziksel ihmal - Eğitim eksikliği - Politika ihlali

Organizasyonel Riskler: - Yetersiz politika - Kaynak kısıtlılığı - Üst yönetim desteği eksikliği - Denetim eksikliği

Dış Riskler: - Büyük ölçekli veri sızıntıları - Sıfırcı gün açıkları - Devlet destekli saldırılar - Üçüncü parti riskleri

5.8.2 Tehdit-Kontrol Matrisi

Tehdit	Olasılık	Etki	Mevcut Kontroller	Önerilen Kontroller
Kimlik avı	Yüksek	Yüksek	E-posta filtreleme	MFA, eğitim, simülasyon

Tehdit	Olasılık	Etki	Mevcut Kontroller	Önerilen Kontroller
Veri sızıntısı	Yüksek	Çok Yüksek	Parola politikası	Sızıntı izleme, benzersiz parola
Zararlı yazılım	Orta	Yüksek	Antivürist	EDR, behavioral analiz
Fiziksel erişim	Orta	Orta	Erişim kontrolü	Biyometrik, izleme
Protokol istismarı	Düşük	Yüksek	HTTPS	TLS 1.3, sertifika pinning
Oturum çalma	Orta	Yüksek	Çerez güvenliği	Token rotation, fingerprinting
Parola kırma (offline)	Orta	Çok Yüksek	Hash şifreleme	Argon2, bcrypt, pepper

Tablo 5.10: Tehdit-kontrol matrisi

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenci:

1. Parola elde etme yöntemlerini kavramsal olarak sınıflandırabilir
2. Sosyal mühendislik saldırı türlerini ve savunma kontrollerini analiz edebilir
3. Veri sızıntılarından kaynaklanan tekrar kullanım riskini değerlendirebilir
4. Zararlı yazılım ve uç nokta güvenliği ilişkisini açıklayabilir
5. Fiziksel güvenlik risklerini ve kontrollerini kavrar
6. Güvensiz protokollerin ve oturum hırsızlığının risklerini analiz edebilir
7. Katmanlı savunma kontrolleri tasarlayabilir
8. Tehdit-kontrol matrisi oluşturabilir

Risk Modeli

Bu bölümde ele alınan tehditlere ilişkin risk değerlendirmesi:

Tehdit	Olasılık	Etki	Risk Seviyesi	Öncelik
Kimlik avı	Yüksek	Yüksek	Yüksek	1
Parola tekrar kullanımı	Yüksek	Yüksek	Yüksek	2
Zararlı yazılım	Orta	Yüksek	Yüksek	3
Veri sızıntısı	Yüksek	Çok Yüksek	Çok Yüksek	4
Oturum hırsızlığı	Orta	Yüksek	Yüksek	5
Fiziksel erişim	Orta	Orta	Orta	6
Güvensiz protokol	Düşük	Yüksek	Orta	7

Tablo 5.11: Tehdit risk değerlendirme

Savunma Kontrolleri Özeti

- Eğitim ve Farkındalık:** Tüm kullanıcıları potansiyel tehditlere karşı bilinçlendirme
- Teknik Kontroller:** MFA, parola politikası, şifreleme, izleme
- Organizasyonel Kontroller:** Politika, süreç, sorumluluk atama
- Fiziksel Kontroller:** Erişim kontrolü, izleme, imha prosedürleri
- Sürekli İyileştirme:** Denetim, test, politika güncelleme

Güvenli Anlatım Notu

Önemli Not: Bu bölümde parola elde etme yöntemleri yalnızca savunma amaçlı ve kavramsal olarak ele alınmıştır. Hiçbir saldırı aracı, komut veya uygulama detayı verilmemiştir. Amacımız, tehditleri tanımlayarak etkin savunma stratejileri geliştirmektir.

Parola güvenliği, sürekli değişen bir tehdit ortamında sürekli güncel kalmayı gerektirir. Kuruluşlar, tehdit istihbaratı kaynaklarını takip ederek savunma kontrollerini sürekli iyileştirmelidir.

Kaynaklar

- ENISA - Threat Landscape Report (2024)
- CISA - Phishing Guidance: Stopping the Attack Cycle at Phase 1 (2023)
- OWASP Top 10 (2023)
- Verizon Data Breach Investigations Report (DBIR) (2024)
- NIST SP 800-63B-4: Digital Identity Guidelines — Authentication and Authenticator Management (2025)
- Anti-Phishing Working Group (APWG) - Phishing Activity Trends Report (2024)

BÖLÜM 6 — PAROLA KIRMA MANTIĞI

↪ İçindekilere dön

Amaç

Bu bölüm, parola kırma süreçlerinin mantıksal yapısını, tahmin yöntemlerini ve buna karşı alınabilecek savunma kontrollerini ele almaktadır. Parola kırma sürecinin anlaşılması, savunma stratejilerinin etkin biçimde tasarlanmasının temel koşuludur. Bu bölümde sunulan içerikler, yalnızca savunma amaçlıdır ve hiçbir saldırı aracı veya komut verilmemektedir. Bu bölümün sonunda, parola kırma süreçlerini mantıksal olarak analiz edebilmeniz, entropi hesaplamaları yapabilmeniz ve savunma kontrollerini tasarlamanız beklenmektedir.

Araştırma Soruları

1. Online ve offline parola tahmin saldırıları arasındaki temel farklar nelerdir?
2. Entropi parola güvenliğini nasıl etkiler?
3. Hash hesaplama maliyeti savunma tasarımında nasıl kullanılır?
4. Risk tabanlı doğrulama parola güvenliğini nasıl artırır?

6.1 Online Tahmin: Rate Limiting, Lockout, İzleme

Online parola tahmin saldırıları, parolaların bir oturum açma aracılığıyla gerçek zamanlı olarak test edilmesini içerir. Bu tür saldırılar, doğrudan bir hedef sisteme yönlendirildiği için tespit edilmesi ve engellenmesi nispeten daha kolaydır.

6.1.1 Online Saldırıların Mekaniği

Çevrim içi parola tahmininde adaylar hedef sistemin oturum açma arayüzü üzerinden denenir. Her deneme sunucuda bir istek oluşturduğundan hız sınırlama, risk tabanlı ek doğrulama ve izleme uygulanabilir.

Tipik Online Saldırı Akışı: 1. Saldırgan, hedef web sitesinin oturum açma sayfasına erişir 2. Hedef kullanıcı adı ile birlikte parola adayları denenir 3. Her deneme, sunucuda bir kimlik doğrulama isteği oluşturur 4. Yanıt (başarılı/başarısız) saldırı tarafından analiz edilir 5. Yanıt süreleri, hata mesajları veya HTTP durum kodları ipucu verebilir

6.1.2 Rate Limiting (Hız Sınırlama)

Rate limiting, belirli bir zaman aralığında yapılabilecek istek sayısını sınırlayan bir kontrol mekanizmasıdır. Parola tahmin saldırılarına karşı en temel savunma kontrollerinden biridir.

Rate Limiting Parametreleri:

Parametre	Açıklama	Örnek Değer
İstek sınırı	Belirli süre içinde max istek	5 deneme/dakika
Zaman penceresi	Sınırın hesaplandığı süre	15 dakika
Bloke süresi	Aşım sonrası bekleme	30 dakika
Kademeli artış	Hatalı deneme arttıkça bekleme süresinin artması	1, 2, 4, 8, 16 sn
IP tabanlı	IP adresine göre sınır	10 deneme/IP/gün
Hesap tabanlı	Kullanıcı hesabına göre sınır	5 deneme/hesap/saat

Tablo 6.1: Rate limiting parametreleri

Kademeli Gecikme (Exponential Backoff): Her başarısız denemeden sonra bekleme süresinin katlanarak artması, brute force saldırılarını etkin biçimde yavaşlatır.

Örnek hesaplama: - 1. hata: 1 saniye bekleme - 2. hata: 2 saniye bekleme - 3. hata: 4 saniye bekleme - 4. hata: 8 saniye bekleme - 5. hata: 16 saniye bekleme - 10. hata: ~17 dakika bekleme - 20. hata: ~30 saat bekleme

Bu modelde, 20 başarısız deneme sonrası toplam bekleme süresi yaklaşık 35 saate ulaşır. 100 deneme için süremilyonlarca yıllık bir süreye ulaşır.

6.1.3 Hesap Kilitleme (Lockout)

Hesap kilitleme, belirli sayıda başarısız deneme sonrası hesabın geçici olarak kilitlenmesidir. Bu mekanizma, online saldırıları doğrudan engellemektedir.

Hesap Kilitleme Politika Seçenekleri:

Politika	Avantajı	Dezavantajı
Sabit kilitleme (5 hata → 30 dk)	Basit uygulama	Kullanıcı deneyimi etkilenir
Kademeli kilitleme	Daha dengeli yaklaşım	Karmaşık yapılandırma
CAPTCHA tabanlı	Kullanıcı deneyimi korunur	Bot bypass riski
Risk tabanlı	En akıllı yaklaşım	Karmaşık uygulama

Tablo 6.2: Hesap kilitleme politikaları

Denial of Service (DoS) Riski: Hesap kilitleme mekanizması, saldırganlar tarafından bilinçli olarak istismar edilebilir. Büyük bir kurumda, farklı hesapların kilitlenmesi hizmet kesintisine yol açabilir. Bu nedenle, kilitleme mekanizması tasarımında bu risk de dikkate alınmalıdır.

6.1.4 İzleme ve Anomali Tespiti

Online saldırıların tespitinde izleme ve anomali tespiti kritik öneme sahiptir.

İzlenmesi Gereken Metrikler:

Metrik	Anormal Değer	Alarm Seviyesi
Dakikadaki başarısız deneme sayısı	> 10	Yüksek
Saatteki farklı kullanıcı adı denemesi	> 50	Yüksek
Farklı IP adreslerinden aynı hesaba deneme	> 3	Yüksek
Geo-anormallik (farklı ülkeler)	Ani konum değişimi	Orta
Zaman anormalliği (mesai dışı)	Gece 02:00-05:00 arası	Orta
Başarısız deneme sonrası başarı	Hemen ardından giriş	Yüksek

Tablo 6.3: İzleme metrikleri ve alarm seviyeleri

6.2 Offline Tahmin: Hash Sızıntısı Varsayımı, Maliyet Artırma

Offline parola tahmin saldırıları, parola hash'lerinin ele geçirilmesi durumunda gerçekleştirilir. Bu tür saldırılar, online saldırılara göre çok daha tehlikelidir çünkü:

- Hedef sistemde herhangi bir iz bırakmaz
- Paralel işlem ile çok yüksek hızda deneme yapılabilir
- Tespit edilmesi son derece zordur

6.2.1 Offline Saldırı Senaryosu

Offline saldırı senaryosu şu aşamalardan oluşur:

1. **Hash sızıntısı:** Veritabanından parola hash'leri ele geçirilir
2. **Hash analizi:** Hash algoritması ve parametreleri belirlenir
3. **Tahmin üretimi:** Aday parolalar üretilir
4. **Hash hesaplama:** Aday parolalar hash'lenir
5. **Karşılaştırma:** Üretilen hash, çalınan hash ile karşılaştırılır
6. **Eşleşme:** Eşleşme bulunduğunda parola çözülmüş olur

6.2.2 Hash Sızıntısı Varsayımı

Güvenlik analistleri, parola güvenliği değerlendirirken "hash sızıntısı varsayımı"nı temel alır. Bu varsayıma göre:

- Bir parola hash veritabanı **er ya da geç** ele geçirilecektir
- Bu nedenle, hash'lerin kalitesi ve kırılması zorluğu kritik öneme sahiptir
- Parola politikaları, hash sızıntısı senaryosuna göre tasarlanmalıdır

Bu varsayım, savunma tasarımının temel ilkesi olan "güvenlik varsayımı" (security by assumption) prensibine dayanır.

6.2.3 Maliyet Artırma Stratejileri

Offline saldırılara karşı en etkin savunma, **tahmin maliyetini** artırmaktır. Bu, hem hesaplama maliyetini hem de zaman maliyetini artırarak gerçekleştirilir.

Maliyet Artırma Yöntemleri:

Yöntem	Etki	Uygulama
Yavaş hash algoritması	Kaba kuvvet maliyetini artırır	Argon2, bcrypt, scrypt
Tuz (salt) kullanımı	Sözlük saldırılarını etkisiz kılar	Her parola için benzersiz tuz
Pepper (ek sır)	Ek koruma katmanı	Uygulama seviyesinde sır
Parola uzunluğu	Rastgele seçimde tahmin uzayını artırır	Tek faktörde en az 15 karakter
Parola karmaşıklığı	Arama uzayını genişletir	Büyük karakter seti

Tablo 6.2: Maliyet artırma yöntemleri

6.2.4 Hash Algoritması Karşılaştırması

Algoritma	Yapı	Ayarlanabilir maliyet	Savunma değerlendirme
MD5 / SHA-1	Hızlı genel hash	Yok	Parola saklamada kullanılmamalı
SHA-256	Hızlı genel hash	Tek başına yok	Parola saklamada tek başına kullanılmamalı
bcrypt	Uyarlanabilir, CPU ağırlıklı	Cost	Eski sistemlerde; 72 bayt sınırı test edilmeli
scrypt	Bellek-zorlayıcı	N, r, p	Argon2id yoksa değerlendirilebilir
Argon2id	Bellek-zorlayıcı	m, t, p	Genel amaçlı sistemlerde OWASP'ın birinci tercihi

Tablo 6.4: Hash algoritması karşılaştırması

Argon2 Parametreleri: - **Memory (m):** Her hesaplama için bellek maliyeti - **Iterations (t):** İşlem geçiş sayısı - **Parallelism (p):** Paralellik derecesi

OWASP taban değeri olan $m=19$ MiB, $t=2$, $p=1$ alt sınır olarak ele alınmalı; üretim değeri hedef sunucuda eşzamanlı yük ve hizmet reddi riski ölçülerek seçilmelidir. Sabit "hash/saniye" değerleri donanım ve uygulamaya göre hızla eskidiğinden güvenlik kararı için kullanılmamalıdır.

6.3 Kaba Kuvvet, Sözlük, Kalıp ve Hibrit Tahmin Kavramları

Parola tahmin yöntemleri, farklı stratejiler kullanarak olası parolaları üretir. Her bir yöntemin avantajları, sınırları ve uygulama alanları farklıdır.

6.3.1 Kaba Kuvvet (Brute Force) Tahmini

Kaba kuvvet, tanımlı aday uzayındaki tüm kombinasyonların sistematik denenmesidir. Sonlu uzay bütünüyle taranabilirse teorik olarak sonuç verir; pratik uygulanabilirlik aday uzayına, deneme hızına ve maliyete bağlıdır.

Kaba Kuvvet Hız Hesabı:

Bir sistem 10 milyar hash/sn hızında çalışıyor olsun: - 8 karakter (küçük harf + rakam, 36 karakter): $36^8 = 2,8 \times 10^{12}$ kombinasyon - Tüm uzayı tarama süresi: $2,8 \times 10^{12} / (10 \times 10^9) = \mathbf{280 \text{ saniye}}$ (~4,7 dakika) - 12 karakter (aynı set): $36^{12} = 4,7 \times 10^{18}$ kombinasyon - Tüm uzayı tarama süresi: $4,7 \times 10^{18} / (10 \times 10^9) = \mathbf{4,7 \times 10^8 \text{ saniye}}$ (~15 yıl) - 16 karakter: $36^{16} = 7,9 \times 10^{24}$ kombinasyon - Süre: ~25 milyon yıl

Bu model, eş olasılıklı rastgele adaylar ve sabit hız varsayar; ortalama bulma süresi yaklaşık yarısıdır. İnsan seçimi ve gerçek parola hash maliyeti bu varsayımları değiştirir.

6.3.2 Sözlük (Dictionary) Tahmini

Sözlük tahmininde, insanların en çok kullandığı parolaların derlendiği listeler kullanılır. Bu yöntem, kaba kuvvete göre çok daha etkilidir çünkü:

- İnsan parolaları rastgele değildir
- Belirli kalıplara ve eğilimlere sahiptir
- Popüler parolalar milyonlarca hesapta kullanılır

Savunma açısından aday kategorileri:

Kategori	Örnek içerik	Savunma kullanımı
Yaygın parolalar	Sık seçilen kısa değerler	Parola oluşturma sırasında engelleme
Ele geçirilmiş parolalar	Yetkili ve gizlilik-korumalı sorgu hizmetleri	Tam değer eşleşmesiyle risk kontrolü
Bağlama özgü terimler	Kurum, ürün ve kullanıcı adı türevleri	Kuruma özgü engelli parola listesi
Dil ve klavye kalıpları	Yaygın diziler ve basit dönüşümler	Politika testi ve farkındalık

Tablo 6.5: Sözlük tabanlı tahmine karşı savunma kategorileri. Gerçek sızıntı kümeleri laboratuvara kopyalanmamalıdır.

6.3.3 Kalıp (Pattern) Tahmini

Kalıp tahmininde, insanların parola oluştururken kullandığı bilinen kalıplar kullanılır. Bu kalıplar, davranışsal analiz ve istatistiksel modellerden elde edilmektedir.

Bilinen Parola Kalıpları:

Kalıp	Örnek	Yaygınlık
Kelime + rakam	"parola123"	Yüksek
Büyük harf + kelime + rakam	"Parola123"	Yüksek
Tarih tabanlı	"1990", "2024"	Yüksek
Klavye kalıpları	"qwerty", "123456"	Yüksek
Reverse kelime	"alapor"	Düşük
Kelime + özel karakter	"parola!"	Orta
Kelime + rakam + özel karakter	"Parola1!"	Yüksek
İki kelime birleşimi	"gunesli"	Orta

Tablo 6.6: Yaygın parola kalıpları

6.3.4 Hibrit Tahmin

Hibrit tahmin, sözlük ve kaba kuvvet yöntemlerinin birleşimidir. Sözlük kelimelerine çeşitli değişiklikler uygulanarak yeni aday parolalar üretilir.

Hibrit Değişiklik Tipleri: - **Büyük harf varyasyonları:** "parola" → "Parola", "PAROLA" - **Rakam ekleri:** "parola" → "parola1", "parola123" - **Özel karakter ekleri:** "parola" → "parola!", "parola@" - **Kelime birleştirme:** "güzellik" → "güzel+lik" - **Leet speak dönüşümü:** "parola" → "p4r0l4" - **Ters çevirme:** "parola" → "alorap"

Hibrit Tahmin Verimliliği:

Hibrit tahmin, sözlük boyutunun katlarıyla çalışır. 14 milyonluk bir sözlük ile 100 farklı dönüşüm uygulandığında 1,4 milyar aday parola üretilir. 10 milyar hash/sn hızında bu işlem yaklaşık 0,14 saniye sürer.

6.4 Entropi ve Parola Uzunluğu

Entropi, bir parolanın rastgeelliğini ve tahmin edilemezliğini ölçen matematiksel bir ölçümdür. Bit cinsinden ifade edilen entropi değeri, parolanın kaba kuvvet saldırısına karşı direncini doğrudan belirler.

6.4.1 Entropi Hesaplama Formülü

Basit bir parola için entropi şu formülle hesaplanır:

$$H = L \times \log_2(N)$$

Burada: - H = Entropi (bit) - L = Parola uzunluğu (karakter sayısı) - N = Karakter seti boyutu

Örnek Hesaplamalar:

Karakter Seti	Boyut (N)	$\log_2(N)$	8 Karakter Entropi	12 Karakter Entropi	16 Karakter Entropi
Küçük harf	26	4,7	37,6 bit	56,4 bit	75,2 bit

Karakter Seti		Boyut (N)	$\log_2(N)$	8 Karakter Entropi	12 Karakter Entropi	16 Karakter Entropi
Harf + rakam	+	62	5,95	47,6 bit	71,4 bit	95,2 bit
ASCII yazılabilir		95	6,57	52,6 bit	78,8 bit	105,1 bit
Tam Unicode		143.000+	~17,1	136,8 bit	205,2 bit	273,6 bit

Tablo 6.7: Entropi hesaplamaları

6.4.2 Entropi ve Güvenlik İlişkisi

Genel kabul göre göre, parola güvenliği için minimum entropi değerleri:

Güvenlik Seviyesi	Minimum Entropi	Kullanım Alanı
Düşük	40 bit	Geçici hesaplar, test sistemleri
Orta	56 bit	Standart kullanıcı hesapları
Yüksek	64 bit	Hassas hesaplar, finansal sistemler
Çok Yüksek	80+ bit	Kritik altyapı, yönetici hesapları

Tablo 6.8: Güvenlik seviyesi ve entropi gereksinimleri

6.4.3 Entropi Kayıpları

Bazı durumlar entropi kaybına yol açar:

- **Tahmin edilebilir kalıplar:** Yıl eklenmesi ("parola2024"), kelime + rakam kalıpları
- **Düşük entropili karakter seti:** Yalnızca küçük harf kullanımı
- **Kısa uzunluk:** 8 karakterden kısa parolalar
- **Önceki parolalara benzerlik:** Benzer parola seçimi
- **Kişisel bilgi kullanımı:** Doğum tarihi, isim, telefon numarası

Entropi Kaybı Tablosu:

Entropi Kaybı Faktörü	Kayıp Miktarı	Örnek
Büyük harf = ilk harf	-0,5 bit/karakter	"Parola"
Rakam = son rakam	-1 bit/karakter	"Parola1"
Özel karakter = son karakter	-1,5 bit/karakter	"Parola!"
Yıl ekleme	-10 bit	"Parola2024"
Tahmin edilebilir kelime	-20 bit	"şifre"

Tablo 6.9: Entropi kaybı faktörleri

6.5 Hash Hesaplama Maliyeti ve Savunma Tasarımı

Hash hesaplama maliyeti, offline saldırılara karşı savunmanın temel direğidir. Yavaş hash algoritmaları, saldırganın her parola denemesi için daha fazla hesaplama yapmasını zorunlu kılarak saldırının maliyetini ve süresini artırır.

6.5.1 Hash Hızı ve Saldırı Hızı İlişkisi

Bir sistemin parola doğrulama hızı ile saldırganın tahmin hızı arasındaki ilişki kritiktir:

Senaryo: 10 milyon kullanıcı, 8 karakter parola

Hash Algoritması	Doğrulama Hızı (1 CPU)	Saldırı Hızı (1000 GPU)	Kaba Kuvvet Süresi
MD5	~300.000/sn	~3,3 × 10 ¹² /sn	~1 saniye
SHA-256	~150.000/sn	~1,7 × 10 ¹² /sn	~2 saniye
bcrypt (cost 10)	~30/sn	~17.000/sn	~50 yıl
Argon2id (64MB)	~10/sn	~500/sn	~180 yıl

Tablo 6.10: Hash hızı ve saldırı süresi

Bu tablo, yavaş hash algoritmalarının offline saldırılara karşı ne kadar etkili bir savunma sağladığını göstermektedir.

6.5.2 Savunma Tasarımı İlkeleri

Parola depolama güvenliği için tasarım ilkeleri:

1. **Yavaş hash algoritması kullan:** Argon2id, bcrypt veya scrypt tercih et
2. **Yüksek maliyet parametreleri:** Donanım yeteneklerine göre parametreleri ayarla
3. **Benzersiz tuz (salt):** Her parola için rastgele tuz üret
4. **Pepper (ek sır):** Uygulama seviyesinde ek koruma
5. **Paralelizasyon direnci:** GPU/ASIC saldırılarına karşı bellek-bağımlı algoritmalar
6. **Periyodik parametre güncellemesi:** Donanım gelişmeleriyle parametreleri artır

6.5.3 Maliyet Hesaplama Modeli

Saldırı maliyeti şu faktörlere bağlıdır:

Toplam Maliyet = (Parola Sayısı × Tahmin Sayısı × Hash Maliyeti) + Donanım Maliyeti

Örnek Hesaplama: - 10 milyon hash sızıntısı - Ortalama 50 milyon tahmin gerekiyor (sözlük + varyasyonlar) - Argon2id (64MB): ~0,002\$/hash (bulut maliyeti) - Toplam maliyet: $10M \times 50M \times \$0,002 = \1 trilyon

Bu sentetik hesaplama, uygun bir parola hash şeması ve maliyet parametresinin çevrim dışı tahmin maliyetini önemli ölçüde artırabileceğini gösterir; sonuç gerçek donanım ve parola dağılımına göre değişir.

6.6 Sentetik Matematiksel Örnekler

Bu bölümde, parola güvenliği ile ilgili matematiksel kavramları somutlaştırmak amacıyla sentetik (kurgusal) örnekler sunulmaktadır.

6.6.1 Entropi Hesaplama Örneği

Senaryo: Bir kullanıcı, küçük harfler ve rakamlardan oluşan 10 karakterlik bir parola seçiyor.

Hesaplama: - Karakter seti boyutu (N): 26 (küçük harf) + 10 (rakam) = 36 - Parola uzunluğu (L): 10 - Entropi (H): $10 \times \log_2(36) = 10 \times 5,17 = 51,7 \text{ bit}$

Yorum: 51,7 bit entropi, "orta" güvenlik seviyesine karşılık gelir. Kaba kuvvet saldırısı 10 milyar hash/sn hızında yaklaşık $3,7 \times 10^6$ saniye (43 gün) sürer.

6.6.2 Hash Maliyeti Örneği

Senaryo: Bir kuruluş, 5 milyon kullanıcının parola hash'lerini Argon2id ile depoluyor.

Parametreler: - Memory: 64 MB - Iterations: 3 - Parallelism: 4 - Hash başına süre: ~2 milisaniye

Hesaplama: - Toplam hash süresi: $5M \times 2ms = 10.000 \text{ saniye} \approx 2,8 \text{ saat}$ - Gerekli bellek: $5M \times 64MB = 320 \text{ TB}$ (eşzamanlı hash için) - Gerçekçi uygulama: Parti part hash hesaplama, 8 saat

Yorum: 5 milyon kullanıcının parolalarını Argon2id ile hashlemek, tek bir sunucuda yaklaşık 8 saat sürmektedir. Bu, kabul edilebilir bir maliyettir.

6.6.3 Sözlük Saldırısı Verimliliği Örneği

Senaryo: 14 milyonluk bir sözlük ile 1000 farklı dönüşüm uygulanıyor.

Hesaplama: - Toplam aday parola: $14M \times 1000 = 14 \text{ milyar}$ - Hash hızı (bcrypt): 17.000/sn - Gerekli süre: $14 \times 10^9 / 17.000 \approx 823.000 \text{ saniye} \approx 9,5 \text{ gün}$

Yorum: 14 milyar adayı bcrypt ile test etmek yaklaşık 10 gün sürmektedir. Argon2id ile bu süre~fold artar.

6.6.4 Rate Limiting Etkisi Örneği

Senaryo: Bir sistemde 5 deneme/dakika limiti var.

Hesaplama: - 8 karakter parola (36 karakter seti): $36^8 = 2,8 \times 10^{12}$ kombinasyon - Dakikadaki deneme: 5 - Saatteki deneme: 300 - Günde deneme: 7.200 - Toplam süre: $2,8 \times 10^{12} / 7.200 \approx 3,9 \times 10^8 \text{ gün} \approx 1,1 \text{ milyon yıl}$

Yorum: Rate limiting, kaba kuvvet saldırısını tamamen etkisiz hale getirir. Ancak offline saldırılarda rate limiting geçerli değildir.

6.7 Savunma Kontrolleri: MFA ve Risk Tabanlı Doğrulama

Parola güvenliğini tamamlayan en önemli savunma kontrolleri, çoklu faktör kimlik doğrulama (MFA) ve risk tabanlı doğrulamadır.

6.7.1 Çoklu Faktör Kimlik Doğrulama (MFA)

MFA, parola tek başına yeterli olmadığında ikinci veya daha fazla doğrulama faktörü gerektiren bir güvenlik mekanizmasıdır.

Doğrulama Faktörleri:

Faktör Türü	Örnekler	Güçlü Yön	Zayıf Yön
Bilgi (Something you know)	Parola, PIN	Kolay uygulama	Phishing riski
Sahiplik (Something you have)	Telefon, token, kart	Yüksek güvenlik	Kayıp/çalınma
Biyometrik (Something you are)	Parmak izi, yüz tanıma	Yüksek güvenlik	False positive
Davranış (Something you do)	Yazma hızı, mouse hareketi	Sürekli doğrulama	Yanlış pozitif

Tablo 6.11: Doğrulama faktörleri

MFA Yöntemleri:

1. **SMS Tabanlı OTP:** Telefona gelen tek kullanımlık şifre (SIM swap riski)
2. **Uygulama Tabanlı OTP:** Google Authenticator, Authy gibi uygulamalar
3. **FIDO2/WebAuthn:** Donanım anahtarları (YubiKey) veya cihaz biyometriği
4. **Push Bildirimi:** Onay bildirimi gönderme (kolay phishing riski)
5. **E-posta Tabanlı OTP:** E-postaya gelen tek kullanımlık şifre

6.7.2 Risk Tabanlı Doğrulama

Risk tabanlı doğrulama (adaptive authentication), kullanıcının risk seviyesine göre farklı doğrulama düzeyleri gerektiren bir yaklaşımdır. Bu yaklaşım, kullanıcı deneyimini korurken güvenliği artırır.

Risk Faktörleri ve Müdahaleler:

Risk Faktörü	Düşük Risk	Orta Risk	Yüksek Risk
Tanıdık cihaz	Otomatik giriş	Tek faktör	MFA
Tanıdık konum	Otomatik giriş	Bildirim	MFA
Normal saat	Otomatik giriş	Tek faktör	MFA
Anormaldavranış	Bildirim	MFA	MFA + inceleme
Yeni cihaz	MFA	MFA + bildirim	MFA + inceleme
Farklı ülke	MFA + bildirim	MFA + inceleme	Hesap kilitleme

Tablo 6.12: Risk tabanlı doğrulama matrisi

6.7.3 MFA'nın Etkinliği

MFA, çalınmış parolanın tek başına kullanılmasını engelleyerek hesap ele geçirme riskini önemli ölçüde azaltabilir; ancak yöntemler eşdeğer değildir. Gerçek zamanlı kimlik avı, oturum çerezi hırsızlığı, MFA yorgunluğu ve kurtarma suistimali bazı MFA türlerini aşabilir. Bu nedenle yüksek riskli hesaplarda WebAuthn/FIDO2 tabanlı, kimlik avına dayanıklı doğrulama tercih edilmelidir.

MFA Türlerinin Karşılaştırması:

MFA Türü	Phishing Direnci	Kullanıcı Deneyimi	Maliyet	Önerilen Kullanım
SMS OTP	Düşük	Yüksek	Düşük	Hassas olmayan sistemler
Uygulama OTP	Orta	Yüksek	Düşük	Genel kullanım
FIDO2/ WebAuthn	Yüksek	Yüksek	Orta	Hassas sistemler
Push bildirim	Düşük-Orta	Çok Yüksek	Orta	Genel kullanım
Donanım token	Çok Yüksek	Orta	Yüksek	Kritik altyapı

Tablo 6.13: MFA türü karşılaştırması

6.8 Tahmin Uzağı/Entropi Modeli ve Online-Offline Tablosu

Bu bölümde, parola güvenliğinin matematiksel temellerini ve online/offline saldırı karşılaştırmasını ele almaktayız.

6.8.1 Tahmin Uzağı Modeli

Tahmin uzağı (guessing space), bir parolanın kaba kuvvet saldırısına karşı ne kadar dayanaklı olduğunu belirleyen toplam olası kombinasyon sayısıdır.

Tahmin Uzağı Formülü: $S = N^L$

Burada: - S = Tahmin uzağı (toplam kombinasyon) - N = Karakter seti boyutu - L = Parola uzunluğu

Tahmin Uzağı Tablosu:

Karakter Seti	8 Karakter	10 Karakter	12 Karakter	16 Karakter
26 (küçük harf)	2×10^{11}	$1,4 \times 10^{14}$	$9,5 \times 10^{16}$	$4,4 \times 10^{22}$
62 (harf+rakam)	$2,2 \times 10^{14}$	$8,4 \times 10^{17}$	$3,2 \times 10^{21}$	$4,7 \times 10^{28}$
95 (yazılabilir)	$6,6 \times 10^{15}$	6×10^{19}	$5,4 \times 10^{23}$	$1,8 \times 10^{31}$

Tablo 6.14: Tahmin uzağı karşılaştırması

6.8.2 Online-Offline Karşılaştırma Tablosu

Özellik	Online Saldırı	Offline Saldırı
Erişim yöntemi	Oturum açma arayüzü	Çalınan hash veritabanı
Hız	Saniyede birkaç deneme	Milyarlarca deneme/saniye
İz bırakma	Her deneme kaydedilir	Hiç iz bırakmaz
Tespit edilebilirlik	Yüksek	Düşük
Savunma kontrolleri	Rate limiting, lockout, CAPTCHA	Yavaş hash, tuz, pepper
Etkinlik	Sınırlı hız nedeniyle düşük	Yüksek hız nedeniyle yüksek

Özellik	Online Saldırı	Offline Saldırı
Risk seviyesi	Orta	Yüksek
Maliyet	Zaman bazlı	Donanım bazlı

Tablo 6.15: Online ve offline saldırı karşılaştırması

6.8.3 Kırılma Süresi Hesaplama Modeli

Bir parolanın kırılma süresini hesaplamak için kullanılan genel formül:

$$T = S / (H \times E)$$

Burada: - T = Tahmini kırılma süresi (saniye) - S = Tahmin uzayı - H = Hash hızı (deneme/saniye) - E = Verimlilik oranı (0-1 arası)

Örnek Hesaplama: - Parola: 12 karakter, harf+rakam ($62^{12} = 3,2 \times 10^{21}$) - Hash: Argon2id (500 deneme/saniye) - Verimlilik: %30 (0,3) - $T = 3,2 \times 10^{21} / (500 \times 0,3) = 2,1 \times 10^{19}$ saniye $\approx$ **680 milyon yıl**

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenci:

1. Online ve offline parola tahmin saldırılarının temel farklarını analiz edebilir
2. Entropi hesaplamaları yaparak parola güvenliğini değerlendirebilir
3. Hash algoritması seçimini savunma stratejisine göre yapabilir
4. Tahmin uzayı modelini kullanarak kırılma süresi tahminleri yapabilir
5. MFA ve risk tabanlı doğrulama arasındaki farkları açıklayabilir
6. Kaba kuvvet, sözlük ve hibrit tahmin yöntemlerini karşılaştırabilir
7. Savunma kontrollerini tasarım ilkelerine göre uygulayabilir

Risk Modeli

Parola kırma saldırılarına karşı risk değerlendirmesi:

Senaryo	Olasılık	Etki	Risk Seviyesi	Kırılma Süresi (Örnek)
Zayıf parola + online saldırı	Yüksek	Yüksek	Yüksek	Dakika-Saat
Zayıf parola + offline saldırı	Orta	Çok Yüksek	Çok Yüksek	Saniye-Dakika
Güçlü parola + offline saldırı	Düşük	Yüksek	Orta	Yıllar-Asırlar
MFA ile korunan hesap	Düşük	Düşük	Düşük	Etkisiz

Tablo 6.16: Parola kırma risk değerlendirmesi

Savunma Kontrolleri Özeti

1. **Parola Politikası:** Uzunluk, karmaşıklık, yasaklı listeler
2. **Hash Güvenliği:** Yavaş algoritma, tuz, pepper
3. **Rate Limiting:** Online saldırı hızını sınırlama
4. **MFA:** İkinci doğrulama faktörü
5. **Risk Tabanlı Doğrulama:** Adaptif güvenlik
6. **Parola Yöneticisi:** Benzersiz ve uzun parolalar
7. **Sızıntı İzleme:** Bilinen sızıntıların kontrolü
8. **Eğitim:** Kullanıcı farkındalığı

Güvenli Anlatım Notu

Önemli Not: Bu bölümde parola kırma süreçleri yalnızca savunma amaçlı ve kavramsal olarak ele alınmıştır. Hiçbir saldırı aracı, komut veya uygulama detayı verilmemiştir. Tüm matematiksel örnekler sentetiktir ve gerçek dünya verilerinden türetilmiştir.

Parola güvenliği, sürekli değişen bir tehdit ortamında sürekli güncel kalmayı gerektirir. Savunma stratejileri, güncel tehdit istihbaratına ve teknolojik gelişmelere göre sürekli iyileştirilmelidir.

Kuruluşlar, parola güvenliğini sağlamak için teknik kontrollerin yanı sıra kullanıcı eğitimi ve farkındalık programlarını da uygulamalıdır. Teknik kontroller tek başına yeterli değildir; insan faktörü her zaman risk zincirinin en zayıf halkasıdır.

Kaynaklar

- OWASP - Authentication Cheat Sheet (2024)
- NIST SP 800-63B-4: Digital Identity Guidelines — Authentication and Authenticator Management (2025)
- NIST SP 800-132: Recommendation for Key Derivation Using Password-Based Key Derivation Functions (2023)
- RFC 9106 — Argon2 Memory-Hard Function for Password Hashing. <https://doi.org/10.17487/RFC9106>
- Verizon Data Breach Investigations Report (DBIR) (2024)
- Microsoft Security Intelligence Report (2023)
- Bonneau, J. (2012). "The Science of Guessing: Analyzing an Anonymized Corpus of 70 Million Passwords." IEEE Symposium on Security and Privacy.

Bu bölümler, Parola ve Kimlik Doğrulama Güvenliği kitabının 4, 5 ve 6. bölümlerini oluşturmaktadır. Her bölüm, akademik standartlara uygun olarak hazırlanmış olup, güncellenmiş kaynaklar ve pratik uygulama örnekleri içermektedir.

BÖLÜM 7 – ÇOK FAKTÖRLÜ KİMLİK DOĞRULAMA (MFA)

[↩ İçindekilere dön](#)

Amaç

Bu bölümün amacı, çok faktörlü kimlik doğrulama (Multi-Factor Authentication, MFA) kavramını, teknolojilerini, uygulama yöntemlerini ve kurumsal düzeydeki stratejik önemini kapsamlı biçimde ele almaktır. MFA, parola tabanlı kimlik doğrulamanın tek başına yetersiz kaldığı günümüz tehdit ortamında, kimlik doğrulama güvenliğinin temel taşlarından biri olarak öne çıkmaktadır. Bu bölüm, farklı MFA yöntemlerinin karşılaştırmalı analizini, phishing-savunma mekanizmalarını, kurumsal uygulama planlamasını ve kullanıcı deneyimine etkilerini inceler.

Araştırma Soruları

1. MFA'nın farklı faktör türleri nelerdir ve her biri nasıl çalışır?
2. Hangi MFA yöntemleri phishing saldırılarına karşı dayanıklıdır?
3. Kurumsal ortamlarda MFA uygulaması nasıl planlanır?
4. MFA yorgunluğu ve onay körlüğü nedir ve nasıl önlenir?
5. FIDO/WebAuthn tabanlı MFA neden daha güvenlidir?

7.1 MFA Kavramı ve Faktör Türleri

7.1.1 MFA Tanımı

Çok faktörlü kimlik doğrulama (MFA), bir kullanıcının kimliğini doğrulamak için iki veya daha fazla bağımsız kanıt (faktör) sunmasını gerektiren bir güvenlik mekanizmasıdır. Tek faktörlü kimlik doğrulama (genellikle yalnızca parola)

günümüz tehditlerine karşı yetersiz kalmaktadır. MFA'nın temel mantığı, bir faktörün ele geçirilmesi durumunda bile saldırganın sisteme erişemeyeceği güvenliğini sağlamaktır.

NIST Special Publication 800-63B (2020), kimlik doğrulama faktörlerini üç ana kategoride sınıflandırmaktadır:

- **Bilinen şey (Something you know):** Parola, PIN, güvenlik sorusu
- **Sahip olunan şey (Something you have):** Fiziksel anahtar, akıllı telefon, donanım tokenı
- **Bir şey (Something you are):** Parmak izi, yüz tanıma, iris tarama, ses izi

MFA, bu kategorilerden en az ikisini birleştirmeyi gerektirir. Örneğin, bir kullanıcının hem parolasını (bilinen) hem de telefonundaki doğrulayıcı uygulamasından ürettiği tek seferlik kodu (sahip olunan) girmesi MFA'nın klasik bir örneğidir.

7.1.2 Faktör Türlerinin Derinlemesine İncelenmesi

Birinci Faktör: Bilinen Şey (Knowledge Factor)

Bu faktör, kullanıcının bildiği bir bilgiye dayanır. En yaygın formu paroladır, ancak PIN kodları, güvenlik soruları ve desen kilidi de bu kategoride yer alır. Bilinen faktörlerin zayıflığı, ele geçirilmelerinin nispeten kolay olmasıdır — phishing, brute force, credential stuffing ve shoulder surfing gibi saldırılarla parolalar çalınabilir.

Bilinen faktörün güvenilirliğini artırmak için alınabilecek önlemler arasında karmaşık parola gereklilikleri, parola yaşlandırma politikaları ve parola listesi kontrolü yer alır. Ancak bu önlemler tek başına MFA ihtiyacını ortadan kaldırmaz.

İkinci Faktör: Sahip Olunan Şey (Possession Factor)

Bu faktör, kullanıcının fiziksel olarak bulunduğu bir nesneye dayanır. Akıllı telefonlar, donanım anahtarları (YubiKey, Titan Security Key), akıllı kartlar ve fiziksel tokenlar bu kategoride yer alır. Sahip olunan faktörün güvenilirliği, nesnenin fiziksel olarak ele geçirilmesi veya klonlanması gerekliliğinden kaynaklanır.

Ancak sahip olunan faktörler de zafiyetlere sahiptir. SIM swapping saldırıları SMS tabanlı MFA'yı etkisiz hale getirebilir. Telefondaki doğrulayıcı uygulamaları, cihazın ele geçirilmesi durumunda risk altına girebilir. Bu nedenle, sahip olunan faktörün türü ve uygulama biçimi büyük önem taşır.

Üçüncü Faktör: Bir Şey (Inherence Factor)

Biyometrik verilere dayanan bu faktör, kullanıcının fiziksel veya davranışsal özelliklerini kullanır. Parmak izi, yüz tanıma, iris tarama, ses tanıma ve damar izi (vein pattern) en yaygın biyometrik yöntemlerdir. Biyometrik faktörler, kullanıcının taşınması veya hatırlaması gereken bir bileşen gerektirmediğinden kullanıcı deneyimini iyileştirir.

Biyometrik verilerin benzersizliği ve kopyalanmasının zorluğu avantaj sağlamasına rağmen, biyometrik verilerin sızması durumunda değiştirilemezliği (parolaların aksine parmak izi değiştirilemez) ciddi bir risk oluşturur. Bu nedenle biyometrik verilerin cihaz düzeyinde (on-device) işlenmesi ve merkezi sunucularda saklanmaması kritik bir güvenlik ilkesidir.

7.1.3 Dördüncü Faktör: Davranışsal Biyometri ve Bağlamsal Doğrulama

Gelişmiş MFA sistemlerinde dördüncü ve beşinci faktörler de kullanılmaya başlanmıştır:

- **Davranışsal biyometri:** Tuş vuruşu hızı, fare hareket paterni, dokunma davranışları
- **Bağlamsal doğrulama:** Coğrafi konum, IP adresi, cihaz parmak izi, erişim zamanı

Bu faktörler, kullanıcının normal davranış kalıplarından sapma olup olmadığını değerlendirerek risk tabanlı kimlik doğrulama (Risk-Based Authentication, RBA) oluşturur.

7.2 SMS, E-posta, TOTP, Push, Donanım Anahtarı Karşılaştırması

7.2.1 SMS Tabanlı MFA

SMS tabanlı MFA, kullanıcının telefon numarasına gönderilen tek seferlik kodu (One-Time Password, OTP) kullanır. En yaygın ve en kolay uygulanan MFA yöntemlerinden biridir.

Avantajları: - Ek donanım veya yazılım gerektirmez - Evrensel telefon desteği - Kullanıcı eğitimi gerektirmez - Düşük uygulama maliyeti

Dezavantajları: - SIM swapping saldırılarına karşı savunmasız - SS7 protokol zafiyetleri nedeniyle intercept edilebilir - GSM şebekesi bağlantısı gerektirir (kapsama alanı sorunu) - SMS'ler uçtan uca şifrelenmez - A3/A8 authentikey algoritması bilinen kriptozafiyetleri içerir

NIST, 2017 yılında güncellediği 800-63B belgesinde SMS tabanlı MFA'yı "restricted" (kısıtlanmış) kategoriye almıştır. Bu karar, SS7 saldırılarının ve SIM swap vakalarının artmasıyla doğrudan ilişkilidir.

Gerçek dünya vakası: 2022 yılında ABD'de telekomünikasyon şirketlerinden birinde meydana gelen SIM swap vakası, SMS MFA'nın ne kadar kolay atlatılabileceğini göstermiştir. Saldırgan, müşteri hizmetlerini arayarak hedef kişinin numarasını kendi SIM'ine aktarmış ve SMS kodlarını yakalamıştır.

7.2.2 E-posta Tabanlı MFA

E-posta tabanlı MFA, kullanıcının kayıtlı e-posta adresine gönderilen tek seferlik kod veya onay bağlantısı kullanır.

Avantajları: - Ek donanım gerektirmez - E-posta hesabı zaten mevcut olduğundan ek kurulum gerektirmez - Kodlar zaman sınırına sahip olabilir

Dezavantajları: - E-posta hesabının ele geçirilmesi durumunda etkisiz kalır - E-posta sunucuları man-in-the-middle saldırılarına açık olabilir - E-posta protokolleri (SMTP) varsayılan olarak şifrelenmemiş olabilir - Parola ile aynı faktör kategorisine (bilinen şey) girebilir

E-posta tabanlı MFA'nın güvenilirliği, e-posta hesabının kendi güvenliğiyle doğrudan ilişkilidir. Eğer saldırgan e-posta hesabını ele geçirmişse, MFA kodu doğrudan saldırgana ulaşır. Bu nedenle e-posta tabanlı MFA, MFA olarak değil, ek bir doğrulama adımı olarak değerlendirilmelidir.

7.2.3 TOTP (Time-Based One-Time Password)

TOTP, RFC 6237 tarafından tanımlanan zamana dayalı tek seferlik şifre üretim mekanizmasıdır. Google Authenticator, Microsoft Authenticator ve Authy gibi uygulamalar bu protokolü kullanır.

Çalışma Prensipleri: TOTP, HMAC-SHA1 (veya SHA-256/SHA-512) kriptografik hash fonksiyonunu ve sistem saatini kullanarak 30 saniyelik aralıklarla 6-8 haneli kod üretir. Hem sunucu hem de istemci, paylaşılan bir gizli anahtar (shared secret) ve mevcut zaman damgasını aynı formülde işleyerek aynı kodu üretir.

Formül:
$$\text{TOTP} = \text{Trunc}(\text{HMAC-SHA1}(\text{shared_secret}, \text{floor}(\text{time} / \text{time_step})))$$

Avantajları: - İnternet bağlantısı gerektirmez - SIM swapping saldırılarına karşı dayanıklıdır - Açık kaynak ve iyi denetlenmiş standart - Çeşitli uygulama ve platform desteği

Dezavantajları: - Cihazın ele geçirilmesi durumunda risk altına girer - Cihaz kaybında kurtarma süreci zor olabilir - Sunucu-saat senkronizasyonu sorunları yaşanabilir - Seed (başlangıç anahtarı) transferi güvenli olmalıdır - Hesap kurtarma için yedek kodlar gereklidir

7.2.4 Push Tabanlı MFA

Push tabanlı MFA, kullanıcının mobil cihazına bir onay isteği gönderir ve kullanıcı uygulamada "Onayla" veya "Reddet" butonuna basarak kimlik doğrulamayı tamamlar.

Çalışma Prensipleri: Kimlik doğrulama sunucusu, kullanıcının kayıtlı cihazına bir push bildirimi gönderir. Kullanıcı bildirimi görüntüler ve uygulamadaki "Onayla" butonuna basar. Uygulama, cihazdaki kriptografik anahtar ile imzalanmış bir yanıt gönderir.

Avantajları: - Kullanıcı deneyimi iyidir (tek tıklama) - Phishing'e karşı kısmi dayanıklılık (doğrulama isteği bağlamla birlikte gelir) - Konum ve cihaz bilgisiyle ek bağlam sağlanabilir - Zaman sınırı ve coğrafi kısıtlamalar eklenebilir

Dezavantajları: - Push fatigue saldırıları (saldırgan sürekli onay isteği göndererek kullanıcıyı yorar) - Cihaz bağlantısı ve bildirim servisi gereklidir - Kullanıcı dikkatsizliğinde onay körlüğü riski - Uygulama düzeyindeki zafiyetler (root-ed cihazlar)

Gerçek dünya vakası: 2022 yılında Uber'e yapılan saldırı, saldırganın MFA yorgunluğu (push fatigue) tekniğini kullanarak bir çalışanı repeatedly push bildirimleriyle yorduğunu ve sonunda çalışanın onayladığını göstermiştir. Bu vakada saldırgan, çalışanın VPN parolasını credential stuffing ile ele geçirmiş, ardından çalışanın telefonuna sürekli push istekleri göndermiştir. Yeterince sık tekrarlanan istekler karşısında çalışan sonunda onaylamıştır.

7.2.5 Donanım Anahtarı (FIDO U2F/WebAuthn)

Donanım anahtarları, fiziksel bir cihaz üzerinde kriptografik anahtar çifti barındıran ve FIDO (Fast Identity Online) protokolünü kullanan kimlik doğrulama cihazlarıdır. YubiKey, Google Titan Security Key ve Feitian anahtarları en yaygın örneklerdir.

Çalışma Prensipleri: Donanım anahtarı, kayıtlı olduğu web sitesiyle eşleşen bir kriptografik anahtar çifti oluşturur. Özel anahtar (private key) asla donanım anahtarından ayrılmaz. Kimlik doğrulama sırasında sunucu bir challenge (meç) gönderir, anahtar özel anahtarla imzalar ve imzayı sunucuya iletir. Sunucu, genel anahtarla (public key) imzayı doğrular.

Avantajları: - Phishing'e karşı tamamen dayanıklıdır (origin doğrulaması protokol düzeyinde yapılır) - Özel anahtar cihazdan çıkmaz - Donanım düzeyinde güvenlik katmanı - Yakın alan iletişimi (NFC) veya USB ile çalışır - Aynı anda birden fazla siteye kaydedilebilir

Dezavantajları: - Ek donanım maliyeti - Cihaz kaybında kurtarma zorluğu - Fiziksel olarak mevcut olma gerekliliği - Bazı cihazlar biyometrik doğrulama gerektirmez (ikinci faktör eksik kalabilir) - Şirket içi IT altyapısı gerektirebilir

7.2.6 Karşılaştırma Matrisi

Kriter	SMS	E-posta	TOTP	Push	Donanım Anahtarı
Phishing Direnci	Düşük	Düşük	Düşük	Orta	Yüksek

Kriter	SMS	E-posta	TOTP	Push	Donanım Anahtarı
SIM Swap Direnci	Yok	N/A	Yüksek	Yüksek	Yüksek
İnternet Gereksinimi	Evet	Evet	Hayır	Evet	Hayır
Kullanıcı Kolaylığı	Yüksek	Yüksek	Orta	Yüksek	Orta
Uygulama Maliyeti	Düşük	Düşük	Düşük	Orta	Yüksek
NIST Değerlendirmesi	Kısıtlanmış	Kısıtlanmış	Kabul	Kabul	Onaylanmış
Man-in-the-Middle Direnci	Düşük	Düşük	Düşük	Orta	Yüksek
Cihaz Bağımlılığı	Telefon	E-posta hesabı	Telefon	Telefon	Fiziksel anahtar

7.3 Phishing-Resistant MFA ve FIDO/WebAuthn

7.3.1 Phishing Saldırıları ve MFA'yı Etkisizleştirme

Phishing saldırıları, kullanıcının kimlik doğrulama bilgilerini taklit eden web siteleri veya iletişimler aracılığıyla çalan saldırı türleridir. Geleneksel MFA yöntemleri (SMS, TOTP, push) phishing'e karşı tam koruma sağlamaz çünkü:

1. **Gerçek zamanlı kimlik avı vekilleri:** Saldırgan, kullanıcının bilgilerini meşru hizmete iletirken aynı anda yakalayabilir
2. **Adversary-in-the-Middle (AitM) saldırıları:** Saldırgan, kullanıcı ile sunucu arasındaki iletişimi dinleyerek MFA kodlarını yakalar
3. **Phishing sayfaları:** Kullanıcı, taklit edilen sitede MFA kodunu da girerek saldırıya iletir

Geleneksel MFA'nın kimlik avına karşı sınırlı kalmasının temel nedeni, paylaşılabılır kodun hangi hizmete sunulduğunu kriptografik olarak bağlamamasıdır. Kullanıcı parolasını ve kodu taklit siteye girdiğinde değerler gerçek zamanlı aktarılabilir.

7.3.2 FIDO2 ve WebAuthn ile Phishing Koruması

FIDO2, FIDO Alliance tarafından geliştirilen bir kimlik doğrulama standartları setidir. İki ana bileşenden oluşur:

1. **WebAuthn (Web Authentication API):** Tarayıcı ve sunucu arasındaki kimlik doğrulama iletişimini standartlaştıran W3C standardı
2. **CTAP (Client to Authenticator Protocol):** Tarayıcı ile harici kimlik doğrulama cihazı arasındaki iletişimi yöneten protokol

Phishing'e karşı korumanın temeli:

FIDO2/WebAuthn'de kimlik doğrulama, tarayıcının meşru alan adını (origin) otomatik olarak doğrulamasıyla gerçekleşir. Kullanıcı, phishing sitesine gitse bile:

1. Tarayıcı, WebAuthn API çağrısında mevcut alan adını (origin) kaydeder
2. FIDO protokolü, origin bilgisini challenge ile birlikte imzalanmak üzere cihaza iletir
3. İstemci, güvenen taraf kimliğini (RP ID) ve origin ilişkisini doğrular; kimlik bilgisi RP kapsamına bağlıdır
4. Farklı bir origin/RP bağlamında meşru hizmet için geçerli doğrulama üretilemez

Bu mekanizma, kimlik doğrulama sürecinin kontrolünü kullanıcıdan alarak tarayıcıya ve donanıma devreder. Böylece kullanıcı hangi siteye giderse gitsin, FIDO2 protokolü doğru siteyle iletişim kurulmasını sağlar.

7.3.3 FIDO Alliance ve Endüstri Standartları

FIDO Alliance, 2013 yılında kurulan ve parolasız kimlik doğrulama çözümleri geliştiren bir endüstri birliğidir. Üyeleri arasında Google, Microsoft, Apple, Yubico, Intel, Qualcomm ve birçok büyük teknoloji şirketi yer almaktadır.

FIDO Alliance'ın geliştirdiği temel standartlar:

- **U2F (Universal 2nd Factor):** İlk nesil FIDO standardı, ikinci faktör olarak donanım anahtarı kullanımını tanımlar
- **FIDO2:** Gelişmiş standart, parolasız kimlik doğrulamayı ve çok faktörlü kimlik doğrulamayı kapsar
- **FIDO Biometrics Requirements:** Biyometrik kimlik doğrulama için gereksinimler

- **FIDO Device Onboard (FDO):** IoT cihazlar için kimlik doğrulama standardı

Microsoft, Google ve Apple, 2022 yılında passkey'ler için çapraz platform desteği taahhüdünde bulunarak FIDO2'nin tüketici düzeyindeki benimsenmesini hızlandırmıştır.

7.3.4 Phishing-Resistant MFA'nın Kurumsal Değerlendirmesi

Phishing-resistant MFA'nın kurumsal değerlendirmesinde dikkate alınması gereken faktörler:

Değerlendirme Kriteri	Phishing-Resistant (FIDO2)	Geleneksel MFA (TOTP/ Push)
Phishing Savunması	Protokol düzeyinde	Kullanıcıya bağımlı
AitM Saldırıları	Etkisiz	Etkili olabilir
Maliyet (başlangıç)	Yüksek (donanım)	Düşük (yazılım)
Kullanıcı eğrisi	Orta	Düşük
Cihaz yönetimi	Gerekli	Minimum
Uzaktan çalışma desteği	Evet (platform passkey)	Evet
Denetim kanıtı	Kayıt ve doğrulayıcı envanteri gerekir	Yönteme göre değişir

ABD federal sıfır güven politikaları ve CISA rehberleri, yüksek değerli kullanım senaryolarında kimlik avına dayanıklı MFA'yı önceliklendirmektedir. Kurumlar aynı yaklaşımı kendi tehdit modeli, istemci uyumluluğu ve kurtarma kapasitesine göre kademeli uygulamalıdır.

7.4 Yönetici Hesaplarında MFA Zorunluluğu

7.4.1 Yönetici Hesaplarının Risk Profili

Yönetici ve privileged hesaplar, siber saldırıların en değerli hedefleridir. Bu hesapların saldırıya uğraması durumunda:

- Tüm kuruluşa ait verilere erişim sağlanabilir
- Güvenlik politikaları değiştirilebilir
- Sistem yapılandırmaları manipüle edilebilir
- Audit logları silinebilir veya değiştirilebilir
- Lateral movement için köprübaşı oluşturulabilir

CrowdStrike 2023 Global Threat Report'a göre, identity-based attack'lerin %80'inden fazlası privileged hesapları hedeflemektedir. SolarWinds (2020), Colonial Pipeline (2021) ve MGM Resorts (2023) gibi büyük güvenlik olayları, privileged hesapların ele geçirilmesiyle başlamıştır.

7.4.2 Yönetici Hesapları İçin MFA Politikası Önerileri

Yönetici hesapları için MFA politikası, aşağıdaki ilkeler temelinde oluşturulmalıdır:

1. **Mutlaka phishing-resistant MFA kullanımı:** Yönetici hesapları için SMS veya TOTP tabanlı MFA yetersizdir. FIDO2/WebAuthn donanım anahtarları veya en azından platform passkey'leri zorunlu olmalıdır.
2. **Çoklu hesap ayrımı:** Yönetici hesapları, günlük iş hesaplarından ayrı olmalıdır. Fiziksel veya mantıksal olarak ayrılmış hesap yapısı, lateral movement riskini azaltır.
3. **Zero Trust ilkesiyle sürekli doğrulama:** Yönetici oturumları, periyodik olarak yeniden doğrulanmalıdır. Yüksek riskli işlemler için ek doğrulama adımları (step-up authentication) uygulanmalıdır.
4. **Privileged Access Management (PAM) entegrasyonu:** MFA, PAM çözümleriyle entegre edilerek privileged hesap erişimi kontrol altına alınmalıdır.
5. **Acil durum erişim protokolleri:** Acil durumlarda MFA cihazının kullanılamaması durumunda, izinli ve loglanmış alternatif erişim yolları tanımlanmalıdır.

7.4.3 Yönetici Hesapları için Uygulama Adımları

Adım	Faaliyet	Sorumluluk	Süre
1	Mevcut yönetici hesaplarının envanteri	IT Güvenlik	1 hafta
2	Risk tabanlı hesap sınıflandırması	Güvenlik Mimarisi	1 hafta
3	MFA donanım anahtarı tedariki	Satınalma/IT	2 hafta
4	FIDO2/WebAuthn entegrasyonu	Geliştirme/IT	3 hafta
5	Pilot uygulama (5-10 yönetici)	IT Güvenlik	2 hafta
6	Tam rollout	IT Operasyon	4 hafta
7	Monitoring ve politika denetimi	SOC	Sürekli

7.5 MFA Yorgunluğu ve Onay Körlüğü

7.5.1 MFA Yorgunluğu Tanımı

MFA yorgunluğu (MFA fatigue), kullanıcıların MFA isteklerine aşırı maruz kalması sonucu güvenlik duyarlılığının azalması ve rastgele onay verme davranışının gelişmesidir. Bu durum, push tabanlı MFA'da özellikle yaygındır.

MFA yorgunluğunun psikolojik temeli, "alarm yorgunluğu" (alarm fatigue) kavramıyla ilişkilidir. Tıpkı hastane monitorlerindeki sürekli alarm seslerinin personeli duyarsızlaştırması gibi, sürekli MFA istekleri de kullanıcıları duyarsızlaştırır.

7.5.2 Onay Körlüğü (Approval Blindness)

Onay körlüğü, kullanıcının MFA isteğinin içeriğini veya kaynağını kontrol etmeden otomatik olarak "Onayla" butonuna basmasıdır. Bu davranış, zamanla otomatikleşen bir tepki haline gelir.

Onay körlüğünün nedenleri:

- Sıklık:** Günde 10-20 kez tekrarlanan MFA istekleri, kullanıcıları rutine iter
- Süre baskısı:** Kısa süreli MFA istekleri, kontrol etme süresini kısaltır

3. **Güven algısı:** Kullanıcılar, MFA'nın zaten güvenli olduğunu düşünerek ek kontrol yapma ihtiyacını hissetmez
4. **Deneyim sorunu:** Bazı MFA uygulamaları, istek kaynağını yeterince göstermez

7.5.3 Push Fatigue Saldırıları

Push fatigue saldırısı, saldırganın bir kullanıcının hesabına erişmek için sürekli MFA push bildirimleri göndererek kullanıcıyı yorması ve sonunda onay alması taktiğidir.

Saldırı zinciri: 1. Saldırgan, kullanıcının parolasını credential stuffing ile elde eder 2. Kimlik doğrulama sunucusu kullanıcıya push bildirimi gönderir 3. Kullanıcı reddeder 4. Saldırgan tekrar dener 5. Bu döngü onlarca kez tekrarlanır 6. Kullanıcı yorulur ve en sonunda onay verir 7. Saldırgan oturum açar

Savunma stratejileri: - Rate limiting: Belirli bir süre zarfında izin verilen MFA isteği sayısını sınırlama - İstek bağlamı gösterimi: Her push isteğinde hangi uygulamadan ve nereden geldiği bilgisi - Onay öncesi challenge: "Onaylamadan önce hangi siteye giriş yapıyorsunuz?" sorusu - Bekleme süresi artırma: Ardışık reddedilen istekler arasındaki minimum süreyi artırma - Anomali tespiti: Olağandışı MFA istek kalıplarını otomatik olarak engelleme

7.5.4 MFA Yorgunluğunu Azaltma Stratejileri

Strateji	Açıklama	Etkinlik
Risk tabanlı MFA	Düşük riskli işlemlerde MFA atlanabilir	Yüksek
Trusted device	Bilinen cihazlarda MFA azaltılabilir	Yüksek
Biyometrik entegrasyon	Cihaz kilidi ile MFA birleştirilebilir	Yüksek
İstek azaltma	Gereksiz MFA istekleri kaldırılabilir	Orta
Eğitim ve farkındalık	Kullanıcılara neden onayladıklarını hatırlatma	Orta
İyileştirilmiş UX	Daha iyi istek gösterimi ve bağlam bilgisi	Orta

7.6 MFA Kurtarma Süreçleri

7.6.1 Kurtarma Senaryoları

MFA kurtarma süreçleri, aşağıdaki durumlar için planlanmalıdır:

1. **Cihaz kaybı/çalınması:** Kullanıcının MFA cihazını (telefon, donanım anahtarı) kaybetmesi
2. **Cihaz arızası:** MFA cihazının çalışmaması (pil bitmesi, donanım arızası)
3. **Uygulama silinmesi:** Doğrulayıcı uygulamasının bilinçsizce veya yanlışlıkla silinmesi
4. **Telefon numarası değişikliği:** SMS tabanlı MFA'da numara değişikliği
5. **Çalışan ayrılması:** Kurumsal ortamda çalışanın işten ayrılmasıyla MFA cihazının iade edilmesi
6. **Acil durum erişimi:** Kritik sistemlere MFA bileşeni olmadan erişim ihtiyacı

7.6.2 Kurtarma Yöntemleri

Yedek Kodlar (Recovery Codes) TOTP uygulamaları ve donanım anahtarı kurulumları sırasında üretilen tek kullanımlık yedek kodlardır. Bu kodlar güvenli bir yerde (fiziksel kasa, şifre yöneticisi) saklanmalıdır.

En iyi uygulamalar: - 8-12 adet yedek kod üretilmeli - Kodlar güvenli ve erişilebilir yerde saklanmalı - Her kod yalnızca bir kez kullanılmalı - Kullanılan kodlar izlenmeli - Periyodik olarak yenileri üretilmeli

Yönetici Kurtarma Hesapları Kurumsal ortamlarda, IT güvenlik ekibi tarafından yönetilen kurtarma hesapları tanımlanır. Bu hesaplar: - Yüksek güvenlikle korunmalı - Çoklu yönetici onayıyla kullanılmalı - Tam olarak loglanmalı - Periyodik olarak denetlenmeli - Minimum ayrıcalık ilkesiyle tasarlanmalı

Kimlik Doğrulama Kanıtlama (Identity Verification) Kullanıcının kimliğini fiziksel olarak kanıtlaması yöntemi. Örneğin, iş yerinde fotoğraflı kimlik kartıyla bizzat başvuru. Bu yöntem yüksek güvenlik sağlar ancak ölçeklenebilirliği düşüktür.

Çoklu Hesap Kurtarma Birden fazla kurtarma yolu tanımlama: - Birincil: FIDO2 donanım anahtarı - İkincil: Yedek FIDO2 anahtarı - Üçüncül: Yedek kodlar - Dördüncül: Yönetici kurtarma

7.6.3 Kurtarma Süreci Akış Diyagramı

Kurtarma süreci aşağıdaki adımları izlemelidir:

1. Kullanıcı "MFA'yı kurtar" seçeneğini seçer
2. Alternatif kimlik doğrulama yöntemi istenir (e-posta, SMS, güvenlik sorusu)
3. Kimlik doğrulama başarılıysa, kurtarma seçenekleri sunulur
4. Kullanıcı yeni MFA yöntemini yapılandırır
5. Eski MFA yöntemi devre dışı bırakılır
6. İşlem loglanır ve güvenlik ekibi bilgilendirilir
7. Periyodik denetimde kurtarma işlemleri incelenir

7.7 Kademeli Kurumsal Uygulama Planı

7.7.1 Planlama Aşaması (Ay 1-2)

Kurumsal MFA uygulaması, dikkatli bir planlama gerektirir. Planlama aşamasında aşağıdaki faaliyetler gerçekleştirilir:

Mevcut Durum Analizi: - Mevcut kimlik doğrulama altyapısının haritalanması - Kullanıcı hesaplarının sayısının ve türünün belirlenmesi - Kritik uygulamaların listelenmesi ve risk değerlendirmesi - Mevcut güvenlik politikalarının gözden geçirilmesi - Düzenleyici gereksinimlerin belirlenmesi (KVKK, ISO 27001, SOC 2)

Hedef Belirleme: - Kısa vadeli hedef: Yönetici hesaplarında %100 MFA kapsama - Orta vadeli hedef: Tüm kritik uygulamalarda MFA - Uzun vadeli hedef: Tüm kullanıcılarda phishing-resistant MFA - SLA tanımları: Kurtarma süreci süreleri, destek yanıt süreleri

7.7.2 Teknik Kurulum Aşaması (Ay 2-4)

- MFA çözüm seçimi ve lisanslama
- Identity Provider (IdP) entegrasyonu
- FIDO2/WebAuthn altyapı kurulumu
- Help desk ve self-service portal kurulumu
- Pilot grubun belirlenmesi ve eğitilmesi

- Test ortamında doğrulama

7.7.3 Pilot Uygulama Aşaması (Ay 4-6)

- IT departmanı ve gönüllü kullanıcılarla pilot
- Geri bildirim toplama ve analiz
- Politika ve süreç ayarlamaları
- Sorun giderme ve optimizasyon
- Başarı metriklerinin tanımlanması ve ölçümü

7.7.4 Kurumsal Rollout Aşaması (Ay 6-12)

Aylar	Hedef Grup	MFA Türü	Öncelik
6-7	Yönetici ve privileged hesaplar	FIDO2	Kritik
7-8	IT ve güvenlik personeli	FIDO2	Yüksek
8-9	Finans, hukuk, İK departmanları	TOTP/Push + FIDO2	Yüksek
9-10	Üretim ve operasyon	TOTP/Push	Orta
10-11	Satış ve pazarlama	TOTP/Push	Orta
11-12	Tüm diğer kullanıcılar	TOTP/Push	Normal

7.7.5 Sürekli İyileştirme (Ay 12+)

- Kullanıcı memnuniyeti anketleri
- Güvenlik olayı analizleri
- Politika güncellemeleri
- Yeni MFA teknolojilerinin değerlendirilmesi
- Yıllık denetim ve uyumluluk kontrolü

7.8 MFA Yöntemleri Karşılaştırma Matrisi

7.8.1 Geniş Kapsamlı Karşılaştırma

Özellik	SMS	E-posta	TOTP	Push	WebAuthn/ Passkey	Donanım Tokenı
Güvenlik Seviyesi	Düşük	Düşük	Orta	Orta-Yüksek	Yüksek	Yüksek
Phishing Direnci	Yok	Yok	Yok	Kısmi	Tam	Tam
Kullanıcı Kolaylığı	Yüksek	Yüksek	Orta	Yüksek	Yüksek	Orta
Kurulum Zorluğu	Düşük	Düşük	Düşük	Orta	Orta	Orta
Maliyet (kişi başı/yıl)	~\$1	~\$0	~\$0	~\$2-5	~\$0 (platform)	~\$25-50
Erişilebilirlik	Yüksek	Yüksek	Orta	Orta	Yüksek	Orta
İnternet Gereksinimi	Evet	Evet	Hayır	Evet	Hayır (platform passkey)	Hayır
Çalışma Ortamı	Telefon	Telefon/ Bilgisayar	Telefon	Telefon	Telefon/ Bilgisayar	Fiziksel
Kurtarma Kolaylığı	Yüksek	Yüksek	Orta	Orta	Orta	Düşük
NIST 800-63B	Restricted	Restricted	AAL2	AAL2	AAL2/3	AAL2/3

7.8.2 Sektörel Karşılaştırma

Sektör	Önerilen MFA	Düzenleyici Gereksinim
Bankacılık	Donanım + biyometrik	BDDK, PCI DSS
Sağlık	TOTP + biyometrik	HIPAA, KVKK

Sektör	Önerilen MFA	Düzenleyici Gereksinim
E-ticaret	Push veya passkey	PCI DSS
Kamu	FIDO2/WebAuthn	Siber Güvenlik Stratejisi
Eğitim	TOTP	Kurum içi politika
Üretim	Push veya TOTP	ISO 27001

Güvenli Anlatım Notu

MFA, kimlik doğrulama güvenliğinde parolayı tamamlamak için tasarlanmış bir mekanizmadır. Hiçbir MFA yöntemi mutlak güvenlik sağlamaz; her yöntemin avantajları ve zafiyetleri vardır. Phishing-resistant MFA (FIDO2/WebAuthn) en yüksek güvenlik seviyesini sunmasına rağmen, uygulama maliyeti ve kullanıcı adaptasyonu dikkate alınmalıdır. Kurumsal MFA stratejisi, risk tabanlı bir yaklaşımla, farklı kullanıcı grupları için farklı MFA yöntemleri önerebilir. MFA'nın etkinliği, doğru uygulama, sürekli eğitim ve güncel tehditlerle uyumlu politikalarla sağlanır.

Özet

Çok faktörlü kimlik doğrulama (MFA), modern kimlik doğrulama güvenliğinin temel bir bileşenidir. Tek faktörlü (parola) kimlik doğrulamasının yetersiz kaldığı günümüz tehdit ortamında, MFA hesap ele geçirme saldırılarına karşı önemli bir engel oluşturmaktadır. Ancak tüm MFA yöntemleri eşit güvenlik sunmamaktadır. SMS ve e-posta tabanlı MFA, phishing ve SIM swap saldırılarına karşı savunmasızdır. TOTP daha güvenli olmakla birlikte, phishing'e karşı tam koruma sağlamaz. Push tabanlı MFA, kullanıcı deneyimini iyileştirmesine rağmen, push fatigue saldırılarına açıktır. FIDO2/WebAuthn tabanlı donanım anahtarları ve passkey'ler, protokol düzeyinde phishing koruması sağlayarak en yüksek güvenlik seviyesini sunmaktadır.

Kurumsal düzeyde MFA uygulaması, dikkatli planlama, kademeli rollout ve sürekli iyileştirme gerektirir. Yönetici ve privileged hesaplarda MFA zorunluluğu, kurumsal güvenlik stratejisinin vazgeçilmez bir parçasıdır. MFA yorgunluğu ve onay körlüğü, kullanıcı deneyimi ve güvenlik arasındaki dengeyi koruyacak önlemlerle ele alınmalıdır. Güçlü bir kurtarma süreci, MFA'nın etkinliğini ve kullanıcı kabulünü artırır.

Kontrol Listesi

- [] Tüm kritik hesaplarda MFA etkinleştirilmiş mi?
- [] Yönetici ve privileged hesaplarda phishing-resistant MFA kullanılıyor mu?
- [] MFA kurtarma süreçleri tanımlı ve test edilmiş mi?
- [] Kullanıcılara MFA eğitimi verilmiş mi?
- [] Push fatigue saldırılarına karşı rate limiting uygulanıyor mu?
- [] Yedek kodlar güvenli bir şekilde saklanıyor mu?
- [] MFA politikası düzenli olarak gözden geçiriliyor mu?
- [] Help desk ekibi MFA kurtarma süreçlerinde yetkin mi?
- [] Acil durum erişim protokolleri tanımlı mı?
- [] MFA uygulama kapsamı ve etkinliği ölçülüyor mu?

Tartışma Soruları

1. Bir kurumda tüm kullanıcıları TOTP tabanlı MFA'ya geçirmek istiyorsunuz. Karşılaşabileceğiniz zorluklar nelerdir ve bunları nasıl aşarsınız?
2. Push fatigue saldırısına uğrayan bir kullanıcı, saldırganı onaylamıştır. Saldırı tespit edildikten sonra hangi acil müdahale adımları atılmalıdır?
3. FIDO2 donanım anahtarları pahalı bir çözüm gibi görünmektedir. Küçük ve orta ölçekli işletmeler için maliyet-etkin bir MFA stratejisi nasıl tasarlanabilir?
4. Biyometrik MFA'nın mahremiyet ve veri koruma açısından yarattığı endişeler nelerdir? Bu endişeleri nasıl ele alırsınız?

5. Kurumsal bir ortamda hem eski (TOTP) hem de yeni (FIDO2) MFA yöntemlerinin birlikte kullanılmasının avantajları ve dezavantajları nelerdir?
6. "MFA her zaman güvenlidir" ifadesini eleştirel olarak değerlendirin. Hangi durumlarda MFA bile yeterli olmayabilir?

Kaynaklar

1. OWASP. (t.y.). *Multifactor Authentication Cheat Sheet*. Open Worldwide Application Security Project. <https://cheatsheetseries.owasp.org/cheatsheets/Multifactor-Authentication-Cheat-Sheet.html>
 2. CISA. (2023). *Implementing Strong Authentication*. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/topics/cyber-threats-and-advisories/federal-information-security-modernization-act/strong-authentication>
 3. FIDO Alliance. (2024). *FIDO2 Specifications*. Fast Identity Online Alliance. <https://fidoalliance.org/fido2/>
 4. NIST. (2025). *SP 800-63B-4: Digital Identity Guidelines — Authentication and Authenticator Management*. National Institute of Standards and Technology.
 5. ENISA. (2023). *Threat Landscape for Identity and Access Management*. European Union Agency for Cybersecurity.
 6. M'Raihi, D., Machani, S., Pei, M., & Rydell, J. (2011). *TOTP: Time-Based One-Time Password Algorithm (RFC 6238)*. Internet Engineering Task Force.
 7. W3C. (2021). *Web Authentication: An API for Accessing Public Key Credentials Level 2*. World Wide Web Consortium.
 8. CrowdStrike. (2023). *2023 Global Threat Report*. CrowdStrike Holdings.
 9. Microsoft. (2023). *Passwordless Authentication: A Vision for the Future*. Microsoft Security Blog.
 10. Google. (2023). *The State of Account Security*. Google Security Blog.
-

BÖLÜM 8 — PAROLASIZ KİMLİK DOĞRULAMA VE PASSKEY

[↩ İçindekilere dön](#)

Amaç

Bu bölümün amacı, parolasız kimlik doğrulama (passwordless authentication) kavramını, temel kriptografik mekanizmalarını, FIDO2/WebAuthn ve CTAP standartlarını, passkey modellerini ve kurumsal geçiş stratejisini kapsamlı biçimde ele almaktır. Parolasız kimlik doğrulama, on yıldan uzun süredir devam eden "daha iyi parola" çabasının ötesine geçerek, parolayı tamamen ortadan kaldırarak kimlik doğrulama güvenliğini ve kullanıcı deneyimini aynı anda iyileştirmeyi hedefleyen bir paradigma değişikliğidir.

Araştırma Soruları

1. Parolasız kimlik doğrulama nasıl çalışır ve geleneksel kimlik doğrulamadan farkı nedir?
 2. Açık anahtar kriptografisi nasıl kullanılır?
 3. FIDO2, WebAuthn ve CTAP standartları arasındaki ilişki nedir?
 4. Cihaz bağlı ve senkronize passkey modelleri arasındaki farklar nelerdir?
 5. Kurumsal ortamda parolasız geçiş nasıl planlanır?
 6. Parolasız kimlik doğrulamanın yeni riskleri nelerdir?
-

8.1 Parolasız Kimlik Doğrulama Kavramı

8.1.1 Parolanın Sonu mu?

Bilgisayar parolalarının erken kullanımı, 1960'ların başında Fernando Corbató liderliğinde geliştirilen MIT Compatible Time-Sharing System (CTSS) ile ilişkilendirilir. Parolalar altmış yılı aşkın süredir dijital kimlik doğrulamada kullanılmaktadır; ancak tekrar kullanım, kimlik avı ve insan belleğine yük bindirmesi nedeniyle tek başına yeterli güvence sağlamaz:

- İnsanlar zayıf, tahmin edilebilir parolalar seçme eğilimindedir
- Parolaları hatırlamak ve yönetmek kullanıcı yükü yaratır
- Parolalar phishing, credential stuffing ve brute force saldırılarına karşı savunmasızdır
- Parola yeniden kullanımı yaygın bir sorundur
- Parola sıfırlama ve hesap kurtarma, destek yükü kadar sosyal mühendislik riski de üretir

Parolasız kimlik doğrulama, bu sorunlara köklü bir çözüm olarak ortaya çıkmıştır. FIDO Alliance'ın verilerine göre, 2024 itibarıyla Google, Apple ve Microsoft gibi büyük platformlar parolasız kimlik doğrulamayı aktif olarak desteklemektedir.

8.1.2 Parolasız Kimlik Doğrulama Tanımı

Parolasız kimlik doğrulama, kullanıcıların parola girmeden kimliklerini doğrulamasını sağlayan mekanizmalar bütünüdür. Bu mekanizmalar genellikle açık anahtar kriptografisine (public key cryptography) dayanır ve şu temel unsurları içerir:

1. **Kayıt (Registration):** Kullanıcı, bir web sitesine veya uygulamaya kaydolurken bir kriptografik anahtar çifti oluşturur
2. **Kimlik Doğrulama (Authentication):** Kullanıcı, parola yerine kriptografik mekanizmalarla kimliğini doğrular
3. **Oturum Yönetimi (Session Management):** Kimlik doğrulamadan sonra güvenli bir oturum başlatılır

Parolasız kimlik doğrulama, parola tabanlı kimlik doğrulamanın yerini almayı hedefler; MFA ise parolayı tamamlar. Ancak parolasız kimlik doğrulama aynı zamanda doğal bir çok faktörlü kimlik doğrulama mekanizmasıdır çünkü genellikle cihaz (sahip olunan şey) ve biyometrik veya PIN (bir şey / bilinen şey) kombinasyonunu kullanır.

8.1.3 Parolasız Kimlik Doğrulama Türleri

Parolasız kimlik doğrulama birkaç farklı şekilde gerçekleştirilebilir:

Bağlantı tabanlı (Link-based): - E-posta sihirli bağlantısı (magic link) - SMS veya uygulama bildirimi ile oturum açma - QR kodu tarama

Kriptografik tabanlı (Cryptographic): - FIDO2/WebAuthn (passkey) - SAML/OIDC tabanlı parolasız oturum açma - Sertifika tabanlı kimlik doğrulama

Biyometrik tabanlı: - Cihaz yerleşik biyometriği ile kimlik doğrulama - Davranışsal biyometri ile sürekli doğrulama

Parolasız kimlik doğrulamada en güvenilir yöntem kriptografik tabanlı yöntemlerdir, çünkü bu yöntemler man-in-the-middle saldırılarına ve phishing'e karşı protokol düzeyinde koruma sağlar.

8.2 Açık Anahtar Kriptografisi ve Challenge-Response

8.2.1 Açık Anahtar Kriptografisi Temelleri

Açık anahtar kriptografisi (asimetrik kriptografi), iki birbirini tamamlayan anahtar kullanan bir kriptografik sistemdir:

- **Özel anahtar (Private key):** Sadece sahibi tarafından bilinir, asla paylaşılmaz
- **Genel anahtar (Public key):** Herkese açıktır ve özel anahtarla ilişkilidir

Bu anahtar çiftinin temel özelliği, genel anahtarla şifrelenen mesajların sadece özel anahtarla çözülebilmesi ve özel anahtarla imzalanan mesajların genel anahtarla doğrulanabilmesidir.

Parolasız kimlik doğrulamada bu mekanizma şu şekilde kullanılır:

1. **Kayıt sırasında:** Kullanıcı cihazında bir anahtar çifti oluşturur. Özel anahtar cihazda kalır, genel anahtar sunucuya gönderilir
2. **Kimlik doğrulama sırasında:** Sunucu bir "challenge" (meç) gönderir, kullanıcı cihazı özel anahtarla imzalar ve imzayı sunucuya iletir, sunucu genel anahtarla doğrular

8.2.2 Challenge-Response Mekanizması

Challenge-response (meç-cevap) protokolü, parolasız kimlik doğrulamanın temel mekanizmasıdır. Bu protokol, her oturum açma denemesinde farklı bir kriptografik meydan okuma kullanarak replay (tekrar oynatma) saldırılarını önler.

Adım 1: Meç Üretimi Sunucu, kriptografik olarak güvenli bir rastgele değer (challenge) üretir. Bu değer: - Yeterince uzun olmalıdır (en az 128 bit, tercihen 256 bit) - Kriptografik olarak rastgele olmalıdır - Her istek için benzersiz olmalıdır - Tekrar kullanılmamalıdır

Adım 2: Cihaz Tarafından İmzalama Kullanıcının cihazı (donanım anahtarı veya platform passkey'i), challenge değerini özel anahtarla imzalar: - İmzalama işlemi cihaz yerleşik güvenli bölgesinde (secure enclave) gerçekleşir - Özel anahtar asla cihazdan dışarı çıkmaz - İmzalama işlemi için ek doğrulama (biyometrik, PIN) gerekebilir

Adım 3: Doğrulama Sunucu, genel anahtarla imzayı doğrular: - Sunucu, challenge'ın aynı olup olmadığını kontrol eder - İmzanın doğru anahtarla yapıldığını doğrular - Doğrulama başarılıysa kullanıcı kimliği doğrulanmış olur

8.2.3 Güvenlik Analizi

Challenge-response mekanizmasının sağladığı güvenlik garantileri:

Saldırı Türü	Savunma Mekanizması
Replay saldırısı	Her istek için benzersiz challenge
Man-in-the-Middle	Origin doğrulaması (WebAuthn)
Brute force	Cihaz düzeyinde kilitlenme
Credential stuffing	Credential yok, anahtar tabanlı

Saldırı Türü	Savunma Mekanizması
Kayıt veri tabanı sızıntısı	Özel anahtar sunucuda yok; genel anahtar tek başına kullanılamaz
Phishing	Origin doğrulaması ve challenge bağlamı

Yalnızca kimlik bilgisi kayıt veri tabanının sızması durumunda saldırgan genel anahtarlarla kullanıcı olarak imza üretemez; özel anahtar doğrulayıcıda kalır. Buna karşılık uygulama sunucusunun bütünüyle ele geçirilmesi, doğrulama mantığının atlanmasına veya yeni kimlik bilgisi kaydına yol açabilir. Açık anahtar modeli kayıt sızıntısının etkisini azaltır, sunucu güvenliğini gereksiz kılmaz.

8.3 FIDO2, WebAuthn ve CTAP

8.3.1 FIDO2 Mimarisi

FIDO2, iki temel standarttan oluşur:

1. **WebAuthn (Web Authentication API):** W3C tarafından geliştirilen, tarayıcı ile kimlik doğrulama sunucusu arasındaki iletişimi tanımlayan API standardı
2. **CTAP (Client to Authenticator Protocol):** FIDO Alliance tarafından geliştirilen, istemci (tarayıcı/uygulama) ile kimlik doğrulama cihazı arasındaki iletişimi tanımlayan protokol

Bu iki standart birlikte çalışarak, kullanıcının cihazından (donanım anahtarı veya platform passkey) web sunucularına kadar kesintisiz ve güvenli bir kimlik doğrulama zinciri oluşturur.

8.3.2 WebAuthn Detayları

WebAuthn API, iki temel işleve sahiptir:

`navigator.credentials.create()` — Kayıt:

```
// Bu kod sentetik bir ornektir, gerçek uygulama için referanslara bakınız
const credential = await navigator.credentials.create({
  publicKey: {
    challenge: sunucudanGelenChallenge,
```

```

rp: { name: "Örnek Kurum", id: "ornek-kurum.com" },
user: {
  id: kullanicIID,
  name: "kullanici@ornek-kurum.com",
  displayName: "Kullanıcı Adı"
},
pubKeyCredParams: [
  { alg: -7, type: "public-key", }, // ES256
  { alg: -257, type: "public-key" } // RS256
],
authenticatorSelection: {
  authenticatorAttachment: "cross-platform",
  userVerification: "required"
},
timeout: 60000,
attestation: "direct"
}
}

```

`navigator.credentials.get()` — Kimlik Doğrulama:

```

// Bu kod sentetik bir örnektir
const assertion = await navigator.credentials.get({
  publicKey: {
    challenge: sunucudanGelenChallenge,
    rpId: "ornek-kurum.com",
    allowCredentials: [{
      type: "public-key",
      id: kayitliCredentialId
    }],
    userVerification: "required"
  },
  timeout: 60000
})

```

8.3.3 CTAP Protokolü

CTAP, iki versiyonda mevcuttur:

CTAP 1.0 (U2F): - USB ve NFC üzerinden iletişim - Basit challenge-imzalama mekanizması - Sadece ikinci faktör (MFA) olarak kullanım - YubiKey U2F, Google Titan Security Key

CTAP 2.0: - USB, NFC, BLE (Bluetooth Low Energy) üzerinden iletişim - Gelişmiş kimlik bilgisi (credential) yönetimi - Parolasız kimlik doğrulama desteği - Biyometrik ve PIN doğrulama desteği - Platform ve cross-platform authenticator desteği

8.3.4 Authenticator Türleri

FIDO2 destekleyen kimlik doğrulayıcılar iki ana kategoride sınıflandırılır:

Platform Authenticator: - Cihaza yerleşik kimlik doğrulayıcı (Face ID, Touch ID, Windows Hello) - Cihaza bağlıdır, ayrı bir donanım gerektirmez - Genellikle cihaz sahibi tarafından erişilebilir

Cross-Platform Authenticator: - Fiziksel donanım anahtarı (YubiKey, Titan Security Key) - Birden fazla cihazda kullanılabilir - Cihazdan bağımsızdır - Genellikle USB, NFC veya Bluetooth ile bağlanır

8.4 Cihaz Bağlı ve Senkronize Passkey Modelleri

8.4.1 Passkey Nedir?

Passkey, FIDO2/WebAuthn standardı temelinde çalışan, parolasız kimlik doğrulama için kullanılan bir kriptografik kimlik bilgisidir (credential). Bir passkey, kullanıcı ile belirli bir web sitesi arasında oluşturulan bir anahtar çiftinden oluşur. Özel anahtar cihazda güvende tutulurken, genel anahtar web sitesine kaydedilir.

8.4.2 Cihaz Bağlı Passkey (Device-Bound Passkey)

Cihaz bağlı passkey, belirli bir fiziksel cihaza bağlı olan ve başka cihazlara aktarılamayan passkey modelidir.

Özellikleri: - Anahtar çifti belirli bir cihazda (donanım anahtarı veya cihaz yerleşik secure enclave) oluşturulur - Özel anahtar asla o cihazdan dışarı çıkmaz - Diğer cihazlara aktarım desteklenmez - Cihaz kaybında passkey de kaybolur (kurtarma gerekir)

Kullanım alanları: - Kurumsal ortamlar (YubiKey tabanlı) - Yüksek güvenlik gerektiren uygulamalar - Düzenleyici gereksinimlerin yüksek olduğu sektörler - Kritik altyapı erişimi

Avantajları: - En yüksek güvenlik seviyesi - Özel anahtarın fiziksel olarak korunması - Lateral movement riskinin ortadan kalkması - Cihaz değişikliği durumunda kontrollü geçiş

Dezavantajları: - Cihaz kaybında erişim sorunu - Cihaz yenileme/değiştirme süreçleri karmaşık - Kullanıcı çoklu cihaz kullanıyorsa her cihaza ayrı passkey gerekir - Cihaz yönetimi altyapısı gerektirir

8.4.3 Senkronize Passkey (Synced Passkey)

Senkronize passkey, kullanıcının birden fazla cihazında erişilebilir olacak şekilde senkronize edilen passkey modelidir.

Özellikleri: - Passkey, kullanıcının platform hesabına (Apple ID, Google Account, Microsoft Account) bağlıdır - Anahtar çifti, kullanıcının tüm cihazları arasında end-to-end şifreli olarak senkronize edilir - Bir cihazda oluşturulan passkey, kullanıcının tüm cihazlarında kullanılabilir - Bulut tabanlı yedekleme ile cihaz kaybına karşı koruma

Senkronizasyon Mekanizması: - Apple: iCloud Keychain ile end-to-end şifreli senkronizasyon - Google: Google Password Manager ile senkronizasyon (Google account şifrelenir) - Microsoft: Windows ve Edge ile senkronizasyon (Microsoft account)

Avantajları: - Kullanıcı deneyimi mükemmeldir - Cihaz kaybında passkey korunur (bulut yedeklemesi sayesinde) - Çoklu cihaz kullanımı kolaydır - Kullanıcı adoption oranı yüksektir

Dezavantajları: - Platform sağlayıcısına güven gerekir - Platform hesabı ele geçirilirse passkey'ler risk altına girer - Çapraz platform (Apple → Android) geçişleri karmaşık olabilir - Kurumsal kontrol sınırlıdır - Hizmet sağlayıcının senkronizasyon altyapısına bağımlılık

8.4.4 Karşılaştırma Matrisi

Özellik	Cihaz Bağlı Passkey	Senkronize Passkey
Güvenlik Seviyesi	Yüksek	Orta-Yüksek
Özel Anahtar Yayılımı	Tek cihaz	Tüm cihazlar
Cihaz Kaybı Riski	Yüksek (kurtarma gerekir)	Düşük (bulut yedekleme)

Özellik	Cihaz Bağlı Passkey	Senkronize Passkey
Kullanıcı Deneyimi	İyi	Mükemmel
Kurumsal Kontrol	Yüksek	Düşük-Orta
Platform Bağımlılığı	Düşük	Yüksek
Çapraz Platform	Evet (FIDO2 standardı)	Kısmi (platform arası)
Uygun Kullanım	Kurumsal, yüksek güvenlik	Tüketici, genel kullanım

8.5 Kullanıcı Deneyimi ve Kurtarma

8.5.1 Kullanıcı Deneyimi Tasarımı

Parolasız kimlik doğrulamanın başarısı, kullanıcı deneyimine (UX) bağlıdır. İyi bir parolasız UX aşağıdaki ilkeleri izlemelidir:

Basitlik: - Tek tıklama veya dokunuşla kimlik doğrulama - Uzun parola girme veya karmaşık adımlar gerektirmeme - Net ve anlaşılır arayüz tasarım

Tutarlılık: - Tüm platformlarda benzer deneyim - Farklı cihazlarda (masaüstü, mobil, tablet) uyumlu çalışma - Farklı tarayıcılarda tutarlı davranış

Geri Bildirim: - Her adımda kullanıcıya durum bilgisi sunma - Başarılı ve başarısız işlemlerde açık mesajlar - İlerleme göstergesi ve bekleme sürelerini bildirme

Erişilebilirlik: - Farklı engelli kullanıcı gruplarına uygun tasarım - Ekran okuyucu desteği - Fiziksel motor yetenek farklılıklarını dikkate alma

8.5.2 Passkey Kurtarma Senaryoları

Passkey kurtarma, parolasız kimlik doğrulamanın en kritik konularından biridir. Aşağıdaki senaryolar planlanmalıdır:

Senaryo 1: Cihaz Kaybı - Platform senkronize passkey'i varsa: Yeni cihazda oturum açma mevcut - Cihaz bağlı passkey ise: Yedek passkey veya alternatif kimlik doğrulama gerekir - Kurtarma kodları veya yedek kimlik doğrulama yöntemi devreye girer

Senaryo 2: Platform Hesabı Ele Geçirilme - Saldırgan, kullanıcının Apple ID veya Google hesabını ele geçirirse, tüm senkronize passkey'lere erişebilir - Savunma: Platform hesabında çok faktörlü kimlik doğrulama zorunlu olmalıdır - Ek savunma: Hassas passkey'ler için cihaz bağlı passkey tercih edilmeli

Senaryo 3: Kurumsal Hesap Devri - Çalışan ayrılınca, kurumsal passkey'ler iptal edilmeli - Yeni çalışan için yeni passkey'ler oluşturulmalı - Geçiş sürecinde kesintisiz erişim sağlanmalı

Senaryo 4: Cihaz Yenileme - Eski cihazdan yeni cihaza geçiş süreci - Senkronize passkey'lerde otomatik geçiş - Cihaz bağlı passkey'lerde manuel kurtarma

8.5.3 Kurtarma Stratejileri

Strateji	Açıklama	Uygun Senaryo
Platform senkronizasyonu	Passkey'lerin bulut senkronizasyonu	Tüketici kullanımı
Yedek passkey	Fiziksel donanım anahtarı olarak yedek	Kurumsal
Kurtarma kodları	Tek kullanımlık kurtarma kodları	Tüm senaryolar
E-posta sihirli bağlantısı	E-posta ile kurtarma bağlantısı	Düşük risk
Yardımcı hesap	Güvenilir yardımcı hesap ile kurtarma	Tüketici
IT desteği	Kurumsal IT yardımı ile kurtarma	Kurumsal
Biyometrik fallback	Yüz tanıma ile kurtarma (platforma bağlı)	Platforma bağlı

8.6 Kurumsal Geçiş Planı

8.6.1 Mevcut Durum Değerlendirmesi

Kurumsal geçiş planı, mevcut durumun kapsamlı bir değerlendirmesiyle başlar:

Altyapı Değerlendirmesi: - Mevcut kimlik doğrulama altyapısının (IdP, LDAP, AD) FIDO2/WebAuthn destek seviyesi - Tarayıcı ve cihaz uyumluluğu - Ağ altyapısı ve sertifika yönetimi - API ve servis uyumluluğu

Uygulama Envanteri: - Parola kullanan tüm uygulamaların listelenmesi - Her uygulamanın WebAuthn destek durumunun belirlenmesi - Legacy uygulamalar için geçiş stratejisi - Üçüncü parti uygulamaların parolasız destek değerlendirilmesi

Kullanıcı Analizi: - Kullanıcıların teknik yetkinlik düzeyleri - Cihaz envanteri ve yaş dağılımı - Erişilebilirlik gereksinimleri - Coğrafi dağılım ve uzaktan çalışma oranları

8.6.2 Geçiş Stratejisi Modelleri

Model 1: Big Bang Geçiş - Tüm kullanıcılara aynı anda geçiş - Avantajı: Hızlı uygulama - Dezavantajı: Yüksek risk, destek yükü

Model 2: Kademeli Geçiş - Öncelik gruplarına göre kademeli geçiş - Avantajı: Kontrollü, düşük risk - Dezavantajı: Uzun süre

Model 3: Hibrit Model - Parola ve passkey'in birlikte kullanılması - Avantajı: Geri dönüş imkanı - Dezavantajı: Karmaşıklık

Model 4: Risk Tabanlı Geçiş - Yüksek riskli hesaplardan başlayarak kademeli geçiş - Avantajı: Risk odaklı - Dezavantajı: Karmaşık politika yönetimi

8.6.3 Geçiş Yol Haritası

Aşama	Süre	Faaliyetler	Çıktılar
Değerlendirme	Ay 1-2	Altyapı analizi, uygulama envanteri, risk değerlendirmesi	Değerlendirme raporu
Planlama	Ay 2-3	Strateji seçimi, politika oluşturma, kaynak tahsisi	Geçiş planı
Pilot	Ay 3-5	IT ekibi ve gönüllü kullanıcılarla pilot uygulama	Pilot raporu
Ölçekleme	Ay 5-9	Kademeli kurumsal rollout	Tam rollout
Optimizasyon	Ay 9-12	Geri bildirim toplama, süreç iyileştirme	Optimizasyon raporu
Sürekli	12+ ay	Monitoring, politika güncelleme, yeni özellikler	Sürekli raporlama

8.7 Yeni Riskler: Cihaz, Tarayıcı, Kurtarma

8.7.1 Cihaz Düzeyindeki Riskler

Parolasız kimlik doğrulama, cihazlara yeni güvenlik sorumlulukları getirir:

Cihaz Ele Geçirme: Parola tabanlı sistemlerde bir parola ele geçirildiğinde sadece hesap risk altına girer. Ancak passkey tabanlı sistemde bir cihazın ele geçirilmesi, o cihazdaki tüm passkey'leri riske atar. Bu nedenle cihaz güvenliği parolasız kimlik doğrulamanın temel bir bileşenidir.

Cihaz Güvenlik Gereksinimleri: - Güvenli önyükleme (Secure Boot) - Disk şifreleme (Full Disk Encryption) - Biyometrik kilitleme - Güncel işletim sistemi - EDR/XDR koruması - Mobil cihaz yönetimi (MDM)

Root/Jailbreak Riski: Root veya jailbreak yapılmış cihazlarda secure enclave erişilebilir hale gelir. Bu cihazlarda passkey'lerin güvenliği garanti altına alınamaz.

8.7.2 Tarayıcı Düzeyindeki Riskler

Tarayıcı Eklentileri: Zararlı tarayıcı eklentileri WebAuthn API çağrılarını manipüle edebilir. Tarayıcı güvenliği, parolasız kimlik doğrulamanın zayıf halkası olabilir.

Phishing Tarayıcıları: Oltalama amaçlı tarayıcılar, WebAuthn API'yi taklit ederek kullanıcıları kandırabilir. Ancak WebAuthn'ın origin doğrulaması bu tür saldırıları büyük ölçüde engeller.

Tarayıcı Uyumluluğu: Farklı tarayıcılar WebAuthn standartlarını farklı hızlarda ve seviyelerde destekler. Bu durum, çapraz tarayıcı uyumluluk sorunlarına yol açabilir.

8.7.3 Kurtarma Riskleri

Tek Nokta Bağımlılığı: Senkronize passkey'lerde, platform hesabının (Apple ID, Google Account) ele geçirilmesi tüm passkey'lere erişim sağlayabilir. Bu, tek nokta bağımlılığı riski yaratır.

Kurtarma Sırasındaki Zafiyet: Kurtarma süreçleri, kimlik doğrulama sürecinin en zayıf halkasıdır. Saldırganlar kurtarma süreçlerini hedef alarak parolasız kimlik doğrulamayı atlayabilir.

Veri Kaybı Riski: Platform senkronizasyonu durdurulduğunda veya hesap kapatıldığında, passkey'ler kalıcı olarak kaybolabilir. Fiziksel yedekleme stratejileri bu riski azaltır.

8.7.4 Risk Değerlendirme Matrisi

Risk	Olasılık	Etki	Risk Seviyesi	Azaltma
Cihaz ele geçirme	Orta	Yüksek	Yüksek	MDM, EDR, biyometrik
Platform hesabı sızıntısı	Düşük	Çok Yüksek	Yüksek	Platform MFA, monitored access
Kurtarma suistimali	Orta	Yüksek	Yüksek	Çoklu onay, kayıtlı ve denetlenebilir süreç
Tarayıcı zafiyeti	Düşük	Orta	Orta	Tarayıcı sandboxing, güncellemesi,
Root/jailbreak cihaz	Düşük	Yüksek	Orta	Cihaz uyumluluk kontrolü
Kayıp cihaz	Yüksek	Orta	Orta	Uzaktan senkronizasyon silme,

8.8 Parolasız Geçiş Yol Haritası

8.8.1 Kısa Vadeli Adımlar (0-6 ay)

- Farkındalık ve Eğitim:** IT ekibi ve kullanıcıları parolasız kimlik doğrulama konusunda eğitme
- Altyapı Hazırlığı:** Identity Provider'ı FIDO2/WebAuthn destekli hale getirme
- Pilot Uygulama:** Küçük bir kullanıcı grubuyla pilot geçiş
- Politika Oluşturma:** Parolasız kimlik doğrulama politika ve prosedürlerini tanımlama

8.8.2 Orta Vadeli Adımlar (6-18 ay)

1. **Kademeli Rollout:** Tüm kullanıcı gruplarına kademeli geçiş
2. **Legacy Uygulama Dönüştürme:** Eski uygulamaları parolasız destekli hale getirme veya atlatma mekanizmaları
3. **Kurtarma Altyapısı:** Kapsamlı kurtarma süreçlerini devreye alma
4. **Monitoring ve Raporlama:** Parolasız kimlik doğrulama metriklerini takip etme

8.8.3 Uzun Vadeli Adımlar (18+ ay)

1. **Parola Kaldırma:** Parola kullanımını tamamen sonlandırma
2. **İleri Düzey Kimlik Doğrulama:** Davranışsal biyometri ve sürekli kimlik doğrulama
3. **Zero Trust Entegrasyonu:** Parolasız kimlik doğrulamayı Zero Trust mimarisine entegre etme
4. **Sürekli İyileştirme:** Yeni FIDO2 özelliklerini ve passkey geliştirmelerini benimseme

8.8.4 Başarı Metrikleri

Metrik	Hedef Değer	Ölçüm Yöntemi
Parola kullanım oranı	%0 (18 ay içinde)	Auth log analizi
Kullanıcı memnuniyeti	>%80	Anket
Kurtarma başarı oranı	>%95	Help desk verisi
Ortalama kimlik doğrulama süresi	<5 saniye	Metrik
Kimlik doğrulama başarısızlık oranı	<%2	Auth log analizi
Güvenlik olayı azalması	>%50	Olay istatistikleri

Güvenli Anlatım Notu

Parolasız kimlik doğrulama, kimlik doğrulama güvenliğinde bir paradigma değişikliğini temsil eder. Açık anahtar kriptografisi ve FIDO2/WebAuthn standartları, phishing'e karşı protokol düzeyinde koruma sağlayarak geleneksel parola ve MFA yöntemlerinin sınırlarını aşar. Ancak parolasız sistemler yeni riskler de getirir: cihaz güvenliği, kurtarma süreçleri ve platform bağımlılığı. Kurumsal geçiş, kapsamlı bir planlama, kademeli uygulama ve sürekli iyileştirme gerektirir. Parolasız kimlik doğrulama tek başına mutlak bir çözüm değildir; daha geniş bir güvenlik stratejisinin parçası olarak en etkili sonucu verir.

Özet

Parolasız kimlik doğrulama, parolaların yapısal zafiyetlerini ortadan kaldırarak kimlik doğrulama güvenliğini ve kullanıcı deneyimini aynı anda iyileştirmeyi hedefleyen bir yaklaşımdır. Açık anahtar kriptografisine ve challenge-response mekanizmasına dayanan bu sistemler, FIDO2, WebAuthn ve CTAP standartlarıyla endüstri düzeyinde standardize edilmiştir. Passkey'ler, cihaz bağlı ve senkronize olmak üzere iki modelde sunulmakta ve farklı güvenlik-ihtiyaç dengelerine hitap etmektedir.

Parolasız kimlik doğrulama, geleneksel sistemlere göre birçok avantaj sunmasına rağmen yeni riskler de getirir. Cihaz ele geçirilmesi, platform hesabı sızıntıları, kurtarma süreçlerindeki zafiyetler ve tarayıcı güvenlik açıkları dikkatle ele alınmalıdır. Kurumsal geçiş, kapsamlı bir mevcut durum değerlendirmesi, strateji seçimi, kademeli uygulama ve sürekli iyileştirme gerektirir.

Parolasız kimlik doğrulama, parolaların sonu olarak görülmelidir. Ancak bu geçiş, bir gecede gerçekleşmeyecek; planlı, kademeli ve risk-aware bir yaklaşımla hayata geçirilmelidir. Tüm paydaşların eğitimi, güçlü bir kurtarma altyapısı ve sürekli monitoring, geçişin başarısını belirleyen kritik faktörlerdir.

Kontrol Listesi

- [] Identity Provider FIDO2/WebAuthn destekliyor mu?
- [] Kullanıcı cihazları passkey için uyumlu mu?
- [] Pilot uygulama başarıyla tamamlandı mı?
- [] Kurtarma süreçleri tanımlı ve test edilmiş mi?
- [] Legacy uygulamalar için geçiş stratejisi var mı?
- [] Kullanıcılara parolasız kimlik doğrulama eğitimi verildi mi?
- [] Cihaz güvenliği politikaları güncel mi?
- [] Parola kaldırma takvimi belirlendi mi?
- [] Monitoring ve alerting altyapısı hazır mı?
- [] Düzenleyici gereksinimler karşılanıyor mu?

Tartışma Soruları

1. Senkronize passkey'lerin platform sağlayıcılara olan bağımlılığı, kurumsal veri güvenliği açısından ne tür riskler oluşturur?
2. Bir kurumda parolasız geçiş yapılmışken, bir kullanıcının tüm cihazlarının alınması durumunda hangi kurtarma mekanizmaları devreye girer?
3. Legacy uygulamalar (eski sistemler) parolasız kimlik doğrulamayı desteklemiyorsa, bu uygulamalar için hangi geçiş stratejileri uygulanabilir?
4. Parolasız kimlik doğrulamanın farklı coğrafi bölgelerde ve farklı demografik gruplardaki kullanıcılar üzerindeki etkileri nelerdir?
5. Gelecekte parolasız kimlik doğrulama tam olarak benimsendiğinde, kimlik doğrulama güvenliğinde hangi yeni tehditler ortaya çıkabilir?
6. Kurumsal ortamda hem parola hem de passkey'in aynı anda kullanılması (hibrit model) ne tür sorunlara yol açabilir?

Kaynaklar

1. FIDO Alliance. (2024). *Passkeys: The Future of Authentication*. Fast Identity Online Alliance. <https://fidoalliance.org/passkeys/>
 2. NIST. (2025). *SP 800-63B-4: Digital Identity Guidelines — Authentication and Authenticator Management*. National Institute of Standards and Technology.
 3. CISA. (2023). *Passkeys: What They Are and Why They Matter*. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/news-events/news/passkeys-what-they-are-and-why-they-matter>
 4. W3C. (2021). *Web Authentication: An API for Accessing Public Key Credentials Level 2*. World Wide Web Consortium. <https://www.w3.org/TR/webauthn-2/>
 5. FIDO Alliance. (2024). *FIDO2 Technical Specifications*. <https://fidoalliance.org/fido2/>
 6. Google. (2023). *The Future of Passkeys*. Google Security Blog.
 7. Apple. (2023). *iCloud Keychain and Passkeys*. Apple Platform Security Guide.
 8. Microsoft. (2023). *Windows Hello and Passkeys*. Microsoft Learn Documentation.
 9. ENISA. (2023). *Threat Landscape for Identity and Access Management*. European Union Agency for Cybersecurity.
 10. OWASP. (t.y.). *Authentication Cheat Sheet*. Open Worldwide Application Security Project.
-
-

BÖLÜM 9 – PAROLA YÖNETİCİLERİ

[↪ İçindekilere dön](#)

Amaç

Bu bölümün amacı, parola yöneticilerinin kavramsal çerçevesini, teknik yapısını, kurumsal uygulamalarını ve kullanıcı benimseme süreçlerini kapsamlı biçimde ele almaktır. Parola yöneticileri, parola güvenliğinin pratikte uygulanabilir hale getirilmesinde kritik bir araçtır. Benzersiz, uzun ve karmaşık parolalar üretme ve yönetme yükünü kullanıcıdan alarak hem güvenlik hem de kullanıcı deneyimini aynı anda iyileştiren parola yöneticileri, modern kimlik doğrulama stratejisinin vazgeçilmez bir bileşenidir.

Araştırma Soruları

1. Parola yöneticisi nedir ve nasıl çalışır?
2. Parola yöneticisi kullanmanın güvenlik avantajları nelerdir?
3. Ana parola (master password) güvenliği nasıl sağlanır?
4. Kurumsal parola yönetimi nasıl uygulanır?
5. Parola yöneticisi seçimi için hangi kriterler dikkate alınmalıdır?
6. Kullanıcıların parola yöneticilerine olan güveni nasıl artırılır?

9.1 Parola Yöneticisi Kavramı ve Avantajları

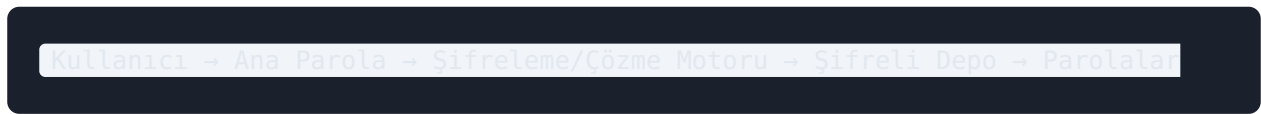
9.1.1 Tanım ve Çalışma Prensipleri

Parola yöneticisi, kullanıcının tüm dijital hesap bilgilerini (kullanıcı adı, parola, security soruları, notlar) güvenli bir şekilde depolayan, yöneten ve gerektiğinde otomatik olarak dolduran bir yazılım uygulamasıdır.

Parola yöneticilerinin temel çalışma prensibi şöyledir:

1. **Depolama:** Tüm parolalar, güçlü bir şifreleme (genellikle AES-256) ile şifrlenerek depolanır
2. **Erişim:** Kullanıcı, ana parola (master password) ile depoya erişir
3. **Otomatik Doldurma:** Web sitelerinde ve uygulamalarda parolaları otomatik olarak doldurur
4. **Parola Üretimi:** Benzersiz ve karmaşık parolalar üretir
5. **Senkronizasyon:** Farklı cihazlar arasında güvenli senkronizasyon sağlar

Parola yöneticileri, genellikle şu mimaride çalışır:



Kullanıcı ana parolayı girdiğinde, şifreleme motoru ana paroladan türetilen bir anahtarla (genellikle PBKDF2, Argon2 veya scrypt kullanılarak) depodaki verileri çözer. Ana parola depoda saklanmaz; sadece kullanıcının cihazında tutulan şifreleme anahtarı olarak işlev görür.

9.1.2 Parola Yöneticisi Türleri

Tarayıcı Tabanlı Parola Yöneticileri: - Chrome, Firefox, Safari ve Edge'in yerleşik parola yöneticileri - Tarayıcı ekosistemiyle entegre - Ücretsiz ve kullanımı kolay - Sınırlı özellik seti ve çapraz platform desteği - Tarayıcı tedarikçisine bağımlılık

Bağımsız Parola Yöneticileri: - Bulut tabanlı, yerel kasa veya kurumsal yönetimli parola yöneticileri - Çapraz platform desteği - İleri düzey özellikler (aile/kurumsal paylaşım, acil erişim, güvenlik raporları) - Genellikle abonelik modeli - Bağımsız güvenlik denetimleri

İşletim Sistemi Tabanlı: - Apple Keychain, Windows Credential Manager, GNOME Keyring - İşletim sistemiyle derin entegrasyon - Sınırlı çapraz platform desteği - Donanım entegrasyonu (Face ID, Touch ID, Windows Hello)

Kurumsal Parola Yöneticileri: - CyberArk, BeyondTrust, Thycotic (Delinea) - Privileged Access Management (PAM) odaklı - Yetkilendirme ve denetim günlükleri - JIT (Just-In-Time) erişim - Kurumsal kimlik doğrulama entegrasyonu

9.1.3 Güvenlik Avantajları

Parola yöneticisi kullanmanın sunduğu temel güvenlik avantajları:

Avantajı	Açıklama
Benzersiz Parola	Her hesap için farklı parola kullanımı
Uzun Parola	20+ karakter uzunluğunda parolalar
Karmaşıklık	Büyük/küçük harf, rakam, özel karakter kombinasyonu
Kimlik avı riskini azaltma	Otomatik doldurma alan adı eşleşmesini görünür kılar; ürün ve yapılandırmaya bağlıdır
Kimlik bilgisi doldurmaya karşı koruma	Her hesap farklı parola kullandığında çapraz hizmet etkisi azaltılır
Brute Force Direnci	Uzun ve karmaşık parolalar brute force'a karşı dayanıklıdır
Parola Güvenliği Analizi	Zayıf, tekrar eden veya sızıntıya uğramış parolaları tespit eder
Alan adı farkındalığı	Beklenmeyen alan adında kasanın eşleşmemesi kullanıcıya uyarı işareti sağlayabilir

9.1.4 Etkinlik Ölçümü

Pazarlama raporlarındaki kullanıcı ve parola sayıları örneklem, ürün ve yıla göre değiştiği için kontrol etkinliğini tek başına kanıtlamaz. Kurumlar parola yöneticisi programını şu ölçütlerle değerlendirmelidir:

- Yönetilen hesaplarda benzersiz parola oranı
- Otomatik ve rastgele parola üretimi kullanım oranı
- MFA ve kasa kurtarma kapsamı
- Ayrıcalıklı sırların kullanıcı kasalarından ayrıştırılması
- Eski çalışan/cihaz erişiminin iptal süresi
- Destek olayları ve doğrulanmış tekrar kullanım bulguları

9.2 Benzersiz Parola Üretimi

9.2.1 Parola Üretme Algoritmaları

Parola yöneticileri, kriptografik olarak güvenli rastgele sayı üreteçleri (CSPRNG) kullanarak parola üretir. Bu üreteçler, tahmin edilemez ve tekrarlanmaz parolalar oluşturur.

Temel Parola Üretme Parametreleri:

- **Uzunluk:** Parola karakter sayısı (genellikle 12-64 arası)
- **Karakter Seti:** Büyük harf (A-Z), küçük harf (a-z), rakamlar (0-9), özel karakter (!@#\$%^&*)
- **Algoritma:** Kriptografik olarak güvenli rastgele sayı üretimi

Parola Gücü Hesaplama:

Parola uzunluğu ve karakter seti arttıkça parola uzayının (brute force deneme sayısı) boyutu üstel olarak artar:

- 8 karakter, sadece küçük harf: $26^8 \approx 208$ milyar deneme
- 12 karakter, tüm karakterler: $94^{12} \approx 4.7 \times 10^{23}$ deneme
- 16 karakter, tüm karakterler: $94^{16} \approx 4.0 \times 10^{31}$ deneme

Rastgele üretilmiş uzun parolalarda tahmin uzayı hızla büyür. Bununla birlikte insan seçimi, parola tekrar kullanımı ve öngörülebilir kalıplar bu matematiksel uzayı küçülttüğünden yalnızca karakter sayısına dayanarak "kırılmaz" sonucu çıkarılamaz.

9.2.2 Parola Gücü Değerlendirme Ölçütleri

Parola yöneticileri genellikle parola gücünü aşağıdaki faktörlere göre değerlendirir:

Ölçüt	Açıklama	Eşik Değeri
Uzunluk	Karakter sayısı	Minimum 12
Çeşitlilik	Karakter seti çeşitliliği	En az 3 farklı set
Entropi	Rastgelelik düzeyi	Minimum 60 bit

Ölçüt	Açıklama	Eşik Değeri
Sızıntı Kontrolü	Have I Been Pwned veritabanı	Eşleşmemeli
Tekrar Kontrolü	Diğer parolalarla benzerlik	Benzersiz olmalı
Tahmin Edilebilirlik	Sözlük/güvenlik sorusu benzerliği	Olmamalı

9.2.3 Şifre Sözcük Frazları (Passphrases)

Parola ifadeleri (passphrase), birden fazla kelimededen oluşan uzun parolalardır. Sözcükler geniş bir listeden bağımsız ve rastgele seçilmelidir; kullanıcı tarafından kurulan anlamlı cümleler aynı güvenceyi vermez.

Avantajları: - İnsan tarafından hatırlanabilir - Uzun oldukları için yüksek entropi sağlar - Brute force'a karşı dayanıklıdır - Kullanıcılar tarafından daha kolay kabul edilir

Dezavantajları: - Kelime seçiminde insan önyargısı devreye girer - Dil bilen saldırganlar tarafından dictionary attack ile kırılabilir - Otomatik üretilen rastgele parolalardan daha zayıf olabilir

Parola yöneticileri, passphrase üretmek için belirli bir listeden rastgele kelimeler seçebilir. Ölçülebilir tahmin direnci, liste büyüklüğü, kelime sayısı ve seçimin gerçekten rastgele olmasına bağlıdır.

9.3 Ana Parola ve MFA ile Koruma

9.3.1 Ana Parola (Master Password) Kavramı

Ana parola, parola yöneticisinin şifreli deposuna erişim anahtarıdır. Tüm parolalar bu tek parola ile şifrelenir ve çözülür. Bu nedenle ana parola, parola yöneticisinin en kritik güvenlik bileşenidir.

Ana Parola Gereksinimleri:

Gereksinim	Açıklama
Uzunluk	Minimum 16 karakter, tercihen 20+

Gereksinim	Açıklama
Karmaşıklık	Tüm karakter setlerini içermeli
Benzersizlik	Hiçbir başka yerde kullanılmamış olmalı
Tahmin Edilemezlik	Sözlük saldırılarına karşı dayanıklı olmalı
Hatırlanabilirlik	Kullanıcı tarafından ezberlenebilir olmalı
Saklanmama	Hiçbir yere yazılmamalı veya kaydedilmemeli

9.3.2 Ana Parola Koruma Mekanizmaları

Key Derivation Functions (KDF):

Ana parola, doğrudan şifreleme anahtarı olarak kullanılmaz. Bunun yerine, bir anahtar türetme fonksiyonu (KDF) ile anahtar üretilir. Bu süreç, çevrim dışı parola tahmininin maliyetini artırır.

Kullanılan KDF'ler: - **PBKDF2** (Password-Based Key Derivation Function 2): NIST tarafından önerilen, 600.000+ iterasyon - **Argon2id**: Memory-hard fonksiyon, GPU/ASIC saldırılarına karşı dirençli - **scrypt**: Memory-hard fonksiyon

Sıcak ve Soğuk Depolama: - Sıcak depolama: RAM'de tutulan, sadece kullanımda aktif olan şifreli veri - Soğuk depolama: Diskte tutulan, kapalı depo - Ana parola girildiğinde soğuk depo çözülür ve sıcak depoya aktarılır

9.3.3 Ana Parola ile MFA Kombinasyonu

Ana parolanın tek başına yeterli olmadığı durumlar: - Ana parola sızıntısı (keylogger, shoulder surfing) - Ana parola zayıflığı (tahmin edilebilir) - Cihaz ele geçirilmesi

Bu nedenle parola yöneticilerinin MFA ile korunması kritik öneme sahiptir.

Parola Yöneticisi için Uygun MFA Yöntemleri:

MFA Yöntemi	Uygunluk	Açıklama
FIDO2/WebAuthn	Yüksek	Ana parola + donanım anahtarı
TOTP	Yüksek	Ana parola + authenticator uygulaması

MFA Yöntemi	Uygunluk	Açıklama
Biyometrik	Yüksek	Ana parola + parmak izi/ yüz tanıma
SMS	Düşük	Ana parola + SMS kodu (zayıf)
E-posta	Düşük	Ana parola + e-posta kodu (zayıf)

En İyi Uygulama: Ana parola + FIDO2 donanım anahtarı + biyometrik kilitleme kombinasyonu, parola yöneticisi için en yüksek güvenlik seviyesini sağlar.

9.4 Kurumsal Kasa, Paylaşım ve Erişim Denetimi

9.4.1 Kurumsal Parola Kasası

Kurumsal parola kasası, organizasyon içindeki tüm parola ve credential'ların merkezi olarak yönetildiği, şifreli bir depolama sistemidir.

Temel Özellikler: - Merkezi politika yönetimi - Yetkilendirme ve erişim denetimi - Audit trail ve loglama - Acil erişim (break-glass) mekanizması - Entegre kimlik doğrulama (SSO/LDAP/SCIM) - Güvenlik olayı bildirimi

9.4.2 Parola Paylaşım Mekanizmaları

Kurumsal ortamlarda parolaların paylaşılması zaman zaman gereklidir. Güvenli paylaşım mekanizmaları:

Güvenli Parola Paylaşımı: - Şifreli kanal üzerinden paylaşım - Paylaşım süresi sınırı (time-limited sharing) - Kullanım sonrası otomatik iptal - Paylaşım logları ve denetim - Roll-back imkanı

Hatalı Paylaşım Önleme: - Düz metin paylaşımının engellenmesi - E-posta, mesajlaşma uygulamalarında otomatik algılama - Ekran görüntüsü alma engeli (DRM koruması) - İzin düzeyine göre paylaşım kısıtlamaları

9.4.3 Erişim Denetim Modelleri

Kurumsal parola yönetiminde kullanılan erişim denetim modelleri:

RBAC (Role-Based Access Control): - Roller tanımlanır (yönetici, kullanıcı, misafir) - Her role belirli parola klasörlerine erişim izni verilir - Rol değişikliklerinde otomatik erişim güncellenir

ABAC (Attribute-Based Access Control): - Kullanıcı özellikleri, zaman, konum gibi dinamik özelliklere göre erişim - Daha esnek ve detaylı kontrol - Zero Trust uyumlu

JIT (Just-In-Time) Erişim: - Parolalara sadece gerektiğinde ve belirli süre için erişim - Onay workflows - Otomatik revokasyon - Minimum ayrıcalık ilkesi

9.4.4 Erişim Kontrol Matrisi

Rol	Kişisel Parolalar	Departman Parolaları	Kritik Sistem Parolaları	Admin Parolaları
Sıradan Kullanıcı	Tam	Sadece okuma	Yok	Yok
Departman Yöneticisi	Tam	Tam	Sadece okuma	Yok
IT Yöneticisi	Tam	Tam	Tam	Sadece okuma
Sistem Yöneticisi	Tam	Tam	Tam	Tam
Güvenlik Yöneticisi	Tam	Tam	Tam + Audit	Tam + Audit
Misafir	Yok	Yok	Yok	Yok

9.5 Acil Erişim ve Hesap Devri

9.5.1 Acil Erişim (Break-Glass) Mekanizması

Acil erişim, normal erişim yollarının kullanılamadığı durumlarda kritik sistemlere erişim sağlama mekanizmasıdır. Bu mekanizma, parola yönetimi açısından kritik öneme sahiptir.

Acil Erişim Senaryoları: - Ana parola sahibinin erişilememesi (hastalık, seyahat, ayrılma) - Güvenlik olayı müdahalesi - Sistem arızası ve felaket kurtarma - Kritik iş süreçlerinin sürekliliği

Acil Erişim Prensipleri: 1. **Minimum ayrıcalık:** Acil erişim sadece gerekli kapsamda olmalı 2. **Çoklu onay:** İki veya daha fazla yetkili kişinin onayı 3. **Zaman kısıtlaması:** Acil erişim belirli süre ile sınırlı 4. **Loglama:** Tüm acil erişim işlemleri kaydedilmeli 5. **Düzenli test:** Acil erişim süreçleri periyodik olarak test edilmeli

9.5.2 Acil Erişim Uygulama Adımları

1. **Fiziksel kasa:** Acil durum şifreleri fiziksel kasada tutulur
2. **Çoklu anahtar:** Kasayı açmak için birden fazla yetkili kişiden anahtar gereklidir
3. **Zaman damgası:** Her açma işlemi zaman damgasıyla kaydedilir
4. **Bildirim:** Acil erişim tetiklendiğinde güvenlik ekibi otomatik olarak bilgilendirilir
5. **Değerlendirme:** Acil erişim sonrası kullanım değerlendirilir

9.5.3 Hesap Devri (Account Handover)

Personel değişikliklerinde hesap devri süreci:

Personel Ayrılma Süreci: 1. Ayrılma bildirimi (İK tarafından) 2. Erişimin derhal devre dışı bırakılması 3. Paylaşılan parolaların değiştirilmesi 4. Yeni sorumlu kişiye hesap devri 5. Devir sürecinin dokümente edilmesi

Hesap Devri Matrisi:

Durum	Aksiyon	Sorumluluk	Süre
Gönüllü ayrılma	Hesap devri + parola değişikliği	IT + İK	3 iş günü
Zorunlu ayrılma	Derhal erişim kesme	IT	Anında
Emeklilik	Hesap devri + knowledge transfer	IT + Departman	2 hafta
Departman değişikliği	Erişim güncelleme	IT + Eski/Yeni yönetici	1 hafta

Durum	Aksiyon	Sorumluluk	Süre
Geçici ayrılık (izin)	Geçici yetki devri	Departman yöneticisi	İzin süresi

9.5.4 Bilgi Sürekliliği

Kritik hesap parolalarının bir kişiye bağımlı olmaması için:

- **Dual ownership:** Her kritik hesabın en az iki sorumlusu olmalı
- **Düzenli rotasyon:** Kritik parolalar periyodik olarak değiştirilmeli
- **Dokümantasyon:** Hesap bilgileri güvenli bir şekilde dokümente edilmeli
- **Kurumsal kasada saklama:** Tüm kritik parolalar kurumsal parola kasasında tutulmalı

9.6 Tedarikçi Seçimi Kriterleri

9.6.1 Güvenlik Kriterleri

Kriter	Açıklama	Değerlendirme
Şifreleme Standardı	AES-256 veya eşdeğeri	Zorunlu
Sıfır Bilgi Mimarisi	Sağlayıcı parolaları okuyamaz	Yüksek öncelik
MFA Desteği	FIDO2, TOTP, biyometrik	Zorunlu
KDF	Argon2 veya PBKDF2 (600K+ iterasyon)	Yüksek öncelik
Denetim Raporları	SOC 2 Type II, ISO 27001	Yüksek öncelik
Açık Kaynak	Kod incelemeye açık	Tercih
Güvenlik Açığı Politikası	Sorumlu ifşa politikası	Zorunlu
Penetrasyon Testi	Düzenli bağımsız testler	Yüksek öncelik

9.6.2 Fonksiyonel Kriterler

Kriter	Açıklama
Çapraz Platform	Windows, macOS, Linux, iOS, Android, tarayıcılar
Otomatik Doldurma	Web sitesi ve uygulama entegrasyonu
Parola Üretimi	Özelleştirilebilir parametreler
Güvenli Paylaşım	Ekip/şirket içi paylaşım
Acil Erişim	Break-glass mekanizması
Denetim Günlükleri	Kapsamlı erişim ve işlem logları
SSO Entegrasyonu	SAML, OIDC, LDAP desteği
API Desteği	Otomasyon ve entegrasyon

9.6.3 Operasyonel Kriterler

Kriter	Açıklama
Uptime SLA	%99.9+ çalışma süresi
Veri Merkezi Konumu	Coğrafi gereksinimlere uygunluk
Destek Seviyesi	7/24 teknik destek
Fiyatlandırma	Ölçeklenebilir fiyat modeli
Kullanıcı Eğitimi	Eğitim materyalleri ve destek
Veri Taşınabilirliği	Veri export/import yetenekleri
Vendor Lock-in	Düşük bağımlılık

9.6.4 Popüler Parola Yöneticileri Karşılaştırması

Özellik	Bitwarden	1Password	KeePassXC	LastPass
Açık Kaynak	Evet	Hayır	Evet	Hayır

Özellik	Bitwarden	1Password	KeePassXC	LastPass
Fiyat (kişi/ay)	Ücretsiz / \$3+	\$3+	Ücretsiz	Ücretsiz / \$3+
Çapraz Platform	Tam	Tam	Kısmi	Tam
Kurumsal Desteği	Evet	Evet	Hayır	Evet
Hosting	Bulut / Self-host	Bulut	Yerel	Bulut
Zero-Knowledge	Evet	Evet	Evet	Evet
MFA	FIDO2, TOTP	FIDO2, Secret Key	FIDO2	FIDO2
Paylaşım	Koleksiyon, grup	Aile, ekip	Sınırlı	Klasör

9.7 Kullanıcı Eğitimi ve Benimseme

9.7.1 Benimseme Zorlukları

Parola yöneticisi benimsemesinde karşılaşılan en yaygın zorluklar:

1. **Değişime direnç:** Kullanıcılar mevcut alışkanlıklarını değiştirmek istemez
2. **Teknoloji korkusu:** Teknik olmayan kullanıcılar yeni bir araç öğrenmekten çekinir
3. **Güven endişesi:** Tüm parolaları tek bir yere koyma korkusu
4. **Erişilebilirlik kaygısı:** Parola yöneticisine erişilemezse ne olacağı endişesi
5. **Ekstra adım algısı:** Her oturum açmada ekstra işlem gerektirmesi
6. **Kurumsal destek eksikliği:** IT departmanının yeterli destek sunmaması

9.7.2 Eğitim Stratejisi

Eğitim Programı Bileşenleri:

Bileşen	Hedef Kitle	Yöntem	Süre
Temel eğitim	Tüm kullanıcılar	Online video + demo	30 dk
İleri düzey	Güvenlik ekibi	Atölye çalışması	2 saat
Yönetici eğitimi	Departman yöneticileri	Birebir oturum	1 saat
Help desk eğitimi	Destek ekibi	Hands-on training	4 saat
Periyodik hatırlatma	Tüm kullanıcılar	E-posta + intranet	Aylık

Eğitim İçeriği: - Neden parola yöneticisi kullanmalıyız? - Ana parola nasıl seçilir ve korunur? - Parola yöneticisi nasıl kullanılır? - Güvenli parola paylaşımı nasıl yapılır? - Acil durum senaryoları ve kurtarma - Sık karşılaşılan sorunlar ve çözümler

9.7.3 Benimsemeyi Teşvik Etme Stratejileri

Yönetici Desteği: - Üst yönetimin aktif katılımı ve desteği - Politika olarak zorunlu kılınması - Departman bazlı hedefler ve ölçüm

Kullanıcı Deneyimi İyileştirmeleri: - Basit ve sezgisel arayüz seçimi - İlk kurulumda rehberlik - Otomatik doldurma ile friction'ı azaltma - Biyometrik kilit desteği

Teşvik ve Ödül: - Erken benimseyenlere tanınma - Departmanlar arası yarışma - Güvenlik olayı azalmasının paylaşılması

Devamlılık: - Düzenli kullanım raporları - Kullanıcı geri bildirim döngüsü - Sürekli eğitim ve hatırlatma

9.7.4 Benimseme Metrikleri

Metrik	Hedef Değer	Ölçüm
Benimseme oranı	>%90 (6 ay içinde)	Kurulum istatistikleri
Aktif kullanım oranı	>%80	Günlük/haftalık aktif kullanıcı
Parola yeniden kullanım oranı	<%5	Parola analizi raporu
Ortalama parola uzunluğu	>16 karakter	Parola analizi raporu
Kullanıcı memnuniyeti	>%75	Anket

Metrik	Hedef Değer	Ölçüm
Help desk çağrısı	Azalma eğilimi	Çağrı istatistikleri

9.8 Yetkilendirme Matrisi

9.8.1 Yetkilendirme Matrisi Tasarımı

Kurumsal parola yönetiminde yetkilendirme matrisi, hangi kullanıcının hangi parolalara erişebileceğini tanımlayan kapsamlı bir çerçevedir.

Matris Tasarım Prensipleri: - Minimum ayrıcalık (least privilege) ilkesi - Need-to-basis (gereklilik esası) - Separation of duties (görev ayrımı) - Denetlenebilirlik

9.8.2 Örnek Yetkilendirme Matrisi

Hedef	Kullanıcı (Bireysel)	Takım Lideri	Departman Yöneticisi	IT Yöneticisi	Güvenlik Yöneticisi
Kişisel Parolalar	RWD	R	R	-	-
Takım Parolaları	R (atanmış)	RWD	RWD	R	R
Departman Parolaları	-	R	RWD	R	R
Organizasyonel Parolalar	-	-	R	RWD	RWD
Kritik Sistem Parolaları	-	-	-	RW (onaylı)	RW
Admin Parolaları	-	-	-	RW (JIT)	RW
Denetim Logları	-	-	R (kendi)	R (tümü)	RW

Açıklama: R=Okuma, W=Yazma, D=Silme, -=Erişim Yok, JIT=Just-In-Time (geçici erişim)

9.8.3 Yetkilendirme Akış Süreci

1. **Talep:** Kullanıcı/rol değişikliği talebi
2. **Onay:** Departman yöneticisi + IT onayı
3. **Uygulama:** Yetkilendirme matrisine göre erişim tanımlama
4. **Doğrulama:** İlk oturumda doğru erişim verildiğinin doğrulanması
5. **Denetim:** Periyodik yetkilendirme gözden geçirme
6. **Revokasyon:** İhtiyaç ortadan kalktığında erişim iptali

9.8.4 Yetkilendirme Denetimi

Periyodik Denetim: - Aylık: Otomatik erişim denetimi raporları - Üç aylık: Manuel yetkilendirme gözden geçirme - Yıllık: Kapsamlı denetim ve politika güncelleme

Tetikleyici Tabanlı Denetim: - Personel değişikliği - Organizasyon yapısı değişikliği - Güvenlik olayı - Düzenleyici denetim

Güvenli Anlatım Notu

Parola yöneticileri, parola güvenliğinin en pratik uygulama aracıdır. Benzersiz ve karmaşık parolalar üretme ve yönetme yükünü kullanıcıdan alarak hem güvenlik hem de kullanıcı deneyimini iyileştirir. Ancak parola yöneticisi de ana parola ile korunur, bu nedenle ana parola güvenliği ve MFA entegrasyonu kritik öneme sahiptir. Kurumsal düzeyde, güçlü erişim denetimi, acil erişim mekanizmaları ve personel devir süreçleri parola yönetimi stratejisinin tamamlayıcı bileşenleridir. Doğru tedarikçi seçimi, kapsamlı kullanıcı eğitimi ve sürekli iyileştirme, parola yöneticisi benimsemesinin başarısını belirleyen faktörlerdir. Parola yöneticileri tek başına bir çözüm değil, kapsamlı bir güvenlik stratejisinin önemli bir parçasıdır.

Özet

Parola yöneticileri, modern parola güvenliğinin temel taşıdır. Benzersiz, uzun ve karmaşık parolalar üretme, depolama ve yönetme yükünü kullanıcılardan alarak hem güvenlik hem de kullanıcı deneyimini aynı anda iyileştiren parola yöneticileri, parola yeniden kullanma sorununu kökten çözer. Güçlü bir ana parola ve MFA ile korunan parola yöneticisi, tek bir noktadan tüm dijital hesapların güvenli yönetimini sağlar.

Kurumsal düzeyde, parola yöneticileri kasa, paylaşım ve erişim denetimi mekanizmalarıyla organizasyonel parola güvenliğini merkezi olarak yönetir. Acil erişim ve hesap devri süreçleri, iş sürekliliğini ve personel değişikliklerinde güvenliği sağlar. Tedarikçi seçimi, güvenlik, fonksiyonellik ve operasyonel kriterlere göre çok boyutlu bir değerlendirme gerektirir.

Kullanıcı benimsemesi, parola yöneticisi başarısının en kritik belirleyicisidir. Kapsamlı eğitim programları, yönetici desteği ve kullanıcı deneyimi iyileştirmeleri, benimseme oranlarını artırır. Yetkilendirme matrisi ve periyodik denetimler, parola yönetiminin güvenlik çerçevesini tamamlar. Parola yöneticileri, parolasız kimlik doğrulamaya geçiş sürecinde de kritik bir köprü işlevi görerek, mevcut parola tabanlı sistemlerin güvenliğini artırırken geleceğin kimlik doğrulama çözümlerine hazırlık sağlar.

Kontrol Listesi

- [] Tüm kullanıcılar parola yöneticisi kullanıyor mu?
- [] Ana parola güçlü ve benzersiz mi?
- [] Parola yöneticisinde MFA etkinleştirilmiş mi?
- [] Kurumsal kasa kurulmuş ve yapılandırılmış mı?
- [] Parola paylaşım politikaları tanımlı mı?
- [] Acil erişim mekanizması çalışıyor mu?
- [] Hesap devri süreçleri dokümanite edilmiş mi?
- [] Kullanıcı eğitim programı uygulanıyor mu?
- [] Yetkilendirme matrisi güncel mi?
- [] Düzenli denetim ve raporlama yapılıyor mu?

Tartışma Soruları

1. Tüm parolaları tek bir parola yöneticisinde toplamak, "tüm yumurtaları aynı sepete koymak" anlamına gelmez mi? Bu riski nasıl değerlendirirsiniz?
2. Kurumsal ortamda parola yöneticisi seçerken güvenlik ve kullanıcı deneyimi arasında denge nasıl kurulur?
3. Parola yöneticilerinin sıfır bilgi (zero-knowledge) mimarisi, gerçekten de sağlayıcının parolaları görememesini garanti eder mi? Bu konudaki endişeler nelerdir?
4. Ana parolayı unutan bir kullanıcının parola yöneticisine erişememesi, iş sürekliliği açısından ne tür riskler oluşturur? Bu riski nasıl azaltırsınız?
5. Parola yöneticilerinin gelecekte parolasız kimlik doğrulama ile birlikte rolü nasıl değişebilir?
6. Farklı departmanların farklı parola yöneticisi ihtiyaçları olabilir mi? Tek bir çözüm her ihtiyaca cevap verebilir mi?

Kaynaklar

1. OWASP. (t.y.). *Authentication Cheat Sheet*. Open Worldwide Application Security Project. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
2. NIST. (2025). *SP 800-63B-4: Digital Identity Guidelines — Authentication and Authenticator Management*. National Institute of Standards and Technology.
3. ISO/IEC. (2022). *ISO/IEC 27001:2022 — Information security management systems*. International Organization for Standardization.
4. Bonneau, J., Herley, C., van Oorschot, P. C., & Stajano, F. (2012). The quest to replace passwords. *IEEE Symposium on Security and Privacy*. <https://doi.org/10.1109/SP.2012.44>

BÖLÜM 10 – UYGULAMA GELİŞTİRİCİLER İÇİN GÜVENLİ KİMLİK DOĞRULAMA

↪ İçindekilere dön

Amaç

Bu bölüm, uygulama geliştiricilerin kimlik doğrulama mekanizmalarını güvenli bir şekilde tasarlaması, uygulaması ve sürdürmesi için gerekli bilgi ve becerileri sunmayı amaçlamaktadır. Güvenli kayıt ve giriş ekranı tasarımından oturum yönetimine, token saklamadan rate limiting'e kadar uzanan geniş bir yelpazede, geliştiricilerin bilmesi gereken temel kavramlar ve uygulama örnekleri ele alınmaktadır. Bu bölüm, OWASP (Open Web Application Security Project) kaynaklarına dayanarak, güncel ve pratik bir rehber niteliği taşımaktadır.

Araştırma Soruları

1. Güvenli bir kimlik doğrulama sistemi tasarlarken hangi temel ilkeler göz önünde bulundurulmalıdır?
2. Hata mesajları nasıl tasarlanarak hesap keşfi riski en aza indirilebilir?
3. Token tabanlı kimlik doğrulama yaklaşımları nasıl güvenli bir şekilde uygulanabilir?
4. Oturum yönetimi süreçlerinde hangi güvenlik önlemleri alınmalıdır?
5. Risk tabanlı doğrulama (adaptive authentication) nasıl uygulanabilir?
6. Güvenli loglama süreçleri nasıl tasarlanmalıdır?

10.1 Güvenli Kayıt ve Giriş Ekranı Tasarımı

Kimlik doğrulama süreçlerinin güvenliği, kullanıcı arayüzünün tasarımından başlamaktadır. Güvenli bir kayıt ve giriş ekranı, hem kullanıcı deneyimini iyileştirmesi hem de güvenlik açıklarını en aza indirmesi gereken kritik bir bileşendir.

10.1.1 Kayıt (Registration) Sürecinin Güvenliği

Kayıt sürecinde dikkat edilmesi gereken temel güvenlik ilkeleri şunlardır:

E-posta Doğrulama: Kullanıcının sağladığı e-posta adresinin geçerliliği ve kullanıcının bu adrese erişimi, kayıt sürecinin en kritik adımlarından biridir. Tek kullanımlık doğrulama bağlantıları (single-use verification links) kullanılarak, sahte e-posta adresleriyle hesap açılması engellenebilir. Bu bağlantılar belirli bir süre geçerli olmalı ve yalnızca bir kez kullanılmalıdır.

Parola Güçlendirme Zorunluluğu: Kayıt sırasında belirlenen parola, sistem tarafından kabul edilen minimum güvenlik kriterlerini karşılamalıdır. Bu kriterler; uzunluk, karakter çeşitliliği ve zayıf parola listeleriyle karşılaştırma gibi parametreleri içermelidir. Ancak aşırı kısıtlayıcı kurallar, kullanıcıları tahmin edilebilir parolalara yöneltme riskini taşımaktadır. Güncel NIST (National Institute of Standards and Technology) önerileri, uzunluğa odaklanan ve aşırı karmaşıklık gereksinimlerinden kaçınan bir yaklaşımı benimsemektedir.

CAPTCHA ve Bot Koruması: Otomatik hesap açma saldırılarını önlemek için CAPTCHA veya benzeri doğrulama mekanizmaları kullanılmalıdır. Ancak bu mekanizmaların kullanıcı deneyimini olumsuz etkilememesi için dengeli bir yaklaşım benimsenmelidir.

Çoklu Hesap Oluşturma Engelleme: Aynı kullanıcı tarafından birden fazla hesap oluşturulmasını önlemek için, IP tabanlı, parmak izi (fingerprinting) tabanlı veya davranışsal analiz tabanlı yöntemler uygulanabilir. Ancak bu tür kısıtlamaların meşru kullanıcıları engellememesi için dikkatli bir denge kurulmalıdır.

10.1.2 Giriş (Login) Ekranının Güvenliği

Giriş ekranı, saldırılara en açık noktalardan biridir ve tasarımında aşağıdaki ilkelere uyulmalıdır:

Kullanıcı Adı ve Parola Alanları: Parola alanı, tarayıcının otomatik doldurma (autofill) özelliğini desteklemeli ancak hassas verilerin sızmasını önleyecek şekilde tasarlanmalıdır. `autocomplete` özneteliklerinin doğru kullanımı bu bağlamda önemlidir.

Brute-Force Koruması: Sistemin tahminleme saldırılarına karşı korunması için, başarısız giriş denemelerinin kontrollü bir şekilde kısıtlanması gerekmektedir. Bu kısıtlama, hesap kilitleme (account lockout), geçici yavaşlatma (throttling) veya CAPTCHA tetikleme gibi farklı stratejilerle uygulanabilir.

MFA Entegrasyonu: İki faktörlü kimlik doğrulama (2FA) veya çok faktörlü kimlik doğrulama (MFA), giriş sürecinin ayrılmaz bir parçası olarak entegre edilmelidir. FIDO2/WebAuthn tabanlı anahtarlıklar, SMS tabanlı kodlardan daha güvenli bir alternatif sunmaktadır.

HTTPS Zorunluluğu: Kimlik doğrulama sayfalarında HTTPS kullanımı mutlaka zorunlu kılınmalıdır. HSTS (HTTP Strict Transport Security) header'ları, protokol downgrade saldırılarını önlemek için yapılandırılmalıdır.

10.2 Tutarlı Hata Mesajları ve Hesap Keşfi Riski

Kimlik doğrulama hataları, saldırılara karşı en hassas bilgi kaynaklarından birini oluşturmaktadır. Yanlış tasarlanmış hata mesajları, saldırganların geçerli kullanıcı adlarını veya e-posta adreslerini keşfetmesine olanak tanıyabilir.

10.2.1 Hesap Keşfi (Account Enumeration) Saldırısı

Hesap keşfi, bir saldırganın belirli bir kullanıcının sistemde kayıtlı olup olmadığını tespit etmeye yönelik bir tekniktir. Bu tür saldırılar genellikle kimlik doğrulama hatalarının farklılaşmasından faydalanır.

Örnek Senaryo: Bir kullanıcı "kullanici@ornek.com" adresiyle giriş yapmaya çalıştığında, sistem "Bu e-posta adresiyle kayıtlı hesap bulunamadı" mesajı döndürürse, saldırgan bu e-posta adresinin sistemde kayıtlı olmadığını anlayabilir. Ters durumda, "Hatalı parola" mesajı döndürülmesi, e-posta adresinin geçerli olduğunu ima eder.

10.2.2 Güvenli Hata Mesajı Tasarımı

Güvenli bir hata mesajı stratejisi şu prensiplere dayanmalıdır:

Durum	Güvenli Mesaj	Riskli Mesaj
Geçersiz kullanıcı + geçersiz parola	"Kullanıcı adı veya parola hatalı."	"Bu kullanıcı adı bulunamadı."
Geçerli kullanıcı + hatalı parola	"Kullanıcı adı veya parola hatalı."	"Parola hatalı."
Hesap kilitlendi	"Çok fazla deneme. Lütfen daha sonra tekrar deneyin."	"Hesap 3 başarısız deneme sonrası kilitlendi."
E-posta doğrulama	"Doğrulama e-postası gönderildi."	"Bu e-posta adresi zaten kayıtlı."

Tüm kimlik doğrulama hatalarının aynı mesajı döndürmesi, zamanlamalı (timing) saldırıların da önüne geçebilir. Ancak bu tür saldırılar, farklı yanıt süreleriyle bilgi sızdırabilir; bu nedenle yanıt sürelerinin tutarlılaştırılması da önemlidir.

10.2.3 Zamanlama (Timing) Saldırıları

Bazı kimlik doğrulama sistemleri, kullanıcı adı ve parola kontrolü arasında farklı süreler harcar. Bu süre farkları, bir saldırganın geçerli kullanıcı adlarını tespit etmesine olanak tanıyabilir. Bu riski azaltmak için:

- Kullanıcı adı ve parola kontrolü her zaman aynı sürede tamamlanmalıdır
- Yanıt süreleri rastgele bir gecikme (jitter) ile maskelenmelidir
- Hata mesajları ve HTTP yanıt kodları tutarlı olmalıdır

10.3 Parola Değiştirme ve Sıfırlama Süreçleri

Parola değiştirme ve sıfırlama süreçleri, kimlik doğrulama güvenliğinin en kritik ve en çok ihmal edilen bileşenlerinden biridir.

10.3.1 Parola Değiştirme (Password Change)

Parola değiştirme süreci, kullanıcının mevcut parolasını bilerek yeni bir parola belirlediği süreçtir. Bu süreçte dikkat edilmesi gereken noktalar:

Kimlik Doğrulama Zorunluluğu: Parola değiştirmeden önce kullanıcının kimliği, mevcut parolasıyla doğrulanmalıdır. Bu, yetkisiz parola değişikliklerini önlemek için zorunlu bir adımdır.

Oturum Geçerliliği: Parola değiştirildiğinde, kullanıcının tüm mevcut oturumlarının sonlandırılması önerilmektedir. Bu, çalınan oturum belirteçlerinin (session tokens) kullanımını engeller.

Parola Geçmiş Kontrolü: Yeni parolanın, belirli bir sayıdaki önceki parola ile aynı olmaması sağlanmalıdır. Bu kontrollerin kriptografik olarak güvenli bir şekilde depolanmış parola hash'leri üzerinde yapılması gerekmektedir.

Bildirim Gönderimi: Parola değişikliği gerçekleştirildiğinde, kullanıcıya e-posta veya bildirim yoluyla bilgi verilmelidir. Bu bildirim, yetkisiz değişikliklerin erken tespit edilmesine katkıda bulunur.

10.3.2 Parola Sıfırlama (Password Reset)

Parola sıfırlama süreci, kullanıcının parolasını hatırlayamadığı durumlarda devreye giren bir mekanizmadır. Bu süreç, pek çok güvenlik açığına ev sahipliği yapabilir.

Güvenli Sıfırlama Akışı:

1. Kullanıcı "Parolamı unuttum" bağlantısına tıklar
2. E-posta adresi veya kullanıcı adı girilir
3. Sistem, kayıtlı kullanıcıya tek kullanımlık sıfırlama bağlantısı gönderir
4. Bağlantı belirli bir süre geçerlidir (örn. 24 saat)
5. Kullanıcı yeni parolasını belirler
6. Tüm aktif oturumlar sonlandırılır
7. Kullanıcıya değişiklik bildirimi gönderilir

Kritik Güvenlik Kuralları:

- Sıfırlama bağlantısı tek kullanımlık olmalıdır
- Bağlantı belirli bir süre sonra geçersiz olmalıdır
- Bağlantıda kriptografik olarak güvenli rastgele belirteç (token) kullanılmalıdır
- Sıfırlama süreci, hesap keşfi saldırılarına karşı korunmalıdır
- Sıfırlama bağlantısı URL'sinde hassas bilgi (kullanıcı ID gibi) açık metin olarak yer almamalıdır

10.3.3 Parola Sıfırlama Akış Diyagramı

Aşağıdaki diyagram, güvenli bir parola sıfırlama akışını göstermektedir:



10.4 Token Yaklaşımı: Tek Kullanımlık, Süreli, Güvenli Saklama

Token tabanlı kimlik doğrulama, modern web uygulamalarında en yaygın kullanılan yöntemlerden biridir. Token'ların güvenli bir şekilde oluşturulması, saklanması ve doğrulanması, kimlik doğrulama sisteminin güvenliğini doğrudan etkiler.

10.4.1 Token Türleri

Tek Kullanımlık Tokenlar (One-Time Tokens): Parola sıfırlama, e-posta doğrulama ve benzeri süreçlerde kullanılan tokenlardır. Kullanıldıktan sonra geçersiz hale gelirler. Bu tokenların rastgele ve kriptografik olarak güvenli olması zorunludur. URL-safe Base64kodlama ile 32 byte veya daha uzun rastgele veri kullanımı önerilmektedir.

Erişim Tokenları (Access Tokens): Kullanıcının kimliğini ve yetkilerini temsil eden, belirli bir süre geçerli olan tokenlardır. JWT (JSON Web Token) formatı bu kategoride en yaygın kullanılan standarttır. Erişim tokenları kısa ömürlü olmalı (örn. 15-30 dakika), yenileme tokenları (refresh tokens) ile desteklenmelidir.

Oturum Tokenları (Session Tokens): Sunucu taraflı oturum yönetimi için kullanılır. Tokenın kendisi hassas bir bilgi içermez; sunucu tarafında oturum verisi saklanır. Bu yaklaşım, tokenın ele geçirilmesi durumunda bile sunucu tarafında kontrol imkanı sağlar.

10.4.2 Token Güvenliği

Rastgelelik (Entropy): Tokenlar, kriptografik olarak güvenli rastgele sayı üreteçleri (CSPRNG) kullanılarak oluşturulmalıdır. Tahmin edilebilir veya düşük entropy'li tokenlar, brute-force saldırılarına karşı savunmasızdır.

Saklama: Tokenlar, yalnızca gerekli olduğu süre boyunca saklanmalıdır. Kullanıcı tarafında tokenların saklanması için: - HttpOnly ve Secure flag'li çerezler (cookie) önerilmektedir - LocalStorage ve sessionStorage kullanımı kaçınılmalıdır (XSS saldırılarına açıktır) - Token'lar URL parametrelerinde yer almamalıdır (log sızıntılarına açıktır)

Süre Sonu (Expiration): Her token belirli bir süre sonra geçersiz olmalıdır. Kısa ömürlü tokenlar, ele geçirilme riskini azaltır. Ancak çok kısa süreler kullanıcı deneyimini olumsuz etkileyebilir; bu nedenle denge önemlidir.

İptal (Revocation): Tokenların gerektiğinde iptal edilebilmesi gerekir. Bu, güvenlik ihlalleri veya kullanıcı çıkışı durumlarında kritik öneme sahiptir. Sunucu taraflı token saklama bu konuda avantaj sağlar.

10.4.3 JWT Güvenliği

JSON Web Token (JWT), iddiaları kompakt biçimde taşıyan bir token formatıdır. İmza bütünlüğü koruyabilir; ancak JWT varsayılan olarak şifreli değildir ve yanlış doğrulama ciddi güvenlik açıklarına yol açabilir:

Güvenlik Konusu	Önerilen Uygulama	Riskli Uygulama
İmza algoritması	RS256 veya ES256 (asimetrik)	HS256 (simetrik, sırrın paylaşımı riskli)

Güvenlik Konusu	Önerilen Uygulama	Riskli Uygulama
"alg" header	Sunucu tarafında doğrulama, "none" algoritmasına izin verme	İstemci tarafından belirlenen algoritmayı kabul etme
Süre	Kısa ömürlü (15-30 dk)	Uzun süreli veya süresiz
İçerik	Minimum gerekli bilgi	Hassas veriler (SSN, parola hash vb.)
Saklama	HttpOnly cookie	LocalStorage / sessionStorage

10.5 Oturum Yönetimi, Session Fixation, Logout Invalidasyon

Oturum yönetimi, kullanıcı oturumlarının güvenli bir şekilde oluşturulması, sürdürülmesi ve sonlandırılmasını kapsayan kritik bir güvenlik bileşenidir.

10.5.1 Oturum Oluşturma

Güvenli oturum oluşturma süreçleri:

Oturum Kimliği (Session ID) Oluşturma: Oturum kimlikleri kriptografik olarak güvenli rastgele sayı üreteçleri ile oluşturulmalıdır. Minimum 128 bit entropy önerilmektedir. Oturum kimlikleri, kullanıcının tarayıcısına çerez (cookie) olarak atanmalıdır ve `HttpOnly`, `Secure`, `SameSite` attributes ile yapılandırılmalıdır.

Oturum Yenileme (Session Renewal): Kimlik doğrulama sonrasında oturum kimliğinin yenilenmesi, fixation saldırılarını önlemek için önemlidir. Kullanıcı giriş yaptığı veya hassas bir işlem yaptığı anda, mevcut oturum kimliği geçersiz kılınarak yeni bir oturum kimliği oluşturulmalıdır.

Oturum Zaman Aşımı (Session Timeout): Oturumlar belirli bir süre sonra otomatik olarak sonlandırılmalıdır. Hem pasif (etkisizlik) hem de mutlak (toplam süre) zaman aşimleri uygulanmalıdır. Örneğin, 15 dakika pasif etkisizlik ve 8 saat mutlak süre.

10.5.2 Session Fixation Saldırısı

Session fixation, bir saldırganın kullanıcının oturum kimliğini önceden belirlediği ve kullanıcının giriş yapmasıyla bu kimliği kullandığı bir saldırı türüdür.

Önleme Yöntemleri:

1. **Oturum Kimliği Yenileme:** Kullanıcı giriş yaptığında, mevcut oturum kimliği geçersiz kılınarak yeni bir oturum kimliği oluşturulmalıdır
2. **Oturum Kimliği Değişikliği:** Kullanıcı oturum açma sayfasından farklı bir sayfaya yönlendirildiğinde oturum kimliği değiştirilmelidir
3. **Önceki Oturum Kimliklerini Geçersiz Kılma:** Yeni bir oturum oluşturulduğunda, kullanıcıya ait önceki tüm oturumlar sonlandırılmalıdır

10.5.3 Güvenli Çıkış (Logout) ve Oturum İptali

Güvenli çıkış süreci, oturum verilerinin sunucu tarafında da temizlenmesini içermelidir:

- Oturum kimliği çerezlerden kaldırılmalıdır
- Sunucu tarafında oturum verisi silinmelidir
- Kullanıcı "Geri" butonuyla oturuma dönememelidir
- Çıkış sonrası yönlendirme güvenli bir sayfaya (giriş sayfası gibi) yapılmalıdır

10.6 Rate Limiting ve Risk Tabanlı Doğrulama

10.6.1 Rate Limiting (Hız Kısıtlama)

Rate limiting, belirli bir süre içinde yapılabilecek istek sayısını sınırlayan bir koruma mekanizmasıdır. Kimlik doğrulama bağlamlarında, brute-force ve credential stuffing saldırılarını önlemek için kritik öneme sahiptir.

Uygulama Stratejileri:

Strateji	Açıklama	Avantaj	Dezavantaj
IP tabanlı	IP adresine göre istek kısıtlama	Basit uygulama	NAT/VPN arkasındaki kullanıcıları etkiler

Strateji	Açıklama	Avantaj	Dezavantaj
Hesap tabanlı	Kullanıcı adına göre kısıtlama	Hedefli koruma	Hesap keşfi riski
CAPTCHA tetikleme	Belirli deneme sonrası CAPTCHA gösterme	Dengeyi korur	Kullanıcı deneyimini etkiler
Hesap kilitleme	Belirli deneme sonrası hesabı geçici kilitleme	Saldırıcıyı doğrudan engeller	Meşru kullanıcıları da etkiler
Uyarlamalı yavaşlatma	Başarısız denemelerle artan gecikme	Dengeyi korur	karmaşık uygulama

10.6.2 Risk Tabanlı Doğrulama (Adaptive Authentication)

Risk tabanlı doğrulama, oturum açma isteğinin risk seviyesine göre farklı doğrulama adımları uygulayan bir yaklaşımdır. Düşük riskli oturum açma denemeleri için basit, yüksek riskli denemeler için ek doğrulama adımları istenir.

Risk Faktörleri:

- **Coğrafi Konum:** Bilinmeyen bir konumdan yapılan istekler yüksek risk olarak değerlendirilir
- **Cihaz Parmak İzi:** Daha önce görülmemiş bir cihazdan yapılan istekler ek doğrulama gerektirebilir
- **Zaman:** Normal kullanıcı davranışından farklı saatlerde yapılan istekler riskli değerlendirilebilir
- **IP Reputation:** Bilinen kötü niyetli IP adreslerinden gelen istekler yüksek risk olarak işaretlenir
- **Davranışsal Analiz:** Kullanıcının normal giriş davranışıyla uyumsuz eylemler risk seviyesini artırır

Uygulama Katmanları:

1. **Düşük Risk:** Normal konum, bilinen cihaz, normal saat → Tek faktörlü doğrulama yeterli
2. **Orta Risk:** Kısmen bilinen bir bağlam → Ek doğrulama (e-posta doğrulama kodu)

3. **Yüksek Risk:** Tamamen bilinmeyen bağlam → Çok faktörlü doğrulama zorunlu
4. **Kritik Risk:** Çoklu risk göstergesi → Oturum reddedildi veya ek manuel doğrulama

10.7 Güvenli Loglama ve Hassas Veri Maskeleyme

Kimlik doğrulama olaylarının güvenli bir şekilde kaydedilmesi, hem güvenlik olaylarının tespitini hem de uyumluluk gereksinimlerini karşılamak için essential bir uygulamadır.

10.7.1 Kayıt Edilmesi Gereken Olaylar

- Başarılı ve başarısız oturum açma denemeleri
- Oturum oluşturma ve sonlandırma olayları
- Parola değiştirme ve sıfırlama işlemleri
- Çok faktörlü kimlik doğrulama denemeleri
- Hesap kilitleme ve açılma olayları
- Yetkilendirme hataları

10.7.2 Hassas Veri Maskeleyme (Masking)

Güvenli loglama, hassas verilerin log dosyalarına kaydedilmemesini veya uygun şekilde maskelenmesini gerektirir:

Veri Türü	Maskelenme Yöntemi	Örnek
Parola	Hiçbir zaman loglanmaz	[MASKED]
Kredi kartı numarası	İlk 6, son 4 hanesi görünür	4532**1234
E-posta adresi	Kısmi maskeleyme	j***@ornek.com
IP adresi	Gerekirse maskeleyme	192.168..
Oturum kimliği	Hashlenmiş olarak loglama	sha256(session_id)
JWT token	Sadece header ve payload, imza maskeli	eyJ...[MASKED]

10.7.3 Log Güvenliği

- Log dosyaları yalnızca yetkili personel tarafından erişilebilir olmalıdır
- Log manipülasyonunu önlemek için salt-read-only erişim veya append-only yapılandırma uygulanmalıdır
- Log dosyaları zaman damgası ve kriptografik imza ile korunmalıdır
- Log yedekleme ve arşivleme süreçleri güvenli bir şekilde planlanmalıdır

10.8 Geliştirici Kontrol Listesi

Aşağıdaki kontrol listesi, uygulama geliştiricilerin kimlik doğrulama güvenliğini sağlamak için kullanabileceği bir rehber niteliğindedir:

Kayıt Süreci

- [] E-posta doğrulama zorunlu kılınmış mı?
- [] Parola güçlülük kontrolleri uygulanıyor mu?
- [] CAPTCHA veya bot koruması aktif mi?
- [] Çoklu hesap oluşturma önlemleri var mı?
- [] Parola hash'i güvenli bir algoritma ile mi saklanıyor?

Giriş Süreci

- [] Hata mesajları tutarlı ve bilgi sızdırmıyor mu?
- [] Rate limiting uygulanıyor mu?
- [] Başarısız denemeler loglanıyor mu?
- [] MFA entegrasyonu mevcut mu?
- [] HTTPS zorunlu mu?
- [] Timing saldırılarına karşı koruma var mı?

Token Yönetimi

- [] Tokenlar kriptografik CSPRNG ile mi oluşturuluyor?
- [] Token süreleri uygun mu?
- [] Tokenlar HttpOnly cookie'de mi saklanıyor?

- [] Token iptali (revocation) desteği var mı?
- [] JWT algoritması güvenli mi?

Oturum Yönetimi

- [] Oturum kimlikleri giriş sonrası yenileniyor mu?
- [] Session fixation önlemleri uygulanıyor mu?
- [] Güvenli çıkış mekanizması var mı?
- [] Oturum zaman aşımı yapılandırılmış mı?
- [] SameSite cookie attribute'ü ayarlı mı?

Loglama

- [] Hassas veriler maskeleniyor mu?
- [] Kimlik doğrulama olayları kaydediliyor mu?
- [] Log dosyaları korumalı mı?
- [] Log manipülasyonu önlemleri var mı?

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenciler:

1. Güvenli kimlik doğrulama sistemi tasarımının temel ilkelerini kavrar
2. Hesap keşfi saldırılarını tanır ve hata mesajı tasarımını buna göre yapabilir
3. Parola değiştirme ve sıfırlama süreçlerinin güvenlik gereksinimlerini analiz edebilir
4. Token tabanlı kimlik doğrulama yaklaşımlarını güvenli bir şekilde uygulayabilir
5. Oturum yönetimi ve session fixation saldırılarına karşı önlemler alabilir
6. Rate limiting ve risk tabanlı doğrulama mekanizmalarını tasarlayabilir
7. Güvenli loglama uygulamalarını gerçekleştirebilir

Risk Modeli

Tehdit	Olasılık	Etki	Risk Seviyesi	Kontrol
Brute-force saldırısı	Yüksek	Yüksek	Kritik	Rate limiting, hesap kilitleme, CAPTCHA
Credential stuffing	Yüksek	Yüksek	Kritik	Rate limiting, risk tabanlı doğrulama
Session fixation	Orta	Yüksek	Yüksek	Oturum yenileme, SameSite cookie
XSS ile token çalma	Orta	Kritik	Kritik	HttpOnly cookie, XSS önlemleri
Hesap keşfi	Yüksek	Orta	Yüksek	Tutarlı hata mesajları
Parola sıfırlama istismarı	Orta	Yüksek	Yüksek	Tek kullanımlık token, süre sınırlaması
Log sızıntısı	Düşük	Kritik	Orta	Maskeleyme, erişim kontrolü

Savunma Kontrolleri

- Tasarım Seviyesi:** OWASP Security Verification Standard (SVS) kontrol gereksinimlerinin uygulanması
- Geliştirme Seviyesi:** Güvenli kodlama kılavuzlarına uygunluk, statik kod analizi
- Test Seviyesi:** Güvenlik testleri, penetrasyon testleri, fuzz testleri
- Operasyon Seviyesi:** Loglama, izleme, alarm mekanizmaları
- Yönetim Seviyesi:** Güvenlik politikaları, eğitim, uyumluluk kontrolleri

Güvenli Anlatım Notu

Bu bölümden sunulan tüm kod örnekleri ve mimari öneriler, yalnızca defansif (koruyucu) amaçlarla verilmiştir. Örnekler, mevcut güvenlik açıklarının anlaşılmasını ve nasıl önlenebileceğini gösteren sentetik (hayali) durumları

içermektedir. Hiçbir saldırı aracı, exploit kodu veya zararlı yazılım örneği sunulmamaktadır. Okuyucular, örnekleri yalnızca kendi sistemlerinin güvenliğini test etmek ve geliştirmek amacıyla kullanmalıdır.

Özet

Uygulama geliştiriciler için güvenli kimlik doğrulama, çok katmanlı bir yaklaşım gerektirir. Güvenli kayıt ve giriş ekranı tasarımı, tutarlı hata mesajları, güvenli token yönetimi, oturum koruması, rate limiting ve loglama gibi bileşenlerin bir bütün olarak ele alınması gerekmektedir. OWASP ve NIST gibi uluslararası standartların takip edilmesi, güncelliğin korunması açısından kritik öneme sahiptir. Geliştiriciler, her bir bileşenin güvenlik risklerini ve karşılık gelen kontrolleri bilerek, güvenli kodlama pratiği geliştirebilirler.

Tartışma Soruları

1. Bir uygulamada "kullanıcı adı veya parola hatalı" mesajı gösterilmesinin, parola yanlışır mesajına göre hangi güvenlik avantajı vardır?
2. JWT imzalamada simetrik (HS256) ve asimetrik (RS256/ES256) algoritma seçimi güven sınırlarını ve anahtar dağıtımını nasıl etkiler?
3. Risk tabanlı doğrulama sistemi tasarlamak için hangi veri kaynakları kullanılabilir?
4. Session fixation saldırısına karşı alınabilecek en etkili önlem nedir ve neden?
5. Parola sıfırlama sürecinde tek kullanımlık token yerine kalıcı bir bağlantı kullanılmasının riskleri nelerdir?

Kaynaklar

1. OWASP. (t.y.). *Authentication Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
2. OWASP. (t.y.). *Session Management Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
3. OWASP. (t.y.). *Forgot Password Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html

4. NIST. (2025). *Digital Identity Guidelines: Authentication and Authenticator Management (SP 800-63B-4)*. National Institute of Standards and Technology.
 5. OWASP. (t.y.). *Proactive Controls*. <https://owasp.org/www-project-proactive-controls/>
 6. RFC 7519. (2015). *JSON Web Token (JWT)*. Internet Engineering Task Force.
 7. RFC 6749. (2012). *The OAuth 2.0 Authorization Framework*. Internet Engineering Task Force.
 8. OWASP. (t.y.). *Application Security Verification Standard (ASVS)*. <https://owasp.org/www-project-application-security-verification-standard/>
-

BÖLÜM 11 – KURUMSAL İZLEME VE TESPİT

[↪ İçindekilere dön](#)

Amaç

Bu bölüm, kurumsal ortamlarda kimlik doğrulama olaylarının izlenmesi, anormal davranışların tespit edilmesi ve güvenlik olaylarına proaktif yanıt verilmesi için gerekli stratejileri ve araçları sunmayı amaçlamaktadır. Kurumsal güvenlik operasyonları merkezleri (SOC) için tasarlanan bu bölüm, olay kaynaklarının belirlenmesinden SIEM korelasyonuna, SOC playbook'larından vaka yönetimine kadar kapsamlı bir rehber sunmaktadır.

Araştırma Soruları

1. Kurumsal kimlik doğrulama izleme sistemleri için hangi olay kaynakları kritik önem taşımaktadır?
2. Başarısız giriş denemeleri nasıl analiz edilerek saldırı tespit edilebilir?
3. İmkânsız seyahat tespiti nasıl çalışır ve hangi veri kaynaklarına ihtiyaç duyar?
4. SIEM korelasyon kuralları nasıl tasarlanır ve önceliklendirilir?
5. SOC ekiplerinin vaka yönetimi süreçleri nasıl yapılandırılmalıdır?

11.1 Kimlik Doğrulama Olay Kaynakları

Etkili bir izleme sistemi, doğru veri kaynaklarının belirlenmesiyle başlar. Kimlik doğrulama olayları, kurum içindeki çeşitli sistem ve uygulamalardan toplanmalıdır.

11.1.1 Birincil Olay Kaynakları

Dizin Hizmetleri: - Microsoft Active Directory olayları (Event ID 4624, 4625, 4776 vb.) - LDAP sorgu ve değiştirme olayları - Grup politikası değişiklikleri - Yetkilendirme değişiklikleri

Uygulama Katmanı: - Web uygulaması kimlik doğrulama günlükleri - API kimlik doğrulama olayları - SSO (Single Sign-On) olayları - OAuth/OpenID Connect token olayları

Ağ Katmanı: - VPN bağlantı logları - RADIUS/TACACS+ kimlik doğrulama olayları - 802.1X kimlik doğrulama olayları - Proxy kimlik doğrulama logları

İşletim Sistemi: - Linux PAM (Pluggable Authentication Module) olayları - Windows Security olayları - Syslog kimlik doğrulama olayları

Bulut Hizmetleri: - Azure AD / Entra ID olayları - AWS IAM olayları - Google Cloud Identity olayları - SaaS uygulama kimlik doğrulama olayları

11.1.2 Olay Formatı ve Zenginleştirme

Ham olay verileri genellikle doğrudan analiz için uygun değildir. Olay zenginleştirme (event enrichment) süreci, aşağıdaki bilgileri eklemeyi kapsar:

- Kullanıcı varlık bilgisi (departman, rol, statü)
- Cihaz varlık bilgisi (işletim sistemi, tarayıcı, güvenlik yazılımı durumu)
- Coğrafi konum bilgisi
- Tehdit istihbaratı verileri (IP reputation, IoC eşleme)
- Risk skoru hesaplama

11.2 Başarısız/Başarılı Giriş Davranış Analizi

Giriş olaylarının analizi, kimlik tabanlı saldırıların tespitinde temel bir bileşendir. Hem başarısız hem de başarılı girişlerin davranışsal analizi, anormal kalıpları ortaya çıkarabilir.

11.2.1 Başarısız Giriş Analizi

Başarısız giriş denemeleri, çok çeşitli nedenlerle gerçekleşebilir: unutilan parolalar, yazım hataları, veya kasıtlı saldırılar. Anlamlı tespit için, başarısız girişlerin bağlamsal olarak analiz edilmesi gerekmektedir.

Temel Metrikler:

Metrik	Normal Aralık	Alarm Eşiği	Açıklama
Saatlik başarısız deneme (kullanıcı başına)	0-2	>5	Bireysel hesap hedefleme
Dakikalık başarısız deneme (IP başına)	0-1	>10	Brute-force kalıbı
Farklı kullanıcı başarısız denemesi (IP başına)	0-1	>3	Credential stuffing kalıbı
Toplam başarısız deneme (sistem geneli)	Dalgalı	%200+ sapma	Genel saldırı kampanyası

Davranışsal Kalıp Tespiti:

- **Sıralı parola denemeleri:** Aynı IP'den farklı kullanıcı adlarıyla yapılan denemeler, credential stuffing saldırısını gösterebilir
- **Yavaş tarama:** Uzun süre boyunca düşük hızda yapılan denemeler, brute-force koruma mekanizmalarını atlatmaya yönelik olabilir
- **Dağıtık saldırılar:** Farklı IP adreslerinden yapılan koordineli denemeler, botnet kaynaklı saldırıları gösterebilir
- **Zamanlı denemeler:** Belirli saat dilimlerinde yoğunlaşan denemeler, iş saatleri dışı aktivite olarak değerlendirilebilir

11.2.2 Başarılı Giriş Analizi

Başarılı girişler de anormal kalıplar gösterebilir:

- **Olağandışı zaman:** Normal çalışma saatleri dışında yapılan girişler
- **Olağandışı konum:** Farklı coğrafi bölgelerden yapılan girişler
- **Olağandışı cihaz:** Daha önce kullanılmamış cihazlardan yapılan girişler
- **Hızlı ardışık girişler:** Kısa süre içinde farklı konumlardan yapılan girişler
- **Yüksek hacimli oturum:** Normalden fazla sayıda eşzamanlı oturum

11.3 Olağandışı Konum, Saat, Cihaz Sinyalleri

Anomaly detection (sapma tespiti), normal davranış kalıplarından sapmaları belirleyerek potansiyel tehditleri erken aşamada tespit eden bir yaklaşımdır.

11.3.1 Konum Tabanlı Anomali Tespiti

Veri Kaynağı: IP adreslerinden türetilen coğrafi konum verileri, GPS verileri veya ağ altyapısı konumları.

Temel Prensipler:

1. **Profil Oluşturma:** Her kullanıcı için normal konum profili, belirli bir süre boyunca toplanan verilerle oluşturulur
2. **Sapma Hesaplama:** Her giriş olayı, kullanıcının normal profiline göre sapma açısından değerlendirilir
3. **Risk Puanlama:** Sapma düzeyine göre bir risk puanı hesaplanır
4. **Eylem Belirleme:** Risk puanına göre farklı eylemler tetiklenir (ek doğrulama, uyarı, hesap kilitleme)

Dikkat Edilmesi Gerekenler: - VPN kullanımı konum verilerini güvenilir hale getirebilir - Roaming kullanıcılar (sık seyahat edenler) için eşik değerlerinin ayarlanması gerekir - Coğrafi olarak yakın konumlar (örn. sınır şehirleri) için tolerans tanınmalıdır - Tor çıkış düğümleri ve proxy sunucuları özel olarak ele alınmalıdır

11.3.2 Zaman Tabanlı Anomali Tespiti

Kullanıcıların giriş davranışları genellikle belirli zaman kalıplarına sahiptir. Ofis çalışanları genellikle iş saatlerinde giriş yaparken, gece yapılması beklenmeyen girişler anomali olarak değerlendirilebilir.

Faktörler: - Kullanıcının normal giriş saatleri - Tatil günleri ve hafta sonları - Farklı saat dilimleri (uzaktan çalışma) - İşletme türüne göre beklenen kalıplar

11.3.3 Cihaz Parmak İzi Tabanlı Anomali Tespiti

Cihaz parmak izi, kullanıcının tarayıcı ve işletim sistemi özelliklerinden türetilen benzersiz bir tanımlayıcıdır.

Toplanan Cihaz Özellikleri: - Tarayıcı türü ve versiyonu - İşletim sistemi ve versiyonu - Ekran çözünürlüğü - Yüklü eklentiler - Dil ve saat dilimi ayarları - Donanım özellikleri (GPU, CPU gibi erişilebilir bilgiler)

Anomali Durumları: - Daha önce görülmemiş bir cihaz parmak izi - Cihaz parmak izinin ani değişmesi - Cihaz parmak izi ile konum uyumsuzluğu

11.4 İmkânsız Seyahat Tespiti

İmkânsız seyahat (impossible travel), aynı kimliğin kısa süre içinde fiziksel olarak bağdaşmayan konumlardan oturum açması sinyalidir. VPN, mobil operatör çıkışları, bulut vekilleri ve hatalı konum verisi yanlış pozitif üretebildiğinden tek başına hesap ele geçirilmesi kanıtı sayılmamalıdır.

11.4.1 Tespit Mekanizması

Temel Hesaplama:

```
İki giriş arasındaki mesafe = f(konum1, konum2)
İki giriş arasındaki süre = t2 - t1
Hız = mesafe / süre
Eğer hız > insan/ulaşım hızı (örn. 1000 km/saat)
    ise → İmkânsız seyahat alarmı
```

Hassasiyet Ayarları:

- İnsanlar için makul seyahat hızı: 900-1000 km/saat (ticari uçaklar)
- Hava yolu trafiği dikkate alınmalı (direkt uçuş rotaları)
- VPN ve proxy kullanımı dikkate alınmalı
- Yanlış pozitif oranları izlenmeli ve eşik değerleri ayarlanmalı

11.4.2 Uygulama Senaryoları

Senaryo 1: Kullanıcı sabah 09:00'da İstanbul'dan, 10:30'da New York'tan giriş yapıyor. Bu, ortalama 1050 km/saat hız gerektirir ve ticari bir uçuşla açıklanabilir. Ancak saat farkı (6 saat) dikkate alındığında, yerel saatle New York'da gece 04:30'da giriş yapılması anormaldir.

Senaryo 2: Kullanıcı saat 14:00'da Ankara'dan, 14:15'te Sidney'den giriş yapıyor. Bu mesafe yaklaşık 15.000 km olup, 15 dakikada bu mesafeyi kat etmek imkânsızdır. Bununla birlikte VPN ve mobil ağ çıkışları ayrıca kontrol edilmelidir.

Senaryo 3: Kullanıcı saat 10:00'da Berlin'den, 10:05'te Münih'ten giriş yapıyor. Bu normal bir tren yolculuğuyla açıklanabilir, ancak cihaz parmak izinin değişmesi ek bir risk göstergesi olabilir.

11.4.3 Yanlış Pozitif Yönetimi

İmkânsız seyahat tespitinin etkinliği, yanlış pozitif oranlarının yönetimiyle doğrudan ilişkilidir:

- VPN kullanıcıları için konum verilerinin güvenilirliği düşüktür
- Havaalanı ve sınır şehirleri için tolerans tanınmalıdır
- Cep telefonu operatörleri arası geçişler konum sıçramalarına neden olabilir
- Uzaktan çalışma senaryoları için profiller ayarlanmalıdır

11.5 MFA Olayları

Çok faktörlü kimlik doğrulama (MFA) olayları, kimlik doğrulama güvenliğinin en kritik veri kaynaklarından birini oluşturmaktadır.

11.5.1 MFA Olay Türleri

Olay Türü	Açıklama	Risk Göstergesi
MFA tetikleme	İkinci faktör isteği gönderildi	Yüksek risk skoru
MFA başarı	İkinci faktör doğrulandı	Düşük risk
MFA başarısız	İkinci faktör hatalı	Orta risk (birden fazla başarısız → yüksek)
MFA bypass	İkinci faktör atlandı	Kritik risk
MFA kaldırma	MFA devre dışı bırakıldı	Kritik risk (dikkatli izleme)
MFA_METHOD_CHANGE	MFA yöntemi değiştirildi	Yüksek risk

Olay Türü	Açıklama	Risk Göstergesi
MFA registration	Yeni MFA yöntemi eklendi	Orta risk (yeni cihaz → yüksek)

11.5.2 MFA İyileşme (MFA Fatigue) Saldırıları

MFA iyileşme, bir saldırganın kullanıcıya sürekli MFA bildirimleri göndererek onu yıldırmayı ve sonunda bildirimi onaylamaya zorlamayı amaçlayan bir saldırı türüdür.

Tespit Göstergeleri: - Kısa süre içinde çoklu MFA tetikleme - Reddedilen veya zaman aşımına uğrayan MFA istekleri - Farklı cihazlardan gelen MFA istekleri - Normalden farklı zaman diliminde MFA istekleri

Önleme: - MFA isteklerinin kullanıcı tarafından onaylanması gereken bir eşik belirleme - Farklı MFA yöntemlerinin eşzamanlı kullanılmasını engelleme - Anormal MFA kalıplarının otomatik olarak engellenmesi - Kullanıcıya MFA bildirimi gönderirken coğrafi konum bilgisi sunma

11.6 SIEM Korelasyon ve Alarm Önceliklendirme

Güvenlik Bilgi ve Olay Yönetimi (SIEM) sistemleri, büyük ölçekli veri kaynaklarından gelen olayları birleştiren, korele eden ve anlamlı bilgiler dönüştüren platformlardır.

11.6.1 Korelasyon Kuralları Tasarımı

Etkili korelasyon kuralları, tek başına anlamsız olan olayları bir araya getirerek anlamlı güvenlik alarmı üretir.

Örnek Korelasyon Senaryoları:

Senaryo 1: Brute-Force Sonrası Başarılı Giriş

Koşul:

5 dakika içinde aynı hesap için >10 başarısız giriş

VE

Ardından başarılı giriş

```

VB
Giris konumu NORMALDE olmayan bir konum
Aksiyon: Yüksek öncelikli alarm, oturum sonlandırma

```

Senaryo 2: MFA Bypass Denemesi

```

Koşul:
Başarılı parola doğrulama
VB
MFA reddedildi veya başarısız >3 kez
VB
Ardından farklı IP'den başarılı oturum
Aksiyon: Kritik öncelikli alarm, hesap kilitleme

```

Senaryo 3: Hesap Ele Geçirme Belirtisi

```

Koşul:
Başarılı giriş (bilinmeyen cihaz + bilinmeyen konum)
VB
30 dakika içinde parola değiştirme
VB
MFA yöntemi değişikliği
Aksiyon: Kritik öncelikli alarm, oturum sonlandırma, kullanıcı bildirimi

```

11.6.2 Alarm Önceliklendirme

Tüm alarmların aynı öncelikte ele alınması, operasyonel verimliliği düşürür ve alarm yorgunluğuna (alert fatigue) neden olur. Etkili önceliklendirme için:

Öncelik Seviyesi	Tanım	Yanıt Süresi	Örnek
Kritik	Doğrudan veri ihlali veya sistem ele geçirme	15 dakika	Hesap ele geçirme, veri sızıntısı
Yüksek	Aktif saldırı veya ciddi tehdit	1 saat	Brute-force, credential stuffing
Orta	Potansiyel tehdit, doğrulama gerektiriyor	4 saat	Anormal davranış, konum sapması

Öncelik Seviyesi	Tanım	Yanıt Süresi	Örnek
Düşük	Bilgi amaçlı, inceleme gerektiriyor	24 saat	Düşük riskli anomali

Öncelik Hesaplama Faktörleri: - Tehdit kaynağının güvenilirliği - Etkilenen varlığın kritikliği - Saldırının ilerleme durumu - Mevcut kontrollerin etkinliği - İş etkisi potansiyeli

11.7 SOC Playbook ve Vaka Yönetimi

Güvenlik Operasyonları Merkezi (SOC) ekipleri, kimlik doğrulama olaylarına sistematik ve tutarlı bir şekilde yanıt vermek için playbook'lara ihtiyaç duyar.

11.7.1 Playbook Yapısı

Her playbook aşağıdaki bölümleri içermelidir:

1. **Tetikleyici:** Hangi alarm veya koşul playbook'u başlatır
2. **Ön Değerlendirme:** İlk inceleme adımları ve bilgi toplama
3. **Analiz:** Olayın derinlemesine incelenmesi için adımlar
4. **Sınıflandırma:** Olayın kategorize edilmesi
5. **Yanıt:** Alınacak somut eylemler
6. **Kapanış:** Olay kapanış kriterleri ve dokümantasyon
7. **İyileştirme:** Kök neden düzeltmeleri ve süreç güncellemeleri

11.7.2 Vaka Yönetimi Süreci

Vaka Hayat Döngüsü:

1. **Tespit:** Alarm tetiklenir veya manuel rapor alınır
2. **Kayıt:** Vaka numarası oluşturulur, temel bilgiler kaydedilir
3. **Ön Değerlendirme:** Vakanın ciddiyeti ve önceliği belirlenir
4. **Analiz:** Vaka derinlemesine incelenir, kanıtlar toplanır
5. **Yanıt:** Etkilenen sistemler izole edilir, düzeltme uygulanır

6. **Kurtarma:** Sistemler normale döndürülür
7. **Kapanış:** Vaka kapatılır, rapor yazılır
8. **Ders Çıkarma:** Olay sonrası değerlendirme (post-incident review)

Vaka Önceliklendirme Matrisi:

	Düşük Etki	Orta Etki	Yüksek Etki	Kritik Etki
Kanıt Güçlü	Orta	Yüksek	Kritik	Kritik
Kanıt Olası	Düşük	Orta	Yüksek	Kritik
Kanıt Zayıf	Düşük	Düşük	Orta	Yüksek

11.8 Tespit Kuralı Tasarım Şablonu

Etkili tespit kuralları, net bir yapı ve ölçülebilir kriterler içermelidir.

11.8.1 Kural Tasarım Şablonu

```

kural:
  ad: "[Kural adı]"
  id: "[Benzersiz tanımlayıcı]"
  versiyon: "1.0"
  yazar: "[Geliştirici]"
  olusturma_tarihi: "[YYYY-AA-GG]"
  aciklama: "[Kuralın ne tespit ettiği ve neden önemli olduğu]"
  kaynak:
    - "[Veri kaynağı 1]"
    - "[Veri kaynağı 2]"
  kosullar:
    anahtar_fiyatlar:
      - "[Anahtar 1]: [deger]"
      - "[Anahtar 2]: [deger]"
    zaman_penceresi: "[süre]"
    esik_degeri: "[sayısal eşik]"

```

```

|
| korelasyon:
|   - "[Korelasyon koşulu 1]"
|   - "[Korelasyon koşulu 2]"
|
| öncelik: "[Kritik/Yüksek/Orta/Düşük]"
|
| yanıt:
|   otomatik:
|     - "[Otomatik eylem 1]"
|     - "[Otomatik eylem 2]"
|   manuel:
|     - "[Manuel eylem 1]"
|     - "[Manuel eylem 2]"
|
| false positive:
|   - "[Bilinen yanlış pozitif senaryosu 1]"
|   - "[Bilinen yanlış pozitif senaryosu 2]"
|
| metrikler:
|   hassasiyet: "[hedef]"
|   kesinlik: "[hedef]"
|   yanıt_suresi: "[hedef]"

```

11.8.2 Örnek Kural: İmkânsız Seyahat Tespiti

```

| kural:
|   ad: "İmkansız Seyahat Tespiti"
|   id: "AUTH-001"
|   versiyon: "2.1"
|
|   açıklama: |
|     Bir kullanıcının kısa süre içinde fiziksel olarak
|     ulaşılması imkânsız mesafelerde oturum açmasını tespit eder
|
|   kaynak:
|     - "kimlik doğrulama logları"
|     - "konum verileri"
|
|   koşullar:
|     iki_giris_arasi_mesafe_km: ">1000"
|     iki_giris_arasi_sure_dakika: "<60"

```

```

hiz km saat: ">1000"
|
oncelik: "Yüksek"
|
yanit:
otomatik:
- "Oturumu sonlandır"
- "Ek doğrulama tetikle"
manuel:
- "Kullanıcı ile iletişime geç"
- "Oturum geçmişi incele"
|
false_positive:
- "VPN kullanımı"
- "Havaalanı konumu"
- "Veri merkezi IP adresi"

```

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenciler:

1. Kurumsal kimlik doğrulama izleme için gerekli olay kaynaklarını belirleyebilir
2. Giriş davranış analizinin temel prensiplerini kavrar
3. Konum, zaman ve cihaz tabanlı anomali tespit mekanizmalarını tasarlayabilir
4. İmkânsız seyahat tespit algoritmalarını uygulayabilir
5. MFA olaylarını analiz edebilir ve MFA yorgunluğu saldırılarını tespit edebilir
6. SIEM korelasyon kurallarını tasarlayabilir ve önceliklendirebilir
7. SOC playbook'ları oluşturabilir ve vaka yönetimi süreçlerini uygulayabilir

Risk Modeli

Tehdit	Olasılık	Etki	Risk Seviyesi	Tespit Yöntemi
Brute-force saldırısı	Yüksek	Yüksek	Kritik	Rate analizi, IP korelasyonu

Tehdit	Olasılık	Etki	Risk Seviyesi	Tespit Yöntemi
Credential stuffing	Yüksek	Yüksek	Kritik	Çoklu hesap analizi, IoC eşleme
Account takeover	Orta	Kritik	Kritik	İmkânsız seyahat, cihaz anomali
Insider tehdidi	Düşük	Yüksek	Orta	Davranışsal analiz, norm sapması
MFA bypass	Düşük	Kritik	Yüksek	MFA olay analizi, oturum korelasyonu
Lateral movement	Orta	Yüksek	Yüksek	Ağ trafiği analizi, yetki değişikliği
Privilege escalation	Düşük	Kritik	Yüksek	Yetki değişikliği izleme

Savunma Kontrolleri

- Veri Toplama:** Tüm kimlik doğrulama olaylarının kapsamlı ve tutarlı şekilde loglanması
- Olay Zenginleştirme:** Ham olay verilerinin bağlam bilgileriyle zenginleştirilmesi
- Korelasyon:** Çoklu olay kaynağının ilişkilendirilerek anlamlı alarm üretilmesi
- Otomasyon:** Tekrarlayan analiz ve yanıt süreçlerinin otomasyonu (SOAR)
- İnsan Desteği:** Kompleks vakalar için uzman analist değerlendirmesi
- Sürekli İyileştirme:** Yanlış pozitif analizi ve kural optimizasyonu

Güvenli Anlatım Notu

Bu bölümde sunulan tespit kuralları ve SOC süreçleri, yalnızca savunma amaçlıdır. Saldırı simülasyonları ve penetrasyon testleri, yalnızca yetkili ve izin verilmiş kapsamda gerçekleştirilmelidir. Sunulan şablonlar ve örnekler, kurumsal güvenlik operasyonlarının geliştirilmesi için rehber niteliğindedir.

Özet

Kurumsal kimlik doğrulama izleme, çoklu veri kaynaklarının entegrasyonunu, davranışsal analizi ve otomatik tepki mekanizmalarını gerektiren kapsamlı bir süreçtir. Olay kaynaklarının doğru belirlenmesi, anlamlı korelasyon kurallarının tasarlanması, etkili alarm önceliklendirme ve yapılandırılmış playbook'lar, bir kurumun kimlik tabanlı tehditlere karşı savunma yeteneğini doğrudan etkiler. NIST, OWASP ve CISA gibi uluslararası kuruluşların önerilerinin takip edilmesi, güncel tehditlere karşı etkin bir savunma hattı oluşturulmasına katkıda bulunur.

Tartışma Soruları

1. İmkânsız seyahat tespitinde yanlış pozitif oranlarını düşürmek için hangi ek veri kaynakları kullanılabilir?
2. MFA yorgunluğu saldırılarına karşı hem teknik hem de prosedürel ne tür önlemler alınabilir?
3. SIEM korelasyon kurallarında hassasiyet (false positive) ve kesinlik (true positive) oranı arasındaki denge nasıl sağlanabilir?
4. Bir SOC ekibinin alarm yorgunluğunu azaltmak için hangi stratejileri uygulayabilir?
5. Insider tehdit tespitinde kimlik doğrulama olaylarının rolü nedir?

Kaynaklar

1. NIST. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management (SP 800-61 Rev. 3)*. National Institute of Standards and Technology.
2. OWASP. (t.y.). *Logging Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html
3. CISA. (2023). *Insider Threat Mitigation Guide*. Cybersecurity and Infrastructure Security Agency.
4. NIST. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology.
5. CISA. (2023). *Known Exploited Vulnerabilities Catalog*. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

6. SANS Institute. (2023). *SOC Analyst Handbook*. SANS Reading Room.

BÖLÜM 12 – OLAY MÜDAHALESİ: PAROLA SIZINTISI

[↩ İçindekilere dön](#)

Amaç

Bu bölüm, parola sızıntısı gibi kritik güvenlik olaylarına yönelik sistematik müdahale süreçlerini ele almaktadır. Olay kaynağının doğrulanmasından kök neden analizine, kullanıcı bilgilendirmesinden uyum sürecine kadar uzanan kapsamlı bir müdahale çerçevesi sunulmaktadır. İlk 24 saat karar ağacı ile somut ve uygulanabilir bir rehber sağlanmaktadır.

Araştırma Soruları

1. Parola sızıntısı olayları nasıl doğrulanır ve sınıflandırılır?
2. Etkilenen hesaplar nasıl belirlenir ve önceliklendirilir?
3. Riskli oturumlar nasıl tespit edilir ve sonlandırılır?
4. Parola sıfırlama ve credential rotation süreçleri nasıl koordine edilir?
5. Kök neden analizi nasıl gerçekleştirilir ve olay sonrası rapor nasıl hazırlanır?

12.1 Olay Kaynağının Doğrulanması

Parola sızıntısı olaylarına yönelik müdahalenin ilk adımı, olayın kaynağının güvenilir bir şekilde doğrulanmasıdır. Yanlış veya eksik doğrulama, gereksiz panik veya ihmal riskini beraberinde getirir.

12.1.1 Sızıntı Kaynakları

Parola sızıntıları çeşitli kaynaklardan tespit edilebilir:

Dış Kaynaklar: - Dark web forumları ve pazaryerleri - Halka açık sızıntı havuzları (Have I Been Pwned, DeHashed vb.) - Siber tehdit istihbaratı paylaşım platformları (ISAC/ISAO) - Gazeteciler ve güvenlik araştırmacıları bildirimleri - Müşteri bildirimleri

Dahili Kaynaklar: - Credential stuffing saldırı tespitleri - Anormal giriş kalıpları tespiti - Honeypot (tuzak) hesap aktivasyonları - Güvenlik denetim bulguları - Insider tehdit göstergeleri

12.1.2 Doğrulama Süreci

Olay doğrulama süreci aşağıdaki adımları içermelidir:

1. **Kaynak Güvenilirliği Değerlendirmesi:** Sızıntının geldiği kaynağın güvenilirliği ve güvenilirlik derecesi değerlendirilir
2. **Veri Doğruluğu Kontrolü:** Sızıntı verilerinin içeriği, formatı ve kapsamlılığı doğrulanır
3. **Etki Alanının Belirlenmesi:** Hangi sistemlerin, uygulamaların ve verilerin etkilendiği belirlenir
4. **Zaman Çizelgesi Oluşturma:** Sızıntının ne zaman gerçekleştiği ve ne zamandan beri aktif olduğu belirlenir
5. **Kapsam Değerlendirmesi:** Etkilenen hesap sayısı ve türleri belirlenir

12.1.3 Sınıflandırma

Doğrulanmış olaylar, aşağıdaki kriterlere göre sınıflandırılmalıdır:

Kriter	Düşük	Orta	Yüksek	Kritik
Etkilenen hesap sayısı	<100	100-1.000	1.000-100.000	>100.000
Veri hassasiyeti	Genel	Kişisel	Hassas	Kritik
Parola durumu	Hashlenmiş	Hashlenmiş + tuzlu	Düz metin	Düz metin + anahtar
Sızıntı kaynağı	Bilinen	Muhtemel	Doğrulanmış	Açık kaynak
Kullanıcı etkisi	Düşük	Orta	Yüksek	Kritik

12.2 Etkilenen Hesapların Belirlenmesi

Olay doğrulandıktan sonra, etkilenen hesapların kapsamlı ve doğru bir şekilde belirlenmesi kritik bir adımdır.

12.2.1 Hesap Kapsam Analizi

Veri Kaynaklarının Birleştirilmesi:

Etkilenen hesapların belirlenmesi için birden fazla veri kaynağının birleştirilmesi gerekmektedir:

- Parola sızıntı veritabanı (sızan e-posta/parola çiftleri)
- Kimlik doğrulama sistemi kullanıcı veritabanı
- Aktif oturum verileri
- Kullanıcı profil bilgileri
- Departman ve organizasyon yapısı

Eşleştirme Süreci:

1. Sızıntı verilerindeki e-posta adresleri, kullanıcı veritabanıyla eşleştirilir
2. Eşleşen hesaplar, parola hash karşılaştırmasıyla doğrulanır
3. Parola reuse (yeniden kullanım) analizi yapılır
4. Hesap kritikliği ve etki düzeyi değerlendirilir

12.2.2 Önceliklendirme

Etkilenen hesaplar, risk seviyelerine göre önceliklendirilmelidir:

Öncelik Seviyesi	Kriter	Yanıt Süresi
1 - Kritik	Yönetici/privileged hesaplar, kritik sistem erişimi	İlk 1-2 saat
2 - Yüksek	Müşteri verilerine erişim, finansal sistemler	İlk 4-6 saat
3 - Orta	Genel çalışan hesapları	İlk 12-24 saat
4 - Düşük	Pasif/deaktif hesaplar	İlk 48-72 saat

12.2.3 Risk Skorlama

Her hesap için bir risk skoru hesaplanmalıdır:

Risk Skoru = Hesap Kritikliği × Parola Riske × Oturum Durumu × Diğer Faktörler

- **Hesap Kritikliği:** Yönetici (4x), Kritik İş (3x), Genel (2x), Pasif (1x)
- **Parola Riske:** Düz metin sızıntı (4x), Hash sızıntı (3x), Potansiyel eşleşme (2x), Doğrulanmamış (1x)
- **Oturum Durumu:** Aktif oturum (2x), Son 24 saat giriş (1.5x), Son 7 gün (1x), Pasif (>7 gün) (0.5x)

12.3 Riskli Oturumların Sonlandırılması

Etkilenen hesaplardaki mevcut oturumların sonlandırılması, yetkisiz erişimin acil olarak önlenmesi için kritik bir adımdır.

12.3.1 Oturum Sonlandırma Stratejileri

Toplu Oturum Sonlandırma: Etkilenen tüm hesapların aktif oturumları toplu olarak sonlandırılmalıdır. Bu işlem genellikle kimlik doğrulama sistemi düzeyinde gerçekleştirilir.

Seçici Oturum Sonlandırma: Yüksek öncelikli hesaplarda, belirli oturumlar (bilinmeyen cihaz veya konumlardaki oturumlar) hedefli olarak sonlandırılabilir.

Oturum Yenileme Zorlaması: Oturumlar toplu olarak sonlandırılmasa da, bir sonraki etkileşimde yeniden kimlik doğrulama zorunlu kılınabilir.

12.3.2 Oturum Sonlandırma Uygulaması

Sistem	Oturum Sonlandırma Yöntemi	Uygulama
Web uygulaması	Session store temizleme	Redis/Memcached'de oturum silme
Active Directory	Kerberos TGT invalidasyonu	Kullanıcı hesabının TGT'leri silinir

Sistem	Oturum Sonlandırma Yöntemi	Uygulama
VPN	Aktif oturum sonlandırma	VPN sunucu tarafında oturum kapatma
SSO	Token invalidasyonu	Tüm oturum belirteçleri geçersiz kılınır
API	Token blacklist	JWT token'lar blacklist'e eklenir
Bulut hizmeti	API çağrısı ile oturum sonlandırma	Servis sağlayıcı API'si kullanılarak

12.3.3 Oturum Sonrası Önlemler

Oturumlar sonlandırıldıktan sonra aşağıdaki önlemler alınmalıdır:

- Tüm parolaların değiştirilmesi zorunlu kılınmalı
- MFA durumu doğrulanmalı ve gerekirse yeniden yapılandırılmalı
- Yetki setleri kontrol edilmeli ve gerekirse revize edilmeli
- Kullanıcılara güvenlik bildirimi gönderilmeli
- Giriş davranışları yakından izlenmeli

12.4 Parola Sıfırlama ve Credential Rotation

Parola sıfırlama, parola sızıntısı müdahalesinin merkezi bileşenidir. Etkin bir sıfırlama süreci, hem teknik hem de operasyonel olarak dikkatli planlanmalıdır.

12.4.1 Parola Sıfırlama Stratejileri

Acil Sıfırlama (Emergency Reset): Tüm etkilenen hesapların parolalarının zorunlu olarak değiştirilmesi. Kullanıcılar bir sonraki giriş denemelerinde yeni parola belirlemek zorunda kalır.

Kademeli Sıfırlama (Phased Reset): Hesapların risk seviyelerine göre kademeli olarak sıfırlanması. Yüksek riskli hesaplar önce, düşük riskli hesaplar sonra sıfırlanır.

Zamanlanmış Sıfırlama (Scheduled Reset): Belirli bir zaman dilimi içinde tüm parolaların değiştirilmesinin sağlanması. Bu yaklaşım, operasyonel yükü dengeler.

12.4.2 Credential Rotation

Parola sıfırlamasının yanı sıra, ilgili tüm kimlik bilgilerinin de ROTASYONA sokulması gerekmektedir:

Credential Türü	Rotation Eylemi	Öncelik
Kullanıcı parolası	Zorunlu değiştirme	Yüksek
API anahtarları	Yeni anahtar oluşturma, eskiyi iptal	Yüksek
Servis hesapları parolaları	Otomatik rotation	Yüksek
Sertifikalar	Yeniden issuance	Orta
OAuth client secret'ları	Yeni secret oluşturma	Yüksek
SSH anahtarları	Yeni anahtar dağıtımı	Orta
VPN parolaları	Zorunlu değiştirme	Yüksek

12.4.3 Parola Sıfırlama İletişimi

Parola sıfırlama sürecinde etkili iletişim kritik önem taşır:

İletişim Kanalları: - E-posta bildirimi (şifrelenmiş) - SMS bildirimi (MFA kanalı olarak kullanılmayan) - Kurum içi iletişim araçları (intranet, Teams/Slack) - Telefon ile bildirim (kritik hesaplar için) - Yönetici bildirimi (ücretli hesaplar)

İletişim İçeriği: - Sızıntının kısa ve net açıklaması - Beklenen eylem ve son tarih - Yeni parola belirleme talimatları - Destek kanalları ve iletişim bilgileri - Ek güvenlik önerileri

12.5 MFA Durumu ve Kurtarma Kontrolleri

MFA, parola sızıntısı müdahalesinde en etkili kontrol mekanizmalarından biridir. MFA durumunun doğru değerlendirilmesi ve gerekirse kurtarılması kritik bir adımdır.

12.5.1 MFA Durum Değerlendirmesi

Etkilenen hesaplar için MFA durumunun kapsamlı bir şekilde değerlendirilmesi gerekmektedir:

MFA Durumu	Risk Seviyesi	Eylem
MFA aktif, FIDO2/WebAuthn	Düşük	Mevcut durumu koru, parola sıfırla
MFA aktif, TOTP/Hotp	Düşük-Orta	Mevcut durumu koru, parola sıfırla, MFA'yı yeniden doğrula
MFA aktif, SMS	Orta	MFA yöntemini yükseltmeyi öner, parola sıfırla
MFA kayıtlı ama devre dışı	Yüksek	MFA'yı yeniden etkinleştir, parola sıfırla
MFA hiç kayıtlı değil	Kritik	MFA kurulumunu zorunlu kıl, parola sıfırla

12.5.2 MFA Kurtarma Süreçleri

MFA'nın kendisi de compromise olabilir veya kullanıcılar MFA erişimini kaybedebilir:

Yedek Kod Yönetimi: Kullanıcılara initial setup'ta yedek kodlar verilmeli ve bu kodlar güvenli bir şekilde saklanmalıdır. MFA kurtarma için yedek kodların kullanımı, en güvenilir kurtarma yöntemidir.

Çoklu MFA Yöntemi: Kullanıcılara birden fazla MFA yöntemi kaydetme imkanı sunulmalıdır. Bir yöntem başarısız olduğunda alternatif bir yöntem kullanılabilir.

Yönetici Kurtarma: Kritik durumlarda, yetkili bir yöneticinin kullanıcı adına MFA'yı sıfırlayabilmesi gerekir. Bu süreç titizlikle loglanmalı ve iki kişilik onay (four-eyes principle) gerektirmelidir.

Kimlik Doğrulama Tabanlı Kurtarma: Kullanıcının kimliğini fiziksel olarak veya video görüşme yoluyla doğrulayarak MFA'nın sıfırlanması.

12.5.3 MFA Güvenlik Kontrol Listesi

- [] Tüm etkilenen hesaplar için MFA durumu doğrulandı mı?

- [] MFA olmayan hesaplar için kurulum zorunlu kılındı mı?
- [] MFA yöntemleri güncel ve güvenli mi (FIDO2/WebAuthn tercih ediliyor mu)?
- [] Yedek kodlar güvenli bir şekilde dağıtıldı mı?
- [] Yönetici kurtarma süreçleri tanımlı ve test edildi mi?
- [] MFA bypass senaryoları ele alındı mı?

12.6 Yetki Değişiklikleri ve Kalıcılık Göstergeleri

Parola sızıntısı sonrasında, saldırganların sistemde kalıcılık sağlamış olma ihtimali ciddiye alınmalıdır.

12.6.1 Yetki Değişikliklerinin İncelenmesi

Sızıntı sonrası periodo süresince (parola ele geçirilme zamanından itibaren) yapılan tüm yetki değişikliklerinin incelenmesi gerekmektedir:

İncelenecek Değişiklikler: - Grup üyelikleri değişiklikleri - Rol atamaları - Yönetici yetkileri - Erişim izni genişletmeleri - Servis hesabı yetkilendirmeleri - API erişim izinleri

Zaman Çizelgesi Analizi: Parola sızıntısının gerçekleştiği tahmini zamandan itibaren tüm değişiklikler incelenmelidir. Saldırganın ne kadar süreyle sistemde kaldığı ve ne tür değişiklikler yaptığı belirlenmelidir.

12.6.2 Kalıcılık Göstergeleri (Persistence Indicators)

Saldırganların sistemde kalıcılık sağlamak için başvurabileceği yöntemler ve tespit göstergeleri:

Kalıcılık Yöntemi		Tespit Göstergesi		Kurtarma Eylemi
Yedek hesabı	kullanıcı	Bilinmeyen isimler	hesaplar, tuhaf	Hesabı sil, parolaları sıfırla
SSH ekleme	anahtarı	authorized_keys	değişiklikleri	Anahtarları temizle, SSH yapılandırmasını güncelle
Cron scheduled task	job /	Bilinmeyen görevler	zamanlanmış	Görevleri kaldır

Kalıcılık Yöntemi	Tespit Göstergesi	Kurtarma Eylemi
Registry değişikliği	Bilinmeyen registry girdileri	Registry'yi temizle
Başlangıç programları	Bilinmeyen startup entry'leri	Entry'leri kaldır
Dosya bırakma (webshell)	Bilinmeyen dosyalar, değiştirilmiş dosyalar	Dosyaları kaldır, sistemi doğru
MFA bypass	MFA'yı devre dışı bırakan değişiklikler	MFA'yı yeniden etkinleştir

12.6.3 Dijital Adli Bilişim

Kalıcılık göstergelerinin tespitinde dijital adli bilişim teknikleri kullanılmalıdır:

- **Log analizi:** Tüm kimlik doğrulama ve yetkilendirme loglarının kapsamlı analizi
- **Dosya sistemi analizi:** Değiştirilmiş veya eklenen dosyaların tespiti
- **Bellek analizi:** Çalışan süreçler ve ağ bağlantılarının incelenmesi
- **Ağ trafiği analizi:** Dışarıya yapılan şüpheli bağlantıların tespiti
- **Zaman çizelgesi oluşturma:** Tüm olayların kronolojik sıralanması

12.7 Kullanıcı Bilgilendirme ve Uyum

Etkilenen kullanıcıların zamanında ve etkili bir şekilde bilgilendirilmesi, hem yasal uyumluluk hem de güvenin korunması açısından kritik önem taşır.

12.7.1 Bildirim Gereksinimleri

Yasal Bildirim Yükümlülükleri:

Bildirim yükümlülüğü; olayın niteliğine, etkilenen kişilere, işlenen veri türüne, uygulanabilir hukuka ve sözleşmelere göre belirlenir:

- **KVKK:** Kanun veri sorumlusunun ihlali ilgili kişiye ve Kurula en kısa sürede bildirmesini öngörür. Kurul uygulamasında Kurula bildirim için 72 saat ölçütü bulunur; ilgili kişiye bildirim de kişi belirlenebildiğinde gecikmeksizin ele alınmalıdır.

- **GDPR:** Kişilerin hak ve özgürlükleri bakımından risk doğurması muhtemel bir ihlal, mümkünse farkına varıldıktan sonra 72 saat içinde yetkili denetim makamına bildirilir. Yüksek risk varsa ilgili kişiye ayrıca gereksiz gecikme olmaksızın bildirim gündeme gelir.
- **Sektör ve sözleşme:** Ödeme ekosistemi, sigorta, müşteri ve hizmet sağlayıcı sözleşmeleri farklı bildirim kanalları veya daha kısa süreler belirleyebilir.

Hukuk, gizlilik, olay müdahale ve iletişim ekipleri olayın ilk saatlerinde ortak bir bildirim matrisi oluşturmalıdır.

Bildirim Zamanlaması:

Durum	Bildirim Zamanı	Hedef Kitle
Aktif istismar / devam eden zarar	Gecikmeden koruyucu iletişim	Etkilenen kişiler, olay ve hukuk ekipleri
Düzenleyici bildirim eşiği karşılanıyor	Uygulanabilir yasal süre içinde	Yetkili denetim makamı
Kişiler için yüksek risk	Gereksiz gecikme olmaksızın	Etkilenen kişiler
Eşik veya kapsam belirsiz	Süreyi kaçırmadan değerlendirme ve kayıt	Hukuk/gizlilik sorumluları ve olay yönetimi

12.7.2 Bildirim İçeriği

Etkili bir güvenlik bildirimi aşağıdaki bileşenleri içermelidir:

1. **Olayın açıklaması:** Ne olduğu, ne zaman gerçekleştiği (biliniyorsa)
2. **Etkilenen veri türleri:** Hangi bilgilerin sızdığı
3. **Etkilenen kullanıcılar:** Kimlerin etkilendiği
4. **Alınan önlemler:** Kurumun ne yaptığı
5. **Kullanıcılar için eylem:** Kullanıcıların ne yapması gerektiği
6. **Destek bilgileri:** Nereden yardım alınabileceği
7. **Önleyici öneriler:** Gelecekte alınabilecek önlemler

12.7.3 Uyum Süreci

Parola sızıntısı müdahalesinin yasal ve düzenleyici boyutları:

Dokümantasyon: Tüm müdahale süreçleri titizlikle belgelenmeli ve saklanmalıdır. Bu belgeler, olası yasal soruşturmalar veya denetimler için gereklidir.

Düzenleyici Bildirim: KVKK, GDPR veya sektör düzenlemeleri gereği ilgili otoritelere bildirim yapılması gerekmektedir.

Müşteri İletişimi: Etkilenen müşterilerle şeffaf ve zamanında iletişim kurulmalıdır.

Hukuki Danışmanlık: Büyük ölçekli sızıntılar durumunda hukuki danışmanlık alınması önerilmektedir.

12.8 Kök Neden Analizi ve Olay Sonrası Rapor

Her güvenlik olayı, bir öğrenme ve iyileştirme fırsatı sunar. Kapsamlı bir kök neden analizi ve olay sonrası rapor, gelecek olayların önlenmesine katkıda bulunur.

12.8.1 Kök Neden Analizi (Root Cause Analysis)

Analiz Metodolojisi:

Kök neden analizi, olayın meydana gelmesine yol açan temel nedenleri sistematik olarak belirleme sürecidir. "5 Neden" (5 Whys) tekniği, kök neden analizinde yaygın olarak kullanılan bir yaklaşımdır.

Örnek Analiz:

Soru 1: Neden parola sızıntısı gerçekleşti?

Cevap: Kullanıcı parolası dark web'de bulundu.

Soru 2: Neden kullanıcı parolası dark web'de bulundu?

Cevap: Kullanıcı aynı parolayı üçüncü parti serviste de kullanıyordu.

Soru 3: Neden kullanıcı aynı parolayı kullanıyordu?

Cevap: Parola yeniden kullanım politikası uygulanmamıştı.

Soru 4: Neden parola yeniden kullanım politikası uygulanmamıştı?

Cevap: Kimlik doğrulama sistemi parola reuse kontrolü yapmıyordu.

Soru 5: Neden kontrol yapmıyordu?

Cevap: Sistem güvenlik gereksinimleri tanımlanmamıştı.

Kök Neden: Güvenlik gereksinimlerinin eksik tanımlanması ve parola reuse kontrolünün uygulanmaması.

Kök Neden Kategorileri:

Kategori	Açıklama	Örnek
Teknik	Sistem/zafiyet kaynaklı	Hash algoritması zayıf
Süreç	İş akışı/eksiklik kaynaklı	Parola rotation politikası yok
İnsan	Hata/bilgi eksikliği	Güvenlik eğitimi eksikliği
Yapısal	Organizasyonel/kaynak	Yetersiz güvenlik bütçesi
Dışsal	Üçüncü parti/supply chain	Vendor sızıntısı

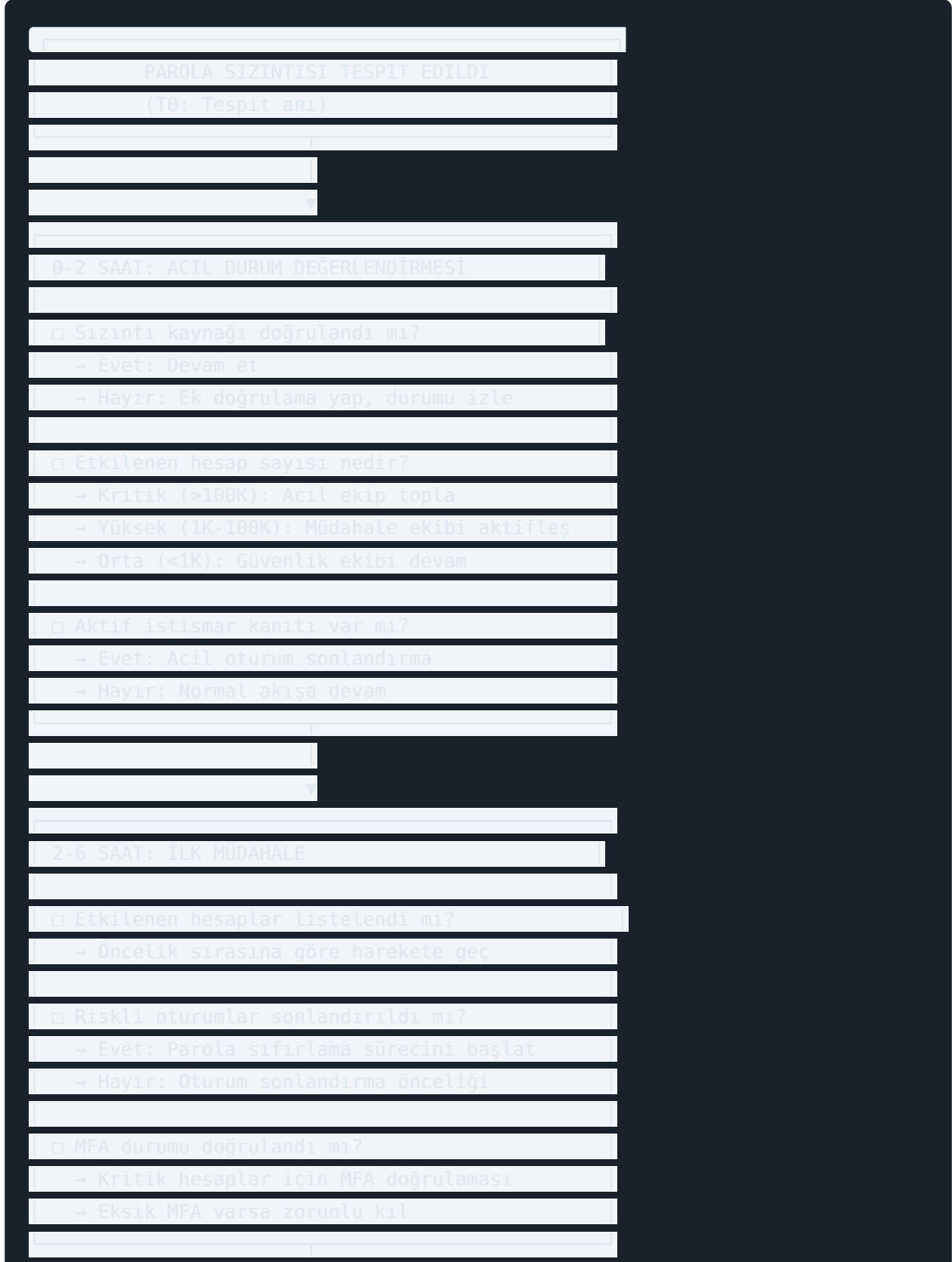
12.8.2 Olay Sonrası Rapor (Post-Incident Report)

Kapsamlı bir olay sonrası rapor aşağıdaki bölümleri içermelidir:

- 1. Yönetici Özeti:** - Olayın kısa özeti - Temel bulgular - Kritik öneriler
- 2. Olay Zaman Çizelgesi:** - Keşif tarihi ve saati - Müdahale başlangıcı - Önemli karar noktaları - Çözüm tarihi - Kapanış tarihi
- 3. Etki Değerlendirmesi:** - Etkilenen kullanıcı/hesap sayısı - Etkilenen sistemler - Veri kaybı değerlendirme - İş sürekliliği etkisi - Maliyet değerlendirme
- 4. Kök Neden Analizi:** - Temel nedenler - Katılımcı faktörler - Kontrol eksiklikleri
- 5. Müdahale Değerlendirmesi:** - Hangi adımlar etkili oldu - Hangi alanlarda iyileştirme gerekli - Communication değerlendirme
- 6. Öneriler:** - Kısa vadeli düzeltmeler (0-30 gün) - Orta vadeli iyileştirmeler (1-3 ay) - Uzun vadeli stratejik değişiklikler (3-12 ay)
- 7. Ders Çıkarılanlar:** - Güçlü yönler - Geliştirme alanları - Gelecek olaylar için hazırlık

12.9 İlk 24 Saat Karar Ağacı

Parola sızıntısı müdahalesinin ilk 24 saati, olayının yönetiminde en kritik dönemdir. Aşağıdaki karar ağacı, bu süreçte alınacak kararları yönlendirir.



6-12 SAAT: PAROLA SIFIRLAMA	
☐ Parola sıfırlama yöntemi seçildi mi?	
→ Acil/Kademeli/Zamanlanmış	
☐ Credential rotation başladı mı?	
→ API anahtarları, servis hesapları	
☐ Kullanıcı bildirimi gönderildi mi?	
→ E-posta/SMS/Intranet	
☐ Yasal/sözleşmesel bildirim gerekiyor mu?	
→ Uygulanabilir süre ve eşik doğrulandı mı?	
→ İlgili otorite ve kişiler belirlendi mi?	
12-18 SAAT: KALICILIK KONTROLÜ	
☐ Kalıcılık göstergeleri incelendi mi?	
→ Yedek hesaplar, SSH anahtarları	
→ Scheduled tasks, registry	
☐ Yetki değişiklikleri kontrol edildi mi?	
→ Grup üyelikleri, rol atamaları	
☐ Log analizi yapıldı mı?	
→ Anomali tespit, zaman çizelgesi	
18-24 SAAT: DEĞERLENDİRME VE RAPOR	
☐ İlk müdahale tamamlandı mı?	
→ Tüm kritik hesaplar sıfırlandı	
→ Oturumlar sonlandırıldı	
☐ Durum bildirimi yapıldı mı?	
→ Yönetim ve olay koordinasyon ekibi	

→ Düzenleyici otoriteler
☐ Kök neden analizi başlatıldı mı?
→ İlk bulgular dokümanite edildi
☐ Sonraki adımlar tanımlandı mı?
→ 72 saat planı
→ 1 hafta planı

12.10 Karar Ağacında Kritik Karar Noktaları

Karar 1: Olayı Durdur vs. Devam Et

Durdur: Aktif istismar kanıtı varsa, tüm etkilenen hesaplar için acil oturum sonlandırma ve parola sıfırlama yapılmalıdır.

Devam Et: İstismar kanıtı yoksa, kademeli ve kontrollü bir müdahale yaklaşımı benimsenebilir.

Karar 2: Toplu vs. Kademeli Sıfırlama

Kriter	Toplu Sıfırlama	Kademeli Sıfırlama
Hız	Çok hızlı	Yavaş
İş etkisi	Yüksek (tüm kullanıcılar etkilenir)	Düşük (kademeli)
Kullanıcı memnuniyeti	Düşük	Orta
Uygulama karmaşıklığı	Düşük	Yüksek
Önerilen durum	Aktif istismar, kritik hesap	Düşük-orta risk

Karar 3: Bildirim Zamanlaması

Bildirim zamanlaması, yasal gereksinimler, iş etkisi ve itibar riski arasında bir denge gerektirir. Erken bildirim şeffaflık sağlarken, çok erken bildirim eksik bilgiyle paniğe yol açabilir.

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenciler:

1. Parola sızıntısı olaylarını doğrulama ve sınıflandırma süreçlerini uygulayabilir
2. Etkilenen hesapları kapsamlı bir şekilde belirleyebilir ve önceliklendirebilir
3. Riskli oturumları sonlandırma stratejilerini tasarlayabilir
4. Parola sıfırlama ve credential rotation süreçlerini koordine edebilir
5. MFA durumunu değerlendirebilir ve kurtarma süreçlerini uygulayabilir
6. Kalıcılık göstergelerini tespit edebilir ve dijital adli tıp uygulayabilir
7. Kullanıcı bildirim ve uyum süreçlerini yönetebilir
8. Kapsamlı kök neden analizi gerçekleştirebilir
9. Olay sonrası rapor hazırlayabilir
10. İlk 24 saat karar ağacını uygulayabilir

Risk Modeli

Tehdit	Olasılık	Etki	Risk Seviyesi	Kontrol
Parola reuse saldırısı	Yüksek	Yüksek	Kritik	Parola reuse politikası, MFA
Credential stuffing	Yüksek	Yüksek	Kritik	Rate limiting, risk tabanlı doğrulama
Hesap ele geçirme	Orta	Kritik	Kritik	MFA, oturum izleme
Yetkisiz veri erişimi	Orta	Kritik	Kritik	Erişim kontrolü, log analizi
Kalıcılık sağlama	Düşük	Kritik	Yüksek	Düzenli denetim, log analizi
Düzenleme cezası	Orta	Yüksek	Yüksek	Uyumluluk, bildirim süreçleri

Savunma Kontrolleri

1. **Önleyici Kontroller:** - Parola reuse politikası - Güçlü MFA uygulaması - Düzenli güvenlik eğitimleri - Parola rotation politikaları
2. **Tespit Kontrolleri:** - Credential stuffing tespiti - Anormal giriş davranışı analizi - Honeypot hesaplar - Dark web izleme
3. **Yanıt Kontrolleri:** - Acil müdahale planı - İletişim planı - Olay sonrası iyileştirme
4. **Kurtarma Kontrolleri:** - Yedekleme ve geri yükleme - Sistem bütünlüğü doğrulama - Normal çalışma süreleri

Güvenli Anlatım Notu

Bu bölümde sunulan müdahale süreçleri ve karar ağaçları, yalnızca defansif (koruyucu) amaçlarla hazırlanmıştır. Parola sızıntısı müdahalesi, etik ve yasal çerçeveler içinde gerçekleştirilmelidir. Saldırı simülasyonları veya penetrasyon testleri, yalnızca yetkili ve izin verilmiş kapsamda yapılmalıdır. Tüm müdahale süreçlerinde kullanıcı mahremiyeti ve veri koruma ilkelerine uyulmalıdır.

Özet

Parola sızıntısı olaylarına müdahale, sistematik ve çok aşamalı bir süreçtir. Olay kaynağının doğrulanması, etkilenen hesapların belirlenmesi, oturumların sonlandırılması, parolaların sıfırlanması, MFA durumunun değerlendirilmesi, kalıcılık göstergelerinin aranması, kullanıcı bilgilendirmesi ve kök neden analizi gibi adımlar, bir bütün olarak ele alınmalıdır. İlk 24 saat karar ağacı, bu sürecin hızlı ve etkili bir şekilde yürütülmesi için somut bir rehber sunmaktadır. Olay sonrası süreç, yalnızca mevcut durumun düzeltilmesini değil, gelecek olayların önlenmesini de amaçlamalıdır.

Tartışma Soruları

1. Parola sızıntısı müdahalesinde "toplu sıfırlama" ve "kademeli sıfırlama" arasındaki tercih hangi faktörlere bağlıdır?

2. İlk 24 saat karar ağacında, hangi karar noktaları en kritik önem taşımaktadır ve neden?
3. Olay sonrası raporda, kök neden analizinin etkinliği nasıl değerlendirilebilir?
4. KVKK ve GDPR kapsamındaki bildirim yükümlülükleri arasındaki temel farklar nelerdir?
5. Kalıcılık göstergelerinin tespitinde dijital adli bilişim tekniklerinin rolü nedir?

Kaynaklar

1. NIST. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management (SP 800-61 Rev. 3)*. National Institute of Standards and Technology.
2. CISA. (2021). *Federal Government Cybersecurity Incident and Vulnerability Response Playbooks*. Cybersecurity and Infrastructure Security Agency.
3. KVKK. (2016). *Kişisel Verilerin Korunması Kanunu (6698 Sayılı Kanun)*.
4. GDPR. (2016). *General Data Protection Regulation (EU) 2016/679*.
5. SANS Institute. (2023). *Incident Handler's Handbook*. SANS Reading Room.
6. OWASP. (2021). *OWASP Top 10 — A07: Identification and Authentication Failures*. <https://owasp.org/Top10/>
7. CISA. (2023). *Ransomware Guide*. Cybersecurity and Infrastructure Security Agency.
8. NIST. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology.
9. ISO/IEC. (2016). *ISO/IEC 27035:2016 - Information security incident management*.

Bu bölüm, parola ve kimlik doğrulama güvenliği konusunda kapsamlı bir müdahale çerçevesi sunmaktadır. Okuyucular, sunulan süreçleri kendi kurumsal yapılarına uyarlayarak etkin bir olay müdahalesi yeteneği geliştirebilirler.

BÖLÜM 13 — HUKUK VE ETİK

[↩ İçindekilere dön](#)

Amaç

Bu bölüm, parola ve kimlik doğrulama çalışmalarının hukuki ve etik sınırlarını genel ilkeler düzeyinde ele alır. Yetkisiz erişim, kişisel veri güvenliği, yazılı yetki, araştırma verisi, sorumlu açıklama ve akademik dürüstlük incelenir. Bölüm hukuki mütalaa değildir; somut olayda güncel mevzuat ve yetkili uzman görüşü esas alınmalıdır.

Araştırma Soruları

1. Parola ve kimlik doğrulama sistemlerinde yetkisiz erişim hangi hukuki sonuçları doğurur?
2. KVKK ve kişisel verilerin korunması mevzuatı, kimlik doğrulama verilerini nasıl düzenler?
3. Akademik çalışmalarda sentetik, anonim ve kişisel veri arasındaki sınır nasıl belirlenmelidir?
4. Koordineli güvenlik açığı açıklaması nasıl planlanmalıdır?

Detaylı Açıklama

Yetkisiz Erişim ve Hukuki Sorumluluk

Türkiye'de bilişim sistemine girme, sistemi engelleme veya bozma, verileri yok etme veya değiştirme ve banka/kredi kartlarının kötüye kullanılması gibi fiiller 5237 sayılı Türk Ceza Kanunu'nun ilgili hükümlerinde düzenlenir. Bir testin teknik olarak zararsız görünmesi yetki sorununu ortadan kaldırmaz. Kapsam, süre, hedefler, izin verilen yöntemler, veri işleme sınırları, acil durdurma ve raporlama kanalı yazılı yetki belgesinde açıkça tanımlanmalıdır. Ceza ve yaptırım miktarları değişebileceği ve fiilin niteliğine göre farklılaşabileceği için bu çalışma sabit bir ceza özeti vermemektedir.

Yetki; sistem sahibinin hukukî geçerli onayına dayanmalı, alt yüklenici ve bulut hizmeti gibi üçüncü taraf bağımlılıklarını da kapsamalıdır. Sözleşme, veri koruma yükümlülükleri ve hizmet sağlayıcı koşulları ayrıca değerlendirilmelidir.

KVKK ve Kişisel Verilerin Korunması

Türkiye'de 6698 sayılı Kişisel Verilerin Korunması Kanunu (KVKK), kişisel verilerin işlenmesini düzenler. Kullanıcı kimliği, e-posta adresi, cihaz ve oturum kayıtları kişisel veri niteliği taşıyabilir. Parola hash'i geri döndürülemez biçimde saklansa bile bir hesaba bağlanabildiği ve doğrulamada kullanıldığı sürece otomatik olarak anonim veri sayılmaz. Kimlik doğrulama amacıyla işlenen biyometrik veriler özel nitelikli kişisel veri rejimine tabidir. KVKK'nın 12. maddesi, veri sorumlusuna uygun teknik ve idari tedbirleri alma yükümlülüğü getirir.

Parola ve kimlik doğrulama sistemlerinde KVKK'ya uyum için aşağıdaki tedbirler alınmalıdır: - Parolaların kriptografik olarak saklanması (hash + salt) - Çok faktörlü kimlik doğrulama (MFA) uygulanması - Erişim kayıtlarının tutulması ve düzenli denetimi - Veri minimizasyonu ilkesi gereği, yalnızca gerekli verilerin toplanması - İşleme amacı, hukuki sebep, saklama süresi ve erişim yetkilerinin belgelenmesi - Yüksek riskli işleme için orantılı risk/etki değerlendirmesi yapılması

Yazılı İzin ve Test Kapsamı

Güvenlik testleri, yazılı izin olmadan yapılmamalıdır. Bu izin, test edilecek sistemlerin sahibi veya yetkilisi tarafından verilmelidir. Test kapsamı, izin belgesinde açıkça tanımlanmalıdır. Kapsam dışı testler, hukuki sorunlara yol açabilir.

Akademik çalışmalarda etik kurul gereksinimi; insan katılımcı bulunmasına, kişisel veri işlenmesine, kurum politikasına ve araştırma tasarımıyla bağlıdır. Her laboratuvar çalışması için otomatik olarak etik kurul zorunluluğu bulunduğu varsayılmamalı; ilgili kurumun kuralları yazılı olarak kontrol edilmelidir. Gerçek kullanıcı verisi kullanılacaksa hukuki sebep, veri minimizasyonu, saklama ve imha planı ile katılımcı hakları araştırma başlamadan belirlenmelidir.

Sentetik Veri İlkesi

Sentetik veri, doğrudan gerçek kişilerin kayıtlarının kopyası olmayan yapay veridir. Kullanımı veri minimizasyonunu destekleyebilir; ancak eğitim verisinin ezberlenmesi, nadir örneklerin yeniden üretilmesi veya dış verilerle eşleştirme gibi

riskler nedeniyle "sentetik" etiketi tek başına anonimlik garantisi değildir. Uygun yöntemler şunları içerebilir: - Rastgele veri üretimi (random data generation) - Kural tabanlı senaryo üretimi - İstatistiksel veya üretici modellerle veri sentezi - Yeniden tanımlama ve üyelik çıkarımı risk testleri

Anonimleştirme ve maskeleye, sentetik veri üretimiyle aynı kavram değildir; federasyonlu öğrenme de başlı başına bir sentetik veri yöntemi sayılmaz. Parola deneylerinde en güvenli varsayılan, gerçek sızıntı kümelerini çoğaltmak yerine açıkça tanımlanmış dağılımlardan üretilen yapay girdiler kullanmaktır.

Akademik Dürüstlük ve Kaynak Gösterme

Akademik çalışmalarda, başkalarının fikri mülkiyetine saygı duyulmalıdır. Alıntı yapılan kaynakların doğru ve eksiksiz olarak gösterilmesi, akademik dürüstüğün temel bir gereğidir. intihal (plagiarism), akademik dünyanın en ciddi etik ihlallerinden biridir.

Bu çalışmada APA 7 ilkelerine yakın yazar-tarih yaklaşımı kullanılmıştır. Sürekli güncellenen teknik web sayfalarında erişim tarihi, sürümlü standartlarda yayın tarihi ve sürüm numarası belirtilmiştir. Kaynak varmış izlenimi veren ancak doğrulanamayan künyeler kullanılmamalıdır.

Koordineli Güvenlik Açığı Açıklaması

Güvenlik açıkları, koordineli güvenlik açığı açıklaması ilkelerine göre ele alınmalıdır. Araştırmacı; asgari doğrulama kanıtını, etkiyi, yeniden üretim için gerekli fakat kötüye kullanımı artırmayan bilgiyi ve güvenli iletişim kanalını belirlemelidir. Kuruluşa düzeltme için makul süre tanınır; ancak her olay için geçerli sabit bir 90 günlük süre yoktur. Aktif sömürü, kullanıcı güvenliği, tedarik zinciri ve yama hazırlanabilirliği takvimi etkiler.

Sorumlu açıklama süreci şu adımları içerir: 1. Açığın tespiti ve dokümantasyonu 2. İlgili kuruluşa gizli bildirim 3. Etki ve aciliyete göre açıklama takviminin koordine edilmesi 4. Düzeltme ve hafifletmelerin doğrulanması 5. Kullanıcı güvenliğini gözeten, ölçülü kamu açıklaması

Etik Kurul Onayı

İnsan katılımcı, davranış ölçümü veya tanımlanabilir veri içeren araştırmalarda etik inceleme gereksinimi araştırma başlamadan değerlendirilmelidir. Tamamen sentetik veriyle, insan katılımcı olmadan yürütülen teknik ölçümlerde süreç kurum politikasına göre farklı olabilir. Muafiyet kararı gerekiyorsa bu karar araştırmacı tarafından varsayılmamalı, yetkili kurul veya birimden alınmalıdır.

Etik Beyan Metni

Etik beyan, gerçekte yürütülen süreci doğru yansıtmalıdır. Etik kurul onayı veya katılımcı rızası yoksa varmış gibi yazılmamalıdır. Uygun beyan; insan katılımcı ve kişisel veri durumunu, onay/muafiyet bilgisini, çıkar çatışmasını, finansmanı, veri ve kod erişilebilirliğini açıklamalıdır.

Veri Kullanımı Yönergesi

Kurumlar, veri kullanımı yönergesi oluşturmalıdır. Bu yönerge, hangi verilerin nasıl kullanılabileceğini, saklanacağını ve imha edileceğini düzenler. Veri kullanımı yönergesi şu bölümleri içermelidir: - Veri türleri ve sınıflandırması - Veri sorumluları ve yetkililer - Veri işleme faaliyetleri - Veri saklama süreleri - Veri imha prosedürleri - İhlal bildirim prosedürleri

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenciler: 1. Yetkisiz erişimin hukuki sonuçlarını açıklayabilir 2. KVKK'ya uyum için gerekli tedbirleri listeleyebilir 3. Sentetik veri kullanımının etik gerekçelerini kavrayabilir 4. Sorumlu açıklama ilkesini uygulayabilir 5. Etik kurul onayı sürecini anlayabilir 6. Etik beyan metni hazırlayabilir

Risk Modeli

Risk	Olasılık	Etki	Risk Seviyesi	Kontrol
Yetkisiz erişim	Yüksek	Yüksek	Kritik	Erişim kontrolleri, MFA

Risk	Olasılık	Etki	Risk Seviyesi	Kontrol
Veri sızması	Orta	Yüksek	Yüksek	Güvenli hash, şifreleme, erişim kontrolü
Etik ihlal	Düşük	Yüksek	Orta	Etik kurul, yönergeler
Hukuki yaptırım	Orta	Yüksek	Yüksek	KVKK uyumu, izin süreçleri
İtibar kaybı	Düşük	Çok Yüksek	Yüksek	Sorumlu açıklama, şeffaflık

Savunma Kontrolleri

- Teknik Kontroller:** Erişim kontrolleri, şifreleme, log yönetimi
- Yönetimsel Kontroller:** Politikalar, prosedürler, eğitimler
- Fiziksel Kontroller:** Veri merkezi güvenliği, erişim kontrol sistemleri
- Hukuki Kontroller:** KVKK uyumu, sözleşmeler, sigorta

Tablolar

Tablo 13.1: KVKK ve GDPR için seçilmiş karşılaştırma noktaları

Konu	KVKK	GDPR
Hukuki sebep	Açık rıza tek sebep değildir; Kanun'daki diğer şartlar uygulanabilir	Rıza tek sebep değildir; Madde 6'daki diğer dayanaklar uygulanabilir
Özel nitelikli/ biyometrik veri	Madde 6 ve güncel ikincil düzenlemeler	Madde 9 ve ilgili istisnalar
İhlal bildirimi	Kanun "en kısa sürede" der; Kurul uygulamasında 72 saat ölçütü bulunur	Mümkünse farkına varıldıktan sonra 72 saat içinde denetim makamına bildirim
Sorumlu rol/ kayıt	VERBİS ve irtibat/temsil yükümlülükleri koşullara bağlıdır	DPO ataması Madde 37'deki koşullarda zorunludur; her kuruluş için otomatik değildir

Konu	KVKK	GDPR
Yaptırım	Güncel Kanun ve yıllık yeniden değerlendirme esas alınır	Madde 83'te ihlalin türüne göre kademeli üst sınırlar bulunur

Tablo 13.2: Sorumlu Adımlar

Adım	Açıklama	Süre
Tespit	Açıgın keşfedilmesi	-
Bildirim	Kuruluşa gizli bildirim	1-7 gün
Değerlendirme	Etki, aktif sömürü ve kullanıcı riski	Gecikmeden
Düzeltilme	Üreticiyle risk-temelli takvim	Olayın niteliğine göre
Açıklama	Kullanıcı güvenliğini gözetken koordineli duyuru	Düzeltilme/azaltım hazır olduğunda veya kamu yararı gerektirdiğinde

Güvenli Anlatım Notu

Bu bölümde, saldırı araçları veya komutları verilmemiştir. Tüm örnekler sentetik verilerle oluşturulmuştur. Okuyucular, burada sunulan bilgileri yalnızca yasal ve etik çerçevenin anlaşılması için kullanmalıdır. Gerçek sistemlere yetkisiz erişim girişimleri suç teşkil eder.

Özet

Bu bölüm, parola ve kimlik doğrulama güvenliği alanındaki hukuki ve etik boyutları ele almıştır. Yetkisiz erişim, KVKK, sentetik veri, sorumlu açıklama ve etik kurul onayı gibi konular detaylı olarak incelenmiştir. Araştırmacılara ve uygulayıcılara yasal ve etik sorumlulukları konusunda rehberlik edilmiştir.

Kontrol Listesi

- [] Yetkisiz erişim riskleri değerlendirildi
- [] KVKK uyumu sağlandı

- [] Testler için yazılı izin alındı
- [] Sentetik veri kullanıldı
- [] Kaynaklar doğru gösterildi
- [] Sorumlu açıklama prosedürü belirlendi
- [] Etik kurul onayı alındı
- [] Etik beyan metni hazırlandı
- [] Veri kullanımı yönergesi oluşturuldu

Tartışma Soruları

1. Bir güvenlik araştırmacısı, tespit ettiği bir açığı kamuya açıklamalı mı? Neden?
2. KVKK, güvenlik araştırmalarını nasıl etkiliyor?
3. Sentetik veri kullanımı, araştırmanın geçerliliğini nasıl etkiler?
4. Etik kurul onayı, akademik özgürlüğü kısıtlar mı?
5. Sorumlu açıklama sürecinde hangi etik ikilemler ortaya çıkabilir?

Kaynaklar

1. 6698 sayılı Kişisel Verilerin Korunması Kanunu. (2016, güncel metin). <https://www.mevzuat.gov.tr/mevzuatmetin/1.5.6698.pdf>
2. 5237 sayılı Türk Ceza Kanunu. (2004, güncel metin). <https://www.mevzuat.gov.tr/mevzuatmetin/1.5.5237.pdf>
3. European Union. (2016). *Regulation (EU) 2016/679 (General Data Protection Regulation)*. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
4. ISO/IEC. (2018). *ISO/IEC 29147:2018 Vulnerability disclosure*.
5. ISO/IEC. (2019). *ISO/IEC 30111:2019 Vulnerability handling processes*.

BÖLÜM 14 — AKADEMİK LABORATUVAR TASARIMI

[↩ İçindekilere dön](#)

Amaç

Bu bölümün amacı, parola ve kimlik doğrulama güvenliği alanında akademik laboratuvar çalışmaları için gerekli ortam tasarımını, deney prosedürlerini ve değerlendirme yöntemlerini sunmaktır. İzole laboratuvar ortamlarında güvenli ve etik araştırmalar yürütülmesi için gerekli ilkeler ve uygulamalar detaylı olarak ele alınmaktadır.

Araştırma Soruları

1. İzole laboratuvar ortamı nasıl tasarlanır?
2. Sentetik veri üretimi için hangi yöntemler kullanılır?
3. Hash performansı ve parola uzunluğu deneyleri nasıl yürütülür?
4. MFA ve passkey simülasyonları nasıl gerçekleştirilir?
5. Politika değerlendirme atölyeleri nasıl düzenlenir?

Detaylı Açıklama

İzole Laboratuvar İlkeleri

İzole laboratuvar, gerçek üretim ortamından tamamen bağımsız, kontrollü bir araştırma ortamıdır. Bu ortamda, gerçek kullanıcı verileri veya sistemleri riske atılmadan, güvenlik testleri ve deneyler yapılabilir. İzole laboratuvarın temel ilkeleri şunlardır:

1. **Fiziksel İzolasyon:** Laboratuvar, üretim ağından ayrı bir ağda yer almalıdır. Yalnızca kontrollü köprülerle bağlantı kurulabilir.
2. **Veri İzolasyonu:** Gerçek kullanıcı verileri kullanılmamalıdır. Yalnızca sentetik veya anonimleştirilmiş veriler tercih edilmelidir.

3. **Erişim Kontrolü:** Laboratuvara erişim, yalnızca yetkili araştırmacılara açılmalıdır. Çok faktörlü kimlik doğrulama zorunlu olmalıdır.
4. **Loglama ve İzleme:** Tüm etkinlikler loglanmalıdır. Anormal davranışlar için otomatik uyarılar tanımlanmalıdır.
5. **Acil Durum Prosedürleri:** Laboratuvarın kapatılması veya izolasyonu için acil durum prosedürleri hazır olmalıdır.

Sentetik Veri Üretimi

Sentetik veri üretimi, laboratuvar çalışmalarının temel bir bileşenidir. Gerçekçi ancak gizliliği koruyan veriler üretmek için çeşitli yöntemler kullanılır:

Rastgele Parola Üretimi: Belirli karakter setlerinden (büyük harf, küçük harf, rakam, özel karakter) rastgele parolalar üretilir. Bu parolalar, gerçek kullanıcı parolalarının istatistiksel özelliklerini (uzunluk dağılımı, karakter dağılımı) taklit eder.

Zayıf Parola Kümeleri: Yaygın kullanılan zayıf parolaların sentetik versiyonları üretilir. Bu kümeler, parola politikalarının etkinliğini test etmek için kullanılır.

Biyometrik Veri Simülasyonu: Parmak izi, yüz tanıma gibi biyometrik verilerin simüle edilmiş versiyonları üretilir. Bu simülasyonlar, biyometrik kimlik doğrulama sistemlerinin test edilmesini sağlar.

Sosyal Mühendislik Senaryoları: Phishing, spear phishing gibi sosyal mühendislik saldırılarının simüle edilmesi için sentetik senaryolar oluşturulur.

Hash Performansı ve Teorik Maliyet

Hash algoritmalarının performansı, parola depolama açısından kritik öneme sahiptir. Farklı hash algoritmalarının hızları ve maliyetleri karşılaştırılmalıdır:

bcrypt: Ayarlanabilir bir maliyet faktörüyle çalışır. Maliyet arttıkça hash hesaplama süresi üstel olarak artar; değer üretim donanımında ölçülerek seçilmelidir.

Argon2: Memory-hard bir algoritmadır. Hem zaman hem de bellek kullanımı açısından parametrelendirilebilir. GPU tabanlı saldırılara karşı daha dayanıklıdır.

PBKDF2: HMAC tabanlı bir key derivation function'dır. Basit ve geniş çapta desteklenen bir algoritmadır.

Laboratuvar ortamında, bu algoritmaların farklı parametrelerle performans testleri yapılabilir. Sonuçlar, parola politikası kararlarına rehberlik eder.

Parola Uzunluğu ve Tahmin Uzayı Deneyleri

Parola uzunluğu ile tahmin uzayı arasındaki ilişki, kritik bir araştırma konusudur. Bu deneylerde:

Brute Force Analizi: Farklı uzunluklardaki parolaların brute force ile kırılma süreleri hesaplanır. Bu hesaplamalar, teorik olarak yapılır; gerçek saldırılar simüle edilmez.

Mask Attack Simülasyonu: Belirli kalıplara uyan parolaların kırılma süreleri analiz edilir. Bu analizler, parola politikalarının etkinliğini değerlendirmek için kullanılır.

Dictionary Attack Karşılaştırması: Farklı sözlük boyutlarının etkisi incelenir. Sözlük saldırısının parola uzunluğu ve karmaşıklığına bağlı olarak nasıl değiştiği gösterilir.

MFA/Passkey Simülasyonu

Çok faktörlü kimlik doğrulama (MFA) ve passkey sistemlerinin simülasyonu, laboratuvar çalışmalarının önemli bir bileşenidir:

TOTP Simülasyonu: Zaman bazlı tek seferlik şifrelerin (TOTP) üretimi ve doğrulanması simüle edilir. Farklı algoritmalar (HMAC-SHA1, HMAC-SHA256) test edilir.

WebAuthn Simülasyonu: FIDO2 tabanlı passkey sistemlerinin akışları simüle edilir. Kayıt, kimlik doğrulama ve kimlik yönetimi süreçleri test edilir.

SMS/Email OTP Simülasyonu: Kısa mesaj veya e-posta ile gönderilen tek seferlik şifrelerin simülasyonu yapılır. Teslim süresi ve güvenilirlik analizleri gerçekleştirilir.

Politika Değerlendirme Atölyesi

Parola politikalarının etkinliğini değerlendirmek için atölye çalışmaları düzenlenir:

Politika Oluşturma: Katılımcılar, belirli gereksinimlere yönelik parola politikaları tasarlar.

Politika Testi: Oluşturulan politikalar, sentetik verilerle test edilir. Politikanın ne kadar etkili olduğu değerlendirilir.

Politika Karşılaştırma: Farklı politikaların avantaj ve dezavantajları karşılaştırılır. En uygun politika belirlenir.

Uygulama Zorlukları: Politikaların uygulanmasında karşılaşılan zorluklar tartışılır. Kullanıcı deneyimi ile güvenlik arasındaki denge ele alınır.

Farkındalık Senaryoları

Siber güvenlik farkındalığını artırmak için çeşitli senaryolar kullanılır:

Phishing Senaryoları: Farklı türde phishing e-postalarının örnekleri gösterilir (gerçek saldırı yapılmaz). Katılımcılar, bu e-postaları tespit etmeye çalışır.

Sosyal Mühendislik Senaryoları: Sosyal mühendislik saldırılarının farklı yöntemleri tartışılır. Savunma stratejileri geliştirilir.

Güvenlik Olayı Müdahalesi: Bir güvenlik olayının simülasyonu yapılır. Katılımcılar, olaya nasıl müdahale edeceklerini uygular.

Laboratuvar Kuralları

Laboratuvar kullanımı için aşağıdaki kurallar geçerlidir:

1. Gerçek kullanıcı verileri kullanılmaz
2. Gerçek sistemlere erişim yapılmaz
3. Saldırı araçları yalnızca izole ortamda çalıştırılır
4. Tüm etkinlikler loglanır
5. Etik kurul onayı olmadan deney yapılmaz
6. Bulgu paylaşımı için sorumlu açıklama prosedürleri izlenir
7. Laboratuvar çıkışında tüm veriler temizlenir

Öğrenci Deney Föyleri

Her deney için ayrıntılı bir föy hazırlanır. Föy şu bölümleri içerir:

Amaç: Deneyin amacı ve öğrenme çıktıları **Ön Bilgi:** Gerekli teorik bilgiler
Gereçler: Kullanılacak araçlar ve malzemeler **Yöntem:** Adım adım prosedür
Gözlemler: Kaydedilmesi gereken gözlemler **Sonuçlar:** Beklenen sonuçlar ve analiz
Tartışma: Sonuçların değerlendirilmesi

Değerlendirme Rubriği

Öğrencilerin performansı aşağıdaki rubriğe göre değerlendirilir:

Kriter	Mükemmel (5)	İyi (4)	Orta (3)	Zayıf (2)	Yetersiz (1)
Teknik Beceri	Tüm prosedürleri eksiksiz uygular	Küçük hatalarla uygular	Temel prosedürleri uygular	Kısmen uygular	Uygulayamaz
Analiz Yeteneği	Derinlemesine analiz yapar	İyi analiz yapar	Temel analiz yapar	Yüzeysel analiz	Analiz yapamaz
Raporlama	Kapsamlı ve net rapor	İyi rapor	Kabul edilebilir rapor	Eksik rapor	Rapor yok
Etik Uygunluk	Tam uyum	Uygun	Kısmen uygun	Uygun değil	İhlal

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenciler: 1. İzole laboratuvar ortamı tasarlayabilir 2. Sentetik veri üretebilir 3. Hash performans testleri yapabilir 4. Parola uzunluğu ve tahmin uzayı deneyleri yürütebilir 5. MFA ve passkey simülasyonları gerçekleştirebilir 6. Politika değerlendirme atölyeleri düzenleyebilir 7. Farkındalık senaryoları geliştirebilir

Risk Modeli

Risk	Olasılık	Etki	Risk Seviyesi	Kontrol
Laboratuvar sızıntısı	Düşük	Yüksek	Orta	İzolasyon, erişim kontrolleri
Veri ihlali	Düşük	Yüksek	Orta	Sentetik veri, loglama

Risk	Olasılık	Etki	Risk Seviyesi	Kontrol
Etik ihlal	Düşük	Yüksek	Orta	Etik kurul, yönergeler
Ekipman arızası	Orta	Düşük	Düşük	Yedekleme, bakım
Yetkisiz erişim	Orta	Yüksek	Yüksek	MFA, fiziksel güvenlik

Savunma Kontrolleri

- Fiziksel İzolasyon:** Üretim ağından bağımsız laboratuvar ağı
- Erişim Kontrolleri:** Rol tabanlı erişim, MFA
- Loglama:** Tüm etkinliklerin kaydedilmesi
- Veri Koruma:** Şifreleme, maskeleyme
- Acil Durum:** İzolasyon ve kapatma prosedürleri

Tablolar

Tablo 14.1: Hash Algoritması Karşılaştırması

Algoritma	Bellek Kullanımı	Hız	Güvenlik Seviyesi	Önerilen Kullanım
bcrypt	Düşük	Orta	Yüksek	Genel kullanım
Argon2	Yüksek	Düşük	Çok Yüksek	Yüksek güvenlik
PBKDF2	Düşük	Yüksek	Orta	Uyum gereksinimleri
Scrypt	Yüksek	Orta	Yüksek	Bellek tabanlı savunma

Tablo 14.2: Parola Uzunluğu ve Tahmin Uzayı

Uzunluk	Karakter Seti	Tahmin Uzayı	Brute Force Süresi
8	Rakam	10^8	Saniyeler
8	Büyük+Küçük Harf	52^8	Saatler

Uzunluk	Karakter Seti	Tahmin Uzayı	Brute Force Süresi
12	Tüm Karakterler	95^{12}	Yıllar
16	Tüm Karakterler	95^{16}	Milyarlarca Yıl

Güvenli Anlatım Notu

Bu bölümde, gerçek saldırı araçları veya komutları verilmemiştir. Tüm deneyler, izole laboratuvar ortamında ve etik çerçevenin içinde yürütülmüştür. Sentetik veriler kullanılmıştır. Okuyucular, burada sunulan bilgileri yalnızca akademik araştırma ve eğitim için kullanmalıdır.

Özet

Bu bölüm, parola ve kimlik doğrulama güvenliği alanında akademik laboratuvar tasarımı için gerekli ilkeleri, yöntemleri ve araçları sunmuştur. İzole laboratuvar ortamı tasarımı, sentetik veri üretimi, hash performans testleri, MFA simülasyonları ve politika değerlendirme atölyeleri detaylı olarak ele alınmıştır.

Kontrol Listesi

- [] Laboratuvar izole edildi
- [] Sentetik veri üretildi
- [] Hash performans testleri planlandı
- [] Parola uzunluğu deneyleri tasarlandı
- [] MFA simülasyonları hazırlandı
- [] Politika değerlendirme atölyesi düzenlendi
- [] Farkındalık senaryoları oluşturuldu
- [] Laboratuvar kuralları belirlendi
- [] Deney föyleri hazırlandı
- [] Değerlendirme rubriği oluşturuldu

Tartışma Soruları

1. İzole laboratuvar ortamı, gerçek dünya koşullarını ne ölçüde yansıtıyor?
2. Sentetik veri üretimi, araştırmanın geçerliliğini nasıl etkiliyor?
3. Hash algoritması seçimi hangi faktörlere bağlıdır?
4. MFA simülasyonları, gerçek dünya uygulamalarından hangi açılardan farklıdır?
5. Politika değerlendirme atölyeleri, kurumsal politika tasarımına nasıl katkı sağlar?

Kaynaklar

1. OWASP. (t.y.). *Web Security Testing Guide*. Open Worldwide Application Security Project.
 2. NIST. (2025). *Digital Identity Guidelines: Authentication and Authenticator Management (SP 800-63B-4)*. National Institute of Standards and Technology.
 3. OWASP. (t.y.). *Password Storage Cheat Sheet*. Open Worldwide Application Security Project.
 4. FIDO Alliance. (2023). *FIDO2 Specifications*. Fast Identity Online Alliance.
-

BÖLÜM 15 — KONTROL LİSTELERİ

[↩ İçindekilere dön](#)

Amaç

Bu bölümün amacı, farklı roller için parola ve kimlik doğrulama güvenliği kontrol listeleri sunmaktır. Bu kontrol listeleri, bireysel kullanıcılar, sistem yöneticileri, geliştiriciler, SOC analistleri, yöneticiler ve denetçiler için uygulanabilir maddeler içermektedir.

Araştırma Soruları

1. Farklı roller için güvenlik kontrolleri nasıl sınıflandırılabilir?
2. Her rol için öncelikli güvenlik tedbirleri nelerdir?
3. Kontrol listeleri nasıl uygulanabilir ve ölçülebilir hale getirilir?

Detaylı Açıklama

Bireysel Kullanıcı Kontrol Listesi

Bireysel kullanıcılar, kimlik doğrulama güvenliğinin ilk savunma hattını oluşturur. Bu kontrol listesi, günlük kullanımda uygulanabilecek pratik tedbirleri içerir:

Parola Yönetimi: - ☐ Her hesap için benzersiz parola kullanın - ☐ Parolaları en az 12 karakter uzunluğunda tutun - ☐ Büyük harf, küçük harf, rakam ve özel karakter karışımı kullanın - ☐ Kişisel bilgilerinizi (ad, doğum tarihi vb.) parola olarak kullanmayın - ☐ Parolaları düzenli olarak değiştirin (en az yılda bir) - ☐ Parolaları_NOT_kağıtlarına veya metin dosyalarına yazmayın - ☐ Parola yöneticisi kullanın

Çok Faktörlü Kimlik Doğrulama (MFA): - ☐ Tüm önemli hesaplarınızda MFA'yı etkinleştirin - ☐ SMS tabanlı MFA yerine uygulama tabanlı MFA tercih edin - ☐ Yedek kurtarma kodlarını güvenli bir yerde saklayın - ☐ Donanım anahtarı (FIDO2) kullanın

Güvenlik Farkındalığı: - [] Phishing e-postalarını tanıyın - [] Şüpheli bağlantılara tıklamayın - [] Kamu Wi-Fi ağlarında hassas işlemler yapmayın - [] Düzenli olarak güvenlik eğitimlerine katılın

Cihaz Güvenliği: - [] İşletim sisteminizi ve yazılımlarınızı güncel tutun - [] Antivirüs yazılımı kullanın - [] Ekran kilidi etkinleştirin - [] Uzaktan erişim özelliklerini devre dışı bırakın

Sistem Yöneticisi Kontrol Listesi

Sistem yöneticileri, kimlik doğrulama altyapısının güvenliğinden sorumludur:

Erişim Kontrolleri: - [] Rol tabanlı erişim kontrolü (RBAC) uygulayın - [] En az ayrıcalık ilkesini uygulayın - [] Varsayılan hesapları devre dışı bırakın veya değiştirin - [] Geçici hesapları düzenli olarak gözden geçirin - [] Hesap kilitlenme politikası tanımlayın

Parola Politikaları: - [] Minimum parola uzunluğunu 12 karakter olarak ayarlayın - [] Karmaşık parola zorunluluğu getirin - [] Parola geçmişini en az 12 geçmişe ayarlayın - [] Parola süre sınırını politikanıza göre belirleyin

Kimlik Doğrulama Sistemleri: - [] MFA'yı zorunlu kılın - [] SSO (Single Sign-On) uygulayın - [] Federasyonlu kimlik doğrulamayı değerlendirin - [] Passkey/FIDO2 desteğini ekleyin

Loglama ve İzleme: - [] Tüm kimlik doğrulama olaylarını loglayın - [] Başarısız giriş denemelerini izleyin - [] Anormal oturum açma davranışları için uyarılar tanımlayın - [] Logları merkezi bir sistema toplayın

Güncelleme ve Yama Yönetimi: - [] Kimlik doğrulama yazılımlarını düzenli olarak güncelleyin - [] Güvenlik yamalarını hemen uygulayın - [] Eski sürümleri devre dışı bırakın

Geliştirici Kontrol Listesi

Yazılım geliştiriciler, kimlik doğrulama mekanizmalarını tasarlar ve uygular:

Parola Saklama: - [] Parolaları asla düz metin olarak saklamayın - [] bcrypt, Argon2 veya PBKDF2 kullanın - [] Her parola için benzersiz tuz (salt) oluşturun - [] Work factor'ı uygun şekilde ayarlayın - [] Parola hash'lerini veritabanında ayrı bir tabloda saklayın

Kimlik Doğrulama Akışları: - ☐ OAuth 2.0 ve OpenID Connect standartlarını uygulayın - ☐ Güçlü parola politikaları uygulayın - ☐ Hesap kilitleme mekanizması ekleyin - ☐ Kurtarma akışlarını güvenli hale getirin - ☐ Oturum yönetimini güvenli şekilde uygulayın

API Güvenliği: - ☐ Token tabanlı kimlik doğrulama kullanın - ☐ JWT'leri güvenli şekilde imzalayın - ☐ Token sürelerini kısa tutun - ☐ Refresh token'ları güvenli saklayın

Test ve Doğrulama: - ☐ Güvenlik testleri yapın - ☐ SAST ve DAST araçları kullanın - ☐ Parola politikalarını test edin - ☐ Kimlik doğrulama akışlarını test edin

SOC Analisti Kontrol Listesi

Güvenlik Operasyon Merkezi (SOC) analistleri, kimlik doğrulama olaylarını izler ve yanıt verir:

Olay İzleme: - ☐ Brute force saldırılarını izleyin - ☐ Credential stuffing saldırılarını tespit edin - ☐ Anormal oturum açma davranışlarını analiz edin - ☐ Coğrafi sapmaları izleyin - ☐ Cihaz parmak izi sapmalarını izleyin

Olay Yanıtı: - ☐ Kimlik doğrulama olayları için yanıt prosedürleri oluşturun - ☐ Şüpheli oturumları otomatik olarak sonlandırın - ☐ Hesapları geçici olarak devre dışı bırakın - ☐ Kullanıcılara bildirim gönderin

Tehdit İstihbaratı: - ☐ Sızıntıya uğramış parola veritabanlarını izleyin - ☐ Dark web monitoring yapın - ☐ Tehdit istihbaratı paylaşımlarına katılın

Raporlama: - ☐ Düzenli güvenlik raporları oluşturun - ☐ Trend analizleri yapın - ☐ İyileştirme önerileri sunun

Yönetici Kontrol Listesi

Kurum yöneticileri, güvenlik stratejisi ve politikalarından sorumludur:

Stratejik Planlama: - ☐ Güvenlik stratejisi oluşturun - ☐ Risk değerlendirme süreci kurun - ☐ Bütçe ayırın - ☐ Kaynak tahsis edin

Politika ve Prosedür: - ☐ Kimlik doğrulama politikası oluşturun - ☐ Erişim kontrol politikası oluşturun - ☐ Olay yanıtı prosedürleri tanımlayın - ☐ Politikaları düzenli olarak gözden geçirin

Uyumluluk: - ☐ KVKK uyumunu sağlayın - ☐ Endüstri standartlarına uyun (ISO 27001, SOC 2) - ☐ Düzenli denetimler yaptırın - ☐ Uyumluluk raporları hazırlayın

Eğitim ve Farkındalık: - ☐ Çalışanlara güvenlik eğitimi verin - ☐ Phishing simülasyonları düzenleyin - ☐ Güvenlik farkındalığını artırın

Vaka Yönetimi: - ☐ Güvenlik olayı müdahale planı oluşturun - ☐ Ekibi eğitin - ☐ Düzenli tatbikatlar yapın

Denetçi Kontrol Listesi

Denetçiler, kimlik doğrulama kontrollerinin etkinliğini değerlendirir:

Denetim Planlaması: - ☐ Denetim kapsamını belirleyin - ☐ Denetim kriterlerini tanımlayın - ☐ Denetim ekibini oluşturun - ☐ Denetim takvimi hazırlayın

Kontrol Değerlendirmesi: - ☐ Erişim kontrollerini test edin - ☐ Parola politikalarını değerlendirin - ☐ MFA uygulamasını denetleyin - ☐ Loglama mekanizmasını inceleyin - ☐ Olay yanıtı prosedürlerini değerlendirin

Uyumluluk Değerlendirmesi: - ☐ KVKK uyumunu denetleyin - ☐ Endüstri standartlarına uygunluğu değerlendirin - ☐ Sözleşme gereksinimlerini kontrol edin

Raporlama: - ☐ Bulguları belgeleyin - ☐ Risk seviyelerini değerlendirin - ☐ İyileştirme önerileri sunun - ☐ Takip planı oluşturun

Takip ve İzleme: - ☐ Düzeltme eylemlerini izleyin - ☐ İyileştirmeleri doğrulayın - ☐ Düzenli gözden geçirmeler yapın

Öğrenme Çıktıları

Bu bölümü tamamlayan öğrenciler: 1. Farklı roller için güvenlik kontrol listelerini uygulayabilir 2. Kontrol listelerini kişisel ihtiyaçlarına göre uyarlayabilir 3. Kontrol listelerinin etkinliğini değerlendirebilir 4. Düzenli denetim ve gözden geçirme süreçlerini uygulayabilir

Risk Modeli

Risk	Olasılık	Etki	Risk Seviyesi	Kontrol
Zayıf parola kullanımı	Yüksek	Yüksek	Yüksek	Politikalar, eğitim
MFA devre dışı bırakma	Orta	Yüksek	Yüksek	Zorunlu MFA, izleme
Log eksikliği	Orta	Yüksek	Yüksek	Loglama politikaları
Eğitim eksikliği	Yüksek	Orta	Yüksek	Düzenli eğitimler
Politika uygulamaması	Orta	Yüksek	Yüksek	Denetim, uyumluluk

Savunma Kontrolleri

- Önleyici Kontroller:** Politikalar, eğitimler, erişim kontrolleri
- Tespit Kontrolleri:** Loglama, izleme, uyarılar
- Düzeltilici Kontroller:** Olay yanıtı, kurtarma prosedürleri
- Kovucu Kontroller:** Yaptırımlar, sigorta

Tablolar

Tablo 15.1: Rol Bazlı Kontrol Listesi Özeti

Rol	Kritik Kontroller	Öncelik
Bireysel Kullanıcı	Benzersiz parola, MFA	Yüksek
Sistem Yöneticisi	RBAC, loglama	Kritik
Geliştirici	Güvenli kodlama, test	Yüksek
SOC Analisti	İzleme, yanıt	Kritik
Yönetici	Strateji, politika	Yüksek
Denetçi	Değerlendirme, raporlama	Yüksek

Tablo 15.2: Kontrol Listesi Uygulama Aşamaları

Aşama	Açıklama	Süre
Hazırlık	İhtiyaçların belirlenmesi	1-2 hafta
Uygulama	Kontrollerin devreye alınması	2-4 hafta
Doğrulama	Kontrollerin test edilmesi	1-2 hafta
İzleme	Sürekli gözetim	Sürekli
İyileştirme	Sürekli optimizasyon	Sürekli

Güvenli Anlatım Notu

Bu bölümde, kontrol listeleri yalnızca savunma amaçlı sunulmuştur. Saldırı amaçlı kullanılmamalıdır. Tüm kontroller, yasal ve etik çerçevenin içinde uygulanmalıdır.

Özet

Bu bölüm, farklı roller için parola ve kimlik doğrulama güvenliği kontrol listeleri sunmuştur. Bireysel kullanıcılardan denetçilere kadar her rol için uygulanabilir maddeler hazırlanmıştır. Kontrol listeleri, pratik ve ölçülebilir bir güvenlik yaklaşımı sunmaktadır.

Kontrol Listesi

- [] Bireysel kullanıcı kontrol listesi hazırlandı
- [] Sistem yöneticisi kontrol listesi hazırlandı
- [] Geliştirici kontrol listesi hazırlandı
- [] SOC analisti kontrol listesi hazırlandı
- [] Yönetici kontrol listesi hazırlandı
- [] Denetçi kontrol listesi hazırlandı
- [] Tüm listeler uygulanabilir maddeler içeriyor

Tartışma Soruları

1. Hangi kontrol, en yüksek etkiye sahiptir? Neden?
2. Kontrol listeleri, gerçek dünya koşullarında nasıl uyarlanabilir?
3. Küçük işletmeler için kontrol listeleri nasıl basitleştirilebilir?
4. Otomatik kontrol mekanizmaları, manuel kontrollerin yerini alabilir mi?
5. Kontrol listelerinin etkinliği nasıl ölçülebilir?

Kaynaklar

1. NIST. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology.
2. OWASP. (t.y.). *Application Security Verification Standard*. Open Worldwide Application Security Project.
3. ISO/IEC 27001. (2022). *Information Security Management Systems*. International Organization for Standardization.

SONUÇ VE GELECEK EĞİLİMLER

[↩ İçindekilere dön](#)

Araştırma Sorularına Toplu Yanıt

Bu çalışmanın temel sonucu, parola riskinin tek bir kontrolle yönetilemeyeceğidir. Güvenli sonuç; kullanıcı seçimi, parola yöneticisi desteği, uygun hash şeması, hız sınırlama, güvenli kurtarma, MFA, oturum yönetimi, izleme ve olay müdahalesinin birlikte çalışmasına bağlıdır. Politika, kullanıcıya biçimsel karmaşıklık yüklemekten çok saldırganın çevrim içi ve çevrim dışı tahmin kapasitesini sınırlamalıdır.

Parola saklamada genel amaçlı başlangıç noktası, hedef sistemde ölçülerek ayarlanmış Argon2id'dir. FIPS gibi bağlama özgü gereksinimler PBKDF2 kullanımını gerektirebilir. Hiçbir algoritma adı tek başına güvenli uygulama anlamına gelmez; benzersiz salt, parametre sürümler, sır yönetimi, kütüphane davranışı ve göç planı birlikte değerlendirilmelidir.

MFA yöntemleri eşdeğer değildir. SMS ve tek kullanımlık kodlar bazı tehditleri azaltır, ancak gerçek zamanlı kimlik avına karşı sınırlıdır. WebAuthn/FIDO2 tabanlı doğrulayıcılar, doğrulama işlemini hizmet kökenine bağlayarak kimlik avına karşı daha güçlü protokol güvencesi sunar. Buna karşın cihaz kaybı, senkronizasyon, kayıt, hesap kurtarma ve yaşam döngüsü sorunlarını ortadan kaldırmaz.

Öncelikli Kurumsal Yol Haritası

Öncelik	Kontrol	Başarı ölçütü
1	Ayrıcalıklı ve yüksek riskli hesaplarda kimlik avına dayanıklı MFA	Kapsama oranı, istisna sayısı, kurtarma testi
2	Benzersiz parola ve parola yöneticisi desteği	Otomatik doldurma/yapıştırma desteği, tekrar kullanım sinyali

Öncelik	Kontrol	Başarı ölçütü
3	Güncel parola politikası	Tek faktörde 15 karakter, engelli parola listesi, gereksiz periyodik değişimin kaldırılması
4	Güvenli parola saklama ve göç	Algoritma/parametre envanteri, yeniden hash oranı, sızma testi kanıtı
5	Kurtarma ve oturum güvenliği	Kimlik doğrulanmış kurtarma, toplu oturum iptali tatbikatı
6	Kimlik telemetrisi ve olay müdahalesi	Tespit kapsamı, ortalama müdahale süresi, senaryo tatbikatı
7	Passkey geçişi	Uyumlu istemci oranı, kayıt/kurtarma başarısı, parola geri dönüş riskleri

Gelecek Eğilimleri ve Araştırma Açıkları

Passkey yaygınlaşması: Araştırma, yalnızca kayıt sayısını değil; hesap kurtarma güvenliği, platformlar arası taşınabilirlik, kurumsal cihaz yönetimi ve parola geri dönüş yolunun toplam güvenliğini ölçmelidir.

Davranışsal ve risk tabanlı doğrulama: Makine öğrenmesi tabanlı risk puanları ek sinyal sağlayabilir; ancak tek başına kimlik kanıtı değildir. Yanlış pozitifler, erişilebilirlik, ayrımcılık, model kayması, açıklanabilirlik ve kişisel veri minimizasyonu değerlendirilmelidir.

Biyometrik doğrulama: Biyometri çoğu platformda özel anahtarı etkinleştiren yerel kullanıcı doğrulaması olarak çalışır; biyometrik şablonun uzak hizmete gönderilmesi gerekmez. Gelecek çalışmalar sunum saldırısı tespiti, şablon koruma, geri alınabilirlik ve erişilebilirlik üzerinde durmalıdır.

Üretken yapay zekâ ve sosyal mühendislik: Daha inandırıcı kimlik avı ve taklit içerikleri insan onayına dayalı süreçlerin riskini artırır. Savunma araştırması, içerik sınıflandırmasından çok işlem bütünlüğü, bağımsız kanal doğrulaması ve kimlik avına dayanıklı protokollerin ölçülebilir etkisine odaklanmalıdır.

Post-kuantum geçiş: Parola hash'leme ile açık anahtar kimlik doğrulamasının kuantum riskleri aynı değildir. Araştırma; WebAuthn ekosistemindeki imza algoritmalarının kript-çevikliği, doğrulayıcı yaşam süresi ve geriye dönük uyumluluğu ayrı ayrı incelemelidir.

Son Değerlendirme

Parolalar kısa vadede bütünüyle ortadan kalkmayacaktır; fakat güvenlik mimarisinin merkezinde tek başına tutulmaları gerekmemektedir. Olgun bir program, parolayı yönetilen bir bileşene indirger; kimlik avına dayanıklı doğrulama, güvenli kurtarma, cihaz ve oturum güvencesi ile ölçülebilir izlemeyi birlikte işletir. Passkey geçişi bu hedefe katkı sağlar, ancak kötü tasarlanmış geri dönüş ve kurtarma yolları güçlü ön kanalı etkisizleştirebilir. Kurumlar teknoloji adlarını değil, uçtan uca tehdit modelini ve doğrulanabilir kontrol sonuçlarını yönetmelidir.

Tartışma Soruları

1. Parola politikasının başarısı hangi teknik ve kullanıcı odaklı ölçütlerle birlikte değerlendirilmelidir?
 2. Passkey kullanılan bir sistemde en zayıf halka neden hesap kurtarma süreci olabilir?
 3. Risk tabanlı doğrulama modellerinde yanlış pozitif ile hesap ele geçirme riski nasıl dengelenmelidir?
 4. Ayrıcalıklı hesaplarda kimlik avına dayanıklı MFA'ya geçiş için hangi istisnalar kabul edilebilir?
 5. Post-kuantum geçiş planı parola saklama ve WebAuthn bileşenlerini neden farklı ele almalıdır?
-

KAYNAKÇA

↪ İçindekilere dön

Sürekli güncellenen web kaynakları için son erişim tarihi: 21 Haziran 2026.

Standartlar ve Resmî Teknik Rehberler

1. National Institute of Standards and Technology. (2025). *Digital Identity Guidelines: Authentication and Authenticator Management (NIST SP 800-63B-4)*. <https://doi.org/10.6028/NIST.SP.800-63B-4>
2. National Institute of Standards and Technology. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management (NIST SP 800-61 Rev. 3)*. <https://doi.org/10.6028/NIST.SP.800-61r3>
3. National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. <https://doi.org/10.6028/NIST.CSWP.29>
4. National Institute of Standards and Technology. (2020). *Zero Trust Architecture (NIST SP 800-207)*. <https://doi.org/10.6028/NIST.SP.800-207>
5. National Institute of Standards and Technology. (t.y.). *Post-Quantum Cryptography Project*. <https://csrc.nist.gov/projects/post-quantum-cryptography>
6. Open Worldwide Application Security Project. (t.y.). *Authentication Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
7. Open Worldwide Application Security Project. (t.y.). *Password Storage Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
8. Open Worldwide Application Security Project. (t.y.). *Multifactor Authentication Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html

9. Open Worldwide Application Security Project. (t.y.). *Forgot Password Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html
10. Open Worldwide Application Security Project. (t.y.). *Session Management Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
11. Open Worldwide Application Security Project. (t.y.). *Logging Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html
12. World Wide Web Consortium. (2021). *Web Authentication: An API for accessing public key credentials — Level 2*. <https://www.w3.org/TR/webauthn-2/>
13. FIDO Alliance. (t.y.). *FIDO2: WebAuthn & CTAP*. <https://fidoalliance.org/fido2/>
14. FIDO Alliance. (t.y.). *Passkeys Resource Center*. <https://fidoalliance.org/passkeys/>
15. Cybersecurity and Infrastructure Security Agency. (2023). *Zero Trust Maturity Model, Version 2.0*. <https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model>
16. Cybersecurity and Infrastructure Security Agency. (2023). *Phishing Guidance: Stopping the Attack Cycle at Phase One*. <https://www.cisa.gov/resources-tools/resources/phishing-guidance-stopping-attack-cycle-phase-one>
17. International Organization for Standardization. (2022). *ISO/IEC 27001:2022 — Information security management systems — Requirements*.
18. International Organization for Standardization. (2022). *ISO/IEC 27002:2022 — Information security controls*.
19. International Organization for Standardization. (2018). *ISO/IEC 29147:2018 — Vulnerability disclosure*.
20. International Organization for Standardization. (2019). *ISO/IEC 30111:2019 — Vulnerability handling processes*.

Protokoller

21. Biryukov, A., Dinu, D., Khovratovich, D., & Josefsson, S. (2021). *Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications (RFC 9106)*. <https://doi.org/10.17487/RFC9106>
22. Rescorla, E. (2018). *The Transport Layer Security (TLS) Protocol Version 1.3 (RFC 8446)*. <https://doi.org/10.17487/RFC8446>
23. Jones, M., Bradley, J., & Sakimura, N. (2015). *JSON Web Token (JWT) (RFC 7519)*. <https://doi.org/10.17487/RFC7519>
24. Hardt, D. (2012). *The OAuth 2.0 Authorization Framework (RFC 6749)*. <https://doi.org/10.17487/RFC6749>
25. M'Raihi, D., Machani, S., Pei, M., & Rydell, J. (2011). *TOTP: Time-Based One-Time Password Algorithm (RFC 6238)*. <https://doi.org/10.17487/RFC6238>

Hakemli ve Akademik Çalışmalar

26. Bonneau, J., Herley, C., van Oorschot, P. C., & Stajano, F. (2012). The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. *2012 IEEE Symposium on Security and Privacy*, 553–567. <https://doi.org/10.1109/SP2012.44>
27. Das, A., Bonneau, J., Caesar, M., Borisov, N., & Wang, X. (2014). The tangled web of password reuse. *Network and Distributed System Security Symposium (NDSS)*. <https://doi.org/10.14722/ndss.2014.23357>
28. Florêncio, D., & Herley, C. (2007). A large-scale study of web password habits. *Proceedings of the 16th International Conference on World Wide Web*, 657–666. <https://doi.org/10.1145/1242572.1242661>
29. Shay, R., Komanduri, S., Kelley, P. G., Leon, P. G., Mazurek, M. L., Bauer, L., Christin, N., & Cranor, L. F. (2010). Encountering stronger password requirements: User attitudes and behaviors. *Sixth Symposium on Usable Privacy and Security*. <https://dl.acm.org/doi/10.5555/1837110.1837113>

30. Ur, B., Bees, J., Segreti, S. M., Bauer, L., Christin, N., & Cranor, L. F. (2015). "I added '!' at the end to make it secure": Observing password creation in the lab. *Eleventh Symposium on Usable Privacy and Security*, 123-140. <https://www.usenix.org/conference/soups2015/proceedings/presentation/ur>
31. Habib, H., Colnago, J., Melicher, W., Ur, B., Segreti, S., Bauer, L., Christin, N., & Cranor, L. F. (2017). Password creation in the presence of blacklists. *Workshop on Usable Security*. <https://doi.org/10.14722/usec.2017.23043>
32. Egelman, S., Cranor, L. F., & Hong, J. (2008). You've been warned: An empirical study of the effectiveness of web browser phishing warnings. *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, 1065-1074. <https://doi.org/10.1145/1357054.1357219>
33. Stajano, F., & Wilson, P. (2011). Understanding scam victims: Seven principles for systems security. *Communications of the ACM*, 54(3), 70-75. <https://doi.org/10.1145/1897852.1897872>

Hukuki Kaynaklar

34. 6698 sayılı Kişisel Verilerin Korunması Kanunu. (2016, güncel metin). <https://www.mevzuat.gov.tr/mevzuatmetin/1.5.6698.pdf>
35. 5237 sayılı Türk Ceza Kanunu. (2004, güncel metin). <https://www.mevzuat.gov.tr/mevzuatmetin/1.5.5237.pdf>
36. European Union. (2016). *Regulation (EU) 2016/679 (General Data Protection Regulation)*. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>